FUNDAMENTALS OF CYBER SECURITY

(R22A6215)

Lecture Notes

B.TECH
(III YEAR – II SEM)
(2025-2026)

Prepared by:

Ms.Anitha Patibandla, Associate Professor
Department of Electronics and Communication Engineering

MALLA REDDY COLLEGE OF ENGINEERING & TECHNOLOGY

(Autonomous Institution – UGC, Govt. of India)

Recognized under 2(f) and 12 (B) of UGC ACT 1956
(Affiliated to JNTUH, Hyderabad, Approved by AICTE - Accredited by NBA & NAAC – 'A' Grade - ISO 9001:2015 Certified)
Maisammaguda, Dhulapally (Post Via. Kompally), Secunderabad – 500100, Telangana State, India



MALLA REDDY COLLEGE OF ENGINEERING AND TECHNOLOGY

B.Tech -III Year-II Sem (ECE) **L/T/P/C**
3/-/-/3

(R22A6215) FUNDAMENTALS OF CYBER SECURITY

COURSE OBJECTIVES

1. To understand the basic concepts of cyber-Security.
2. To study different attacks in cyber-crimes.
3. To understand different tools and methods used in cyber-crime.
4. To study cyber security challenges and implications.
5. To know about Cyber Security Organizational Issues, Policies.

UNIT I

Introduction to Cyber Security: Basic Cyber Security Concepts, layers of security, Vulnerability, threat, Harmful acts, Internet Governance – Challenges and Constraints, Computer Criminals, CIA Triad, Assets and Threat, motive of attackers, active attacks, passive attacks, Software attacks, hardware attacks, Spectrum of attacks, Taxonomy of various attacks, IP spoofing, Methods of defense, Security Models, risk management, Cyber Threats-Cyber Warfare, Cyber Crime, Cyber terrorism, Cyber Espionage, etc., Comprehensive Cyber Security Policy

UNIT II

Cyber Offenses: How Criminals Plan Them: Introduction, How Criminals plan the Attacks, Social Engineering, Cyber stalking, Cyber cafe and Cybercrimes, Botnets: The Fuel for Cybercrime, Attack Vector, Cloud Computing.

UNIT III

Cybercrime: Mobile and Wireless Devices: Introduction, Proliferation of Mobile and Wireless Devices, Trends in Mobility, Credit card Frauds in Mobile and Wireless Computing Era, Security Challenges Posed by Mobile Devices, Registry Settings for Mobile Devices, Authentication service Security, Attacks on Mobile/Cell Phones, Mobile Devices: Security Implications for Organizations, Organizational Measures for Handling Mobile, Organizational Security Policies an Measures in Mobile Computing Era, Laptops.

UNIT IV

Types of Attacks and Cybercrime: Introduction, Proxy Servers and Anonymizers, Phishing, Password Cracking, Keyloggers and Spywares, Virus and Worms, Trojan Horse and Backdoors, Steganography, DoS and DDoS attacks, SQL Injection, Buffer Overflow.

UNIT V

Cyber Security Organizational Policies, Risk and Challenges: Organizational Implications. Introduction, Cost of Cybercrimes and IPR issues, Web threats for Organizations, Security and Privacy Implications, Social media marketing: Security Risks and Perils for Organizations, Social Computing and the associated challenges for Organizations.

TEXT BOOKS:

1. **Cyber Security:** *Understanding Cyber Crimes, Computer Forensics and Legal Perspectives*, Nina Godbole and Sunil Belapure, Wiley INDIA.

REFERENCE BOOKS:

1. Cyber Security Essentials, James Graham, Richard Howard and Ryan Otson, CRC Press.
2. Introduction to Cyber Security , Chwan-Hwa(john) Wu,J.David Irwin.CRC Press T&F Group

COURSE OUTCOMES:

Student will be able to

1. Understand basic concepts of Cyber Crimes.
2. Ability to identify the attacks in Cyber Crimes
3. Able to specify the suitable methods used in Cyber Crime
4. Ability to face cyber security challenges
5. Understand Cyber Security

UNIT-I

Introduction to Cyber Security

Cyber Security Introduction - Cyber Security Basics:

Cyber security is the most concerned matter as cyber threats and attacks are overgrowing. Attackers are now using more sophisticated techniques to target the systems. Individuals, small-scale businesses or large organization, are all being impacted. So, all these firms whether IT or non-IT firms have understood the importance of Cyber Security and focusing on adopting all possible measures to deal with cyber threats.

What is cyber security?

"Cyber security is primarily about people, processes, and technologies working together to encompass the full range of threat reduction, vulnerability reduction, deterrence, internationalengagement, incident response, resiliency, and recovery policies and activities, including computer network operations, information assurance, law enforcement, etc."

OR

Cyber security is the body of technologies, processes, and practices designed to protect networks, computers, programs and data from attack, damage or unauthorized access.

- The term cyber security refers to techniques and practices designed to protect digitaldata.
- The data that is stored, transmitted or used on an information system.

OR

Cyber security is the protection of Internet-connected systems, including hardware, software, and data from cyber attacks.

It is made up of two words one is cyber and other is security.

- Cyber is related to the technology which contains systems, network and programs ordata.
- Whereas security related to the protection which includes systems security, networksecurity and application and information security.

Why is cyber security important?

Listed below are the reasons why cyber security is so important in what's become a predominant digital world:

- Cyber attacks can be extremely expensive for businesses to endure.
- In addition to financial damage suffered by the business, a data breach can also inflictuntold reputational damage.
- Cyber-attacks these days are becoming progressively destructive. Cybercriminals areusing more sophisticated ways to initiate cyber attacks.

- Regulations such as GDPR are forcing organizations into taking better care of thepersonal data they hold.

Because of the above reasons, cyber security has become an important part of the business and the focus now is on developing appropriate response plans that minimize the damage in the event of a cyber attack.

But, an organization or an individual can develop a proper response plan only when he has a good grip on cyber security fundamentals.

Cyber security Fundamentals – Confidentiality:

Confidentiality is about preventing the disclosure of data to unauthorized parties.

It also means trying to keep the identity of authorized parties involved in sharing and holding data private and anonymous.

Often confidentiality is compromised by cracking poorly encrypted data, Man-in-the-middle (MITM) attacks, disclosing sensitive data.

Standard measures to establish confidentiality include:

- Data encryption
- Two-factor authentication
- Biometric verification
- Security tokens

Integrity

Integrity refers to protecting information from being modified by unauthorized parties.

Standard measures to guarantee integrity include:

- Cryptographic checksums
- Using file permissions
- Uninterrupted power supplies
- Data backups

Availability

Availability is making sure that authorized parties are able to access the information when needed.

Standard measures to guarantee availability include:

- Backing up data to external drives

- Implementing firewalls
- Having backup power supplies
- Data redundancy

Types of Cyber Attacks

A cyber-attack is an exploitation of computer systems and networks. It uses malicious code to alter computer code, logic or data and lead to cybercrimes, such as information and identity theft.

Cyber-attacks can be classified into the following categories:

1) **Web-based attacks**
2) **System-based attacks**

Web-based attacks

These are the attacks which occur on a website or web applications. Some of the important web-based attacks are as follows-

1. Injection attacks

It is the attack in which some data will be injected into a web application to manipulate the application and fetch the required information.

Example- SQL Injection, code Injection, log Injection, XML Injection etc.

2. DNS Spoofing

DNS Spoofing is a type of computer security hacking. Whereby a data is introduced into a DNS resolver's cache causing the name server to return an incorrect IP address, diverting traffic to the attackers computer or any other computer. The DNS spoofing attacks can go on for a long period of time without being detected and can cause serious security issues.

3. Session Hijacking

It is a security attack on a user session over a protected network. Web applications create cookies to store the state and user sessions. By stealing the cookies, an attacker can have access to all of the user data.

4. Phishing

Phishing is a type of attack which attempts to steal sensitive information like user login credentials and credit card number. It occurs when an attacker is masquerading as a trustworthyentity in electronic communication.

5. Brute force

It is a type of attack which uses a trial and error method. This attack generates a large number of guesses and validates them to obtain actual data like user password and personal identification number. This attack may be used by criminals to crack encrypted data, or by security, analysts to test an organization's network security.

6. Denial of Service

It is an attack which meant to make a server or network resource unavailable to the users. It accomplishes this by flooding the target with traffic or sending it information that triggers a crash. It uses the single system and single internet connection to attack a server. It can be classified into the following-

Volume-based attacks- Its goal is to saturate the bandwidth of the attacked site, and is measured in bit per second.

Protocol attacks- It consumes actual server resources, and is measured in a packet.

Application layer attacks- Its goal is to crash the web server and is measured in request per second.

7. Dictionary attacks

This type of attack stored the list of a commonly used password and validated them to get original password.

8. URL Interpretation

It is a type of attack where we can change the certain parts of a URL, and one can make a web server to deliver web pages for which he is not authorized to browse.

9. File Inclusion attacks

It is a type of attack that allows an attacker to access unauthorized or essential files which is available on the web server or to execute malicious files on the web server by making use of the include functionality.

10. Man in the middle attacks

It is a type of attack that allows an attacker to intercepts the connection between client and server and acts as a bridge between them. Due to this, an attacker will be able to read, insert and modify the data in the intercepted connection.

System-based attacks

These are the attacks which are intended to compromise a computer or a computer network. Some of the important system-based attacks are as follows-

1. Virus

It is a type of malicious software program that spread throughout the computer files without the knowledge of a user. It is a self-replicating malicious computer program that replicates by inserting copies of itself into other computer programs when executed. It can also execute instructions that cause harm to the system.

2. Worm

It is a type of malware whose primary function is to replicate itself to spread to uninfected computers. It works same as the computer virus. Worms often originate from email attachmentsthat appear to be from trusted senders.

3. Trojan horse

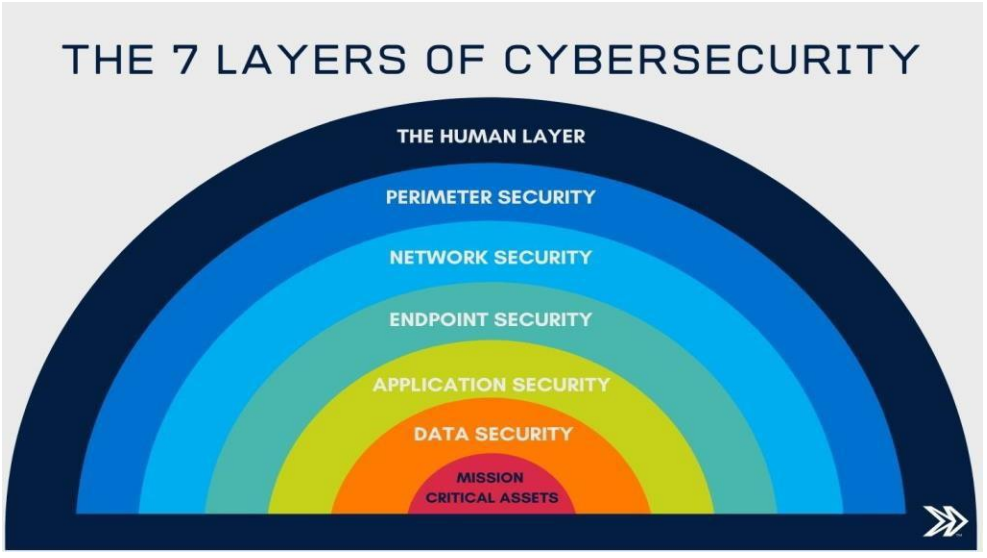
It is a malicious program that occurs unexpected changes to computer setting and unusual activity, even when the computer should be idle. It misleads the user of its true intent. It appears to be a normal application but when opened/executed some malicious code will run in the background.

4. Backdoors

It is a method that bypasses the normal authentication process. A developer may create a backdoor so that an application or operating system can be accessed for troubleshooting or other purposes.

5. Bots

A bot (short for "robot") is an automated process that interacts with other network services. Some bots program run automatically, while others only execute commands when they receivespecific input. Common examples of bots program are the crawler, chatroom bots, and malicious bots.



The 7 layers of cyber security should centre on the mission critical assets you are seeking to protect.

1: Mission Critical Assets – This is the data you need to protect
2: Data Security – Data security controls protect the storage and transfer of data.
3: Application Security – Applications security controls protect access to an application, an application's access to your mission critical assets, and the internal security of the application.
4: Endpoint Security – Endpoint security controls protect the connection between devices and the network.
5: Network Security – Network security controls protect an organization's network and prevent unauthorized access of the network.
6: Perimeter Security – Perimeter security controls include both the physical and digital security methodologies that protect the business overall.
7: The Human Layer – Humans are the weakest link in any cyber security posture. Human security controls include phishing simulations and access management controls that protect mission critical assets from a wide variety of human threats, including cyber criminals, malicious insiders, and negligent users.

Vulnerability, threat, Harmful acts

As the recent epidemic of data breaches illustrates, no system is immune to attacks. Any company that manages, transmits, stores, or otherwise handles data has to institute and enforcemechanisms to monitor their cyber environment, identify vulnerabilities, and close upsecurityholes as quickly as possible.
Before identifying specific dangers to modern data systems, it is crucial to understand the distinction between cyber threats and vulnerabilities.

Cyber threats are security incidents or circumstances with the potential to have a negative outcome for your network or other data management systems.
Examples of common types of security threats include **phishing attacks** that result in the installation of **malware** that infects your data, failure of a staff member to follow data protection protocols that cause a **data breach**, or even a tornado that takes down your company's data headquarters, disrupting access.

Vulnerabilities are the gaps or weaknesses in a system that make threats possible and tempt threat actors to exploit them.

Types of vulnerabilities in network security include but are not limited to SQL injections, server misconfigurations, cross-site scripting, and transmitting sensitive data in a non- encrypted plain text format.
When threat probability is multiplied by the potential loss that may result, cyber security experts, refer to this as a risk.

SECURITY VULNERABILITIES, THREATS AND ATTACKS –

Categories of vulnerabilities

- Corrupted (Loss of integrity)
- Leaky (Loss of confidentiality)
- Unavailable or very slow (Loss of availability)

– Threats represent potential security harm to an asset when vulnerabilities are exploited

- Attacks are threats that have been carried out

- Passive – Make use of information from the system without affecting systemresources
- Active – Alter system resources or affect operation
- Insider – Initiated by an entity inside the organization
- Outsider – Initiated from outside the perimeter

Internet Governance – Challenges and Constraints

- The e-Governance or electronic governance means utilization of ICT (Information and Communications Technology) to carry out the functions and achieve the results of the governance. Governance has become very complex and the increasing expectations from the Government are the reasons for opting for e-governance. Due to changing world and the emergence of digitalization, e-governance has taken the upfront seat. It has become necessary that government initiatives reach the people on time and efficiently through the digitalization of governance.
- People, Process, Technology, and Resources are the four prominent pillars of e-governance. Good governance ensures that all the people can reap the benefits of economic growth. One of the significant steps that the Government took in this regard is to educate the public regarding e-governance initiatives.

Types of Interaction in e-Governance:

There are the following four types of interactions in e-governance.

- **G2G**– (Government to Government) This model aims at sharing the information between Governments like sharing of information between the police departments of various States, Government document exchange, and so on.
- **G2C**– (Government to Citizen) This model aims at sharing the information between the Government and the citizens like online filing of complaints, payment of online bills of electricity, water, and so on.
- **G2B**– (Government to Business) This model aims at sharing information between Government and private sectors like sharing of rules and data, collection of taxes, approval of patents of companies, etc.

- **G2E**– (Government to Employees) This model aims at sharing the information between the Government and employees like employees can fill out all types of forms online.
- Various e-Governance Projects:
- **Smart Gov:** It makes use of e-file instead of paper files. It is implemented in the Andhra Pradesh Secretariat. It is concerned with streamlining operations, knowledge management, and workflow automation.
- **Khajane Project:** It is a project undertaken by the Government of Karnataka. The project resulted in the computerization of the entire treasury data of the Government of the State. Some of the noticeable results are that the number of drawing officers was brought down to around 21,000 from 40000, nearly 2000 staff members were trained to handle the software, about 200 posts in the department of treasury have been abolished, and so on.
- **Digital India Programme:** This programme was started by the Department of Electronics and Information Technology. The program aimed at empowering the country by making it digitally developed. The program was implemented in different phases till 2018. The impact of the agenda is that overall 12,000 rural post offices have been linked electronically.
- **e-Kranti Scheme:** It aimed at the expansion of the internet, mobile phones, and computers to rural areas. The scheme includes the starting up of IT-based jobs in rural areas and also the linking of the internet to the remote villages of the country. There are 44 Mission Mode Projects under the e-Kranti program.
- **e-Governance in municipalities:** It is an initiative done under the umbrella of the overall National e-Governance Plan and the Jawaharlal Nehru National Urban Renewal Mission. The program is aimed at increasing the operational working of the Urban Local Bodies. According to NeGP, Government has decided on four infrastructural pillars for the implementation of e-governance- State Wide Area Network, State Data Centre, Common Service Centre, and Service Delivery Gateway.
- **Public Distribution System:** In PDS, there was the computerization of storage and movement of food grains, fair price shop automation, redressal of grievances, etc.
- **e-Panchayats:** The computerization of panchayat is done on a mission mode basis because the e-governance revolution has not touched the Panchayati Raj Institutions significantly. To improve the quality of governance in Panchayati Raj Institutions including 6094 Block Panchayats and 633 Zilla Panchayats, the Ministry of Panchayati Raj, Government of India has initiated the e-governance scheme known as e-panchayats.
- **Digi-Locker:** It is an initiative introduced by the Government of India under the umbrella of Digital India. Important documents such as Aadhaar cards, mark sheets, and certificates can be digitally stored in Digi-locker. Aadhaar number is essentially required for using Digi-Locker. In 2016, there were 20.13 lakh users of the Digi Locker. The main purpose behind the initiative is to go paperless and the security of documents that can be accessed easily from any place and at any time.

Challenges in e-Governance:

- **Trust:** People should trust the Government and they should be comfortable and confident of the tool and technology that they are using. But due to fraudulent transactions and other factors, the trust of the people is compromised which becomes one of the factors responsible for the limited use of e-governance.
- **Digital divide:** It refers to the division between the people who have access to digital technology and the others who don't have access to it. Economic poverty is one of the main causes of the digital divide. People are unable to afford computers.
- **Lack of Awareness:** Due to the use of digital technology also contributes to the limited use of e-governance techniques. People are not aware of the scope of e-governance and depend on intermediaries for its use.
- **Cost:** In a developing country like India, cost plays a major role in regulating the use of e-governance.
- **Privacy and Security:** People are apprehensive about the security and privacy of their personal data. Government should ensure that no compromise should be done at that end.
- **Accessibility:** Due to inadequate infrastructure facilities in rural areas and language barriers people are unable to access e-governance.
- **Low Computer Literacy:** More than 90% of India's population is digitally illiterate. In addition, the illiterate population comprises 25% to 30% which is one of the biggest challenges.
- **Resistance to Change:** Due to the introduction of Information Technology, a lot of changes have taken place but still, there are various officials, citizens, and politicians who are resistant to change and have different opinions regarding e-Governance.

Some of the Advantages of e-Governance:

- Faster communication through the use of phones and the internet, as it decreases the time taken for communication.
- Paper-based communications require heavy expenditure. It needs a lot of stationary, printers, labour, etc. The cost has been reduced with the use of the internet and phones. Moreover, time and environment are also safe due to their use.
- In earlier times, people faced issues due to physical constraints in reaching out to Government officials. Sometimes because of the ignorance of the officials and at other times due to long queues. But now it has become easy. e-Government is convenient as it provides services according to the schedule and venue of the people.
- e-governance has increased the access of information to the people.
- It also results in improved customer service. GDC (Government Data Centers) are the prominent component of ICT infrastructure for supporting e-governance initiatives.

Computer criminals

Computer criminals have access to enormous amounts of hardware, software, and data; they have the potential to cripple much of effective business and government throughout the world.In a sense, the purpose of computer security is to prevent these criminals from doing damage.

We say **computer crime** is any crime involving a computer or aided by the use of one. Although this definition is admittedly broad, it allows us to consider ways to protect ourselves, our businesses, and our communities against those who use computers maliciously.

One approach to prevention or moderation is to understand who commits these crimes and why. Many studies have attempted to determine the characteristics of computer criminals. Bystudying those who have already used computers to commit crimes, we may be able in the future to spot likely criminals and prevent the crimes from occurring.

CIA Triad

The CIA Triad is actually a security model that has been developed to help people think about various parts of IT security.

CIA triad broken down:

Confidentiality

It's crucial in today's world for people to protect their sensitive, private information from unauthorized access.

Protecting confidentiality is dependent on being able to define and enforce certain access levelsfor information.

In some cases, doing this involves separating information into various collections that are organized by who needs access to the information and how sensitive that information actually is - i.e. the amount of damage suffered if the confidentiality was breached.

Some of the most common means used to manage confidentiality include access control lists, volume and file encryption, and Unix file permissions.

Integrity

Data integrity is what the "I" in CIA Triad stands for.

This is an essential component of the CIA Triad and designed to protect data from deletion or modification from any unauthorized party, and it ensures that when an authorized person makesa change that should not have been made the damage can be reversed.

Availability

This is the final component of the CIA Triad and refers to the actual availability of your data. Authentication mechanisms, access channels and systems all have to work properly for the information they protect and ensure it's available when it is needed.

Understanding the CIA triad

The CIA Triad is all about information. While this is considered the core factor of the majority of IT security, it promotes a limited view of the security that ignores other importantfactors.

For example, even though availability mayserve to make sure you don't lose access to resources needed to provide information when it is needed, thinking about information security in itself doesn't guarantee that someone else hasn't used your hardware resources without authorization.

It's important to understand what the CIA Triad is, how it is used to plan and also to implement a quality security policywhile understanding the various principles behind it. It's also important to understand the limitations it presents. When you are informed, you can utilize the CIA Triad for what it has to offer and avoid the consequences that may come alongby not understanding it.

Assets and Threat

What is an Asset: An asset is any data, device or other component of an organization's systems that is valuable – often because it contains sensitive data or can be used to access such information.

For example: Anemployee's desktop computer, laptop or company phone would be considered an asset, as would applications on those devices. Likewise, critical infrastructure, such as servers and support systems, are assets. An organization's most common assets are informationassets. These are things such as databases and physical files – i.e. the sensitive data that you store

What is a threat: A threat is any incident that could negatively affect an asset – for example, if it's lost, knocked offline or accessed by an unauthorized party.

Threats can be categorized as circumstances that compromise the confidentiality, integrity or availability of an asset, and can either be intentional or accidental.

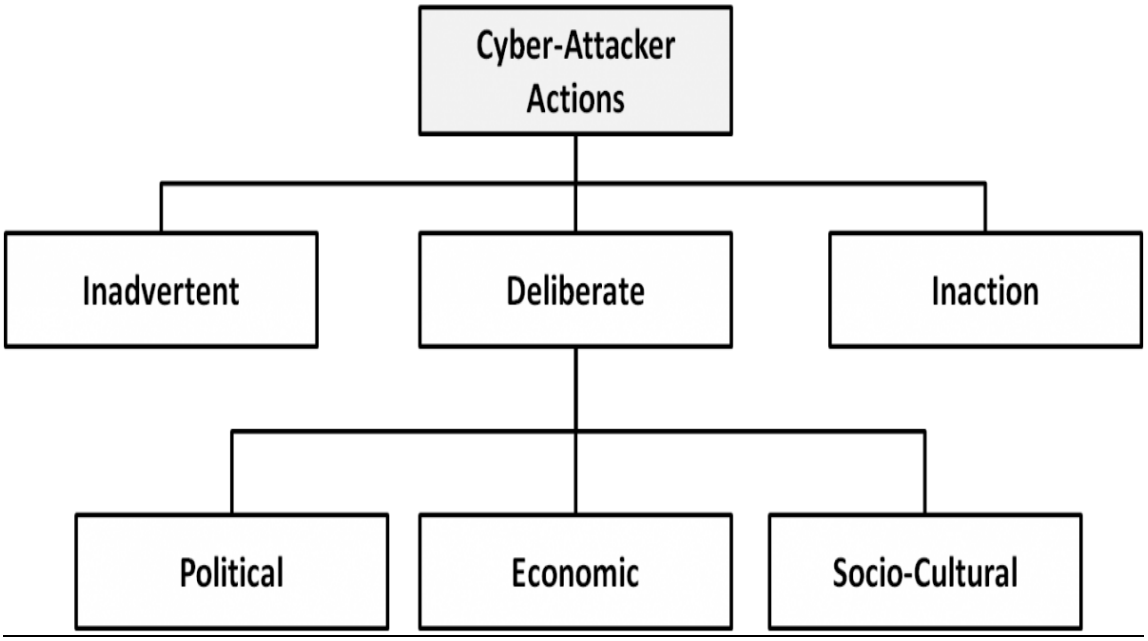
Intentional threats include things such as criminal hacking or a malicious insider stealing information, whereas accidental threats generally involve employee error, a technical malfunction or an event that causes physical damage, such as a fire or natural disaster.

Motive of Attackers

The categories of cyber-attackers enable us to better understand the attackers' motivationsand the actions they take. As shown in Figure, operational cyber security risks arise from three types of actions: i) inadvertent actions (generally by insiders) that are taken without maliciousor harmful intent; ii) deliberate actions (by insiders or outsiders) that are taken intentionally and are meant to do harm; and iii) inaction (generally by insiders), such as a failure to act in agiven situation, either because of a lack of appropriate skills, knowledge, guidance, or availability of the correct person to take action Of primary concern here are

deliberate actions,of which there are three categories of motivation.

1. ***Political motivations****:* examples include destroying, disrupting, or taking control oftargets; espionage; and making political statements, protests, or retaliatory actions.
2. ***Economic motivations****:* examples include theft of intellectual property or other economically valuable assets (e.g., funds, credit card information); fraud; industrialespionage and sabotage; and blackmail.
3. ***Socio-cultural motivations****:* examples include attacks with philosophical, theological, political, and even humanitarian goals. Socio-cultural motivations also include fun, curiosity, and a desire for publicity or ego gratification.



Types of cyber-attacker actions and their motivations when deliberate

Active attacks: An active attack is a network exploit in which a hacker attempts to make changes to data on the target or data en route to the target.

Types of Active attacks:

Masquerade: in this attack, the intruder pretends to be a particular user of a system to gain access or to gain greater privileges than they are authorized for. A masquerade may be attempted through the use of stolen login IDs and passwords, through finding security gaps in programs or through bypassing the authentication mechanism.

Session replay: In this type of attack, a hacker steals an authorized user's log in information by stealing the session ID. The intruder gains access and the ability to do anything the authorized user can do on the website.

Message modification: In this attack, an intruder alters packet header addresses to direct a message to a different destination or modify the data on a target machine.

In a **denial of service (DoS)** attack, users are deprived of access to a network or web resource. This is generally accomplished by overwhelming the target with more traffic than it can handle.

In a **distributed denial-of-service (DDoS)** exploit, large numbers of compromised systems (sometimes called a botnet or zombie army) attack a single target.

Passive Attacks:*Passive attacks* are relatively scarce from a classification perspective, but can be carried out with relative ease, particularly if the traffic is not encrypted.

Types of Passive attacks:

Eavesdropping (tapping): the attacker simply listens to messages exchanged by two entities. For the attack to be useful, the traffic must not be encrypted. Any unencrypted information, such as a password sent in response to an HTTP request, may be retrieved by the attacker.

***Traffic analysis*:** the attacker looks at the metadata transmitted in traffic in order to deduce information relating to the exchange and the participating entities, e.g. the form of the exchanged traffic (rate, duration, etc.). In the cases where encrypted data are used, traffic analysis can also lead to attacks by cryptanalysis, whereby the attacker may obtain information or succeed in unencrypting the traffic.

Software Attacks: Malicious code (sometimes called *malware*) is a type of software designed to take over or damage a computer user's operating system, without the user's knowledge or approval. It can be very difficult to remove and very damaging. Common malware examples are listed in the following table:

Attack	Characteristics
Virus	A *virus* is a program that attempts to damage a computer system and replicate itselfto other computer systems. A virus: • Requires a host to replicate and usually attaches itself to a host file or ahard drive sector. • Replicates each time the host is used. • Often focuses on destruction or corruption of data. • Usually attaches to files with execution capabilities such as .doc, .exe, and .bat extensions. • Often distributes via e-mail. Many viruses can e-mail themselves toeveryone in your address book. • Examples: Stoned, Michelangelo, Melissa, I Love You.

Worm	A *worm* is a self-replicating program that can be designed to do any number of things, such as delete files or send documents via e-mail. A worm can negatively impact network traffic just in the process of replicating itself. A worm: • Can install a backdoor in the infected computer. • Is usually introduced into the system through a vulnerability. • Infects one system and spreads to other systems on the network. • Example: Code Red.
Trojan horse	A *Trojan horse* is a malicious program that is disguised as legitimate software. Discretionary environments are often more vulnerable and susceptible to Trojan horse attacks because security is user focused and user directed. Thus the compromise of a user account could lead to the compromise of the entire environment. A Trojan horse: • Cannot replicate itself. • Often contains spying functions (such as a packet sniffer) or backdoorfunctions that allow a computer to be remotely controlled from the network. • Often is hidden in useful software such as screen savers or games. • Example: Back Orifice, Net Bus, Whack-a-Mole.
Logic Bomb	A *Logic Bomb* is malware that lies dormant until triggered. A logic bomb is aspecific example of an asynchronous attack. • A trigger activity may be a specific date and time, the launching of a specific program, or the processing of a specific type of activity. • Logic bombs do not self-replicate.

Hardware Attacks:

Common hardware attacks include:

- Manufacturing backdoors, for malware or other penetrative purposes; backdoorsaren't limited to software and hardware, but they also affect embedded radio- frequency identification (RFID) chips and memory
- Eavesdropping by gaining access to protected memory without opening otherhardware
- Inducing faults, causing the interruption of normal behaviour
- Hardware modification tampering with invasive operations
- Backdoor creation; the presence of hidden methods for bypassing normal computerauthentication systems
- Counterfeiting product assets that can produce extraordinary operations and thosemade to gain malicious access to systems.

Cyber Threats-Cyber Warfare: Cyber warfare refers to the use of digital attacks -- like computer viruses and hacking -- by one country to disrupt the vital computer systems of another, with the aim of creating damage, death and destruction. Future wars will see hackers using computer code to attack an enemy's infrastructure, fighting alongside troopsusing conventional weapons like guns and missiles.

Cyber warfare involves the actions by a nation-state or international organization to attack and attempt to damage another nation's computers or information networks through, for example, computer viruses or denial-of-service attacks.

Spectrum of Cyber Attacks

Throughout the brief history of cyberwarfare, actors at all levels have performed a wide range of attacks. Despite individual differences, these attacks can be arranged into five categories or levels that build upon one another to form a spectrum: **Network Denial, Enterprise Denial, Enterprise Manipulation, Mission Denial, and Mission Manipulation.**

The "Spectrum of Cyber Attack" incorporates the definition of denial from Joint Publication (JP) 3-12, Cyberspace Operations, "to prevent access to, operation of, or availability of a target function"3 as the foundation for the three levels designated as denial attacks: Network Denial, Enterprise Denial, and Mission Denial. The spectrum builds upon JP 3-12's definition of manipulation, "controls or changes. . . to create physical denial effects, using deception, decoying, conditioning, spoofing, falsification and other similar techniques,"4 for the remaining levels designated as manipulation attacks: Enterprise Manipulation and Mission Manipulation. In this definition, physical simply refers to the fact that manipulation effects have an impact outside of cyberspace. This definition not only refers to the physical systems themselves, but also the cognitive layer, or users, of those systems. This describes manipulating a system to in-turn manipulate or drive an effect in the human element. Manipulation attacks require a more complete understanding of the systems involved along with deeper, more intrusive network access. This knowledge and access are required to successfully manipulate, deceive, or otherwise influence the behavior of users within a target organization.

Level 1: Network Denial Definition. A cyber attack that prevents a network from communicating with external networks Description. The first level of attack is the most simple to conduct, difficult to stop, and thus commonly used. Level 1, Network Denial, targets only the transmission of information, not the actual information itself. These attacks may affect only a part of the network or the network in its entirety. They can be accomplished through several different methods, many of which are exceedingly difficult for the victim to stop. Level 1 attacks primarily differ from other levels in that they affect the target's ability to interact with other organizations while internal processes are largely unaffected.

Examples. A simple example of Network Denial is characterized by an attacker that logs into a router at the border of an organization's network and stops it from transferring data. This example results in the blocking of all traffic on a network and isolates the target organization, temporarily preventing it from transmitting any information in or out using computer networks. This type of network isolation degrades the operations of any organization but only as long as the target is unable to restore proper functionality. More advanced level 1 attacks require national-level resources or access to central backbones of the internet. These include Border Gateway Protocol hijacking, Domain Name Server

hijacking, and large-scale Distributed Denial of Service, all of which have been used by either Russia, Iran, or China.5 These attacks take advantage of the fundamental trust that the internet is built on, giving them the added benefit that there is very little a victim can do to stop them, and they are always at the disposal of a nation.

Tradeoffs. Network Denial attacks are conceptually simple to execute but only provide temporary paralysis of a target's operations. Fewer moving pieces at the technical level results in the highest chance for success compared to all other levels and requires far less knowledge about the target. New targets can be attacked within hours or days and require little preparation. The trade-off, however, is that level 1 attacks draw significant attention and are quick to diagnose. Overall, level 1 attacks require less time, less funding, and thus less commitment, yet they are only expected to disable an organization for hours to days depending on the sophistication of the target's personnel.

Level 2: Enterprise Denial Definition. A cyber attack that denies an organization's users access to their data Description. The next level of cyber attack also disables an organization, but in a manner that inhibits the daily activities of end-users. The term enterprise is used to describe the systems and applications users rely on to perform day-to-day tasks. Examples of daily activities affected by level 2 attacks include the ability to log into computers, send e-mail, and alter documents. Level 2 attacks differ from level 1, Network Denial, in that they specifically disrupt information that an organization's users interact with directly.

Examples. The most common example of a level 2 attack is ransom malware, or "ransomware," currently in vogue with cybercriminals. Ransomware does not need to know anything about an organization before executing its core objective, to deny users access to their data by encrypting it. The files that become encrypted are critical to the system users as the malicious software attacks all files, historical records, activity records, and any others used to carry out daily tasks and company function. This is precisely why it is so devastating for companies hit by such attacks. The most destructive level 2 attack to date has been the "NotPetya" ransomware that caused an estimated $10 billion in damages worldwide in 2017. As an example of the financial impact caused by NotPetya, the international shipping company Maersk alone suffered $300 million in damages and experienced a complete operational shut down for almost a week. This level of disaster is not unique to Maersk,6 or even NotPetya itself. "WannaCry," "SamSam," and "Ryuk" are all well-documented ransomware attacks dating back to 2017 that inflicted millions in financial costs and achieved wide-scale operational impacts across numerous organizations.7

Tradeoffs. Level 2 attacks are likely to cost more financially than any other cyber attack, purely based on the scope and number of systems they affect. Similar to level 1, level 2 attacks require very little target knowledge, and thus, require less time and monetary investment than other levels. However, the likelihood of success of level 2 attacks is also less than that of level 1 attacks due to the deeper network access required. Additionally, the most damaging level 2 attacks to-date only managed to take organizations offline for a few days despite the severe financial costs, and all operations were restored in a manner of weeks.

Level 3: Enterprise Manipulation Definition. A cyber attack that manipulates the decision-making of an organization's users without being detected Description. Enterprise Manipulation is the first level on the spectrum that tailors more toward affecting the behavior of the adversary than removing their ability to operate. These attacks target the same computer systems as level 2, Enterprise Denial, attacks but utilize a deeper understanding of the organization to influence or corrupt, but not deny, common organizational processes. Further, a key objective in executing a level 3 attack is to do so without the user being aware of the attack. This is the key distinction between level 3 and the first two levels. Level 3 attacks must be performed in a manner that is not predictable nor widespread throughout the target organization. Enterprise users have been conditioned over time to be mistrusting of computers and software due to confusing interfaces, technical user manuals, overall complexity, and frequent data loss. By introducing outside gremlins into the systems, end-users can further lose confidence in their ability to effectively perform tasks, thereby leading to loss in productivity and organizational effectiveness.

Examples. Although data manipulation has only started to be openly discussed in the past few years,8 it is easy to envision the potential chaos that can result from such attacks and has captured the imagination of television producers in series such as "Mr. Robot."9 These attacks can be as simple as removing key e-mails, locking particular user accounts, or corrupting vital user files. More robust and potentially far-reaching attacks can be catastrophic, such as manipulating financial or human resource data. According to Forbes, the manipulation of financial data is already extensively practiced by North Korean hackers. North Korea has stolen a staggering $2 billion in 35 compromises across 17 nations.10 For example, North Korea drained $498K from the city of Tallahassee by manipulating payroll data.11 These attacks were designed to obtain funds rather than impose crippling costs on the underlying organizations, yet the devastating impact to the organizations were the same.

Tradeoffs. Enterprise Manipulation attacks strike at the psyche of an organization with the aim of crippling its effectiveness for a prolonged period of time. Levels 1 and 2 cause overt disruptions resulting in temporary outages, but level 3 attacks can hinder an organization for an indefinite period of time. These attacks require a nearly identical preparation time as level 2 but have a much lower chance of success and less quantifiable results. Level 3 attacks also cost more to execute because they must use more sophisticated tools to remain undetected in the target network. Level 3 attacks will not likely impose costs similar to the other levels, but 96 AIR & SPACE POWER JOURNAL → WINTER 2020 Musielewicz they allow attackers to remain within the network undetected while eroding the productivity of an organization. Level 3 attacks also provide the ability to engage a target without the increased risks of retaliation or escalation because of their inherent stealth and plausible deniability. As long as level 3 attacks remain hidden, they allow the perpetrator to develop level 4 and level 5 attacks, all while the target simultaneously suffers negative impacts on efficiency and productivity.

Level 4: Mission Denial Definition. A cyber attack that specifically prevents the operation of processes or systems critical to an organization's mission Description. The final two

levels of the Spectrum of Cyber Attack focus solely on the chain of systems and processes that are essential to an organization carrying out its core mission. This focus may be the destruction of mission-critical data or even—in very specific scenarios—the physical destruction of hardware through industrial control system manipulation. The precision of these attacks is what specifically distinguishes level 4, Mission Denial, from level 2, Enterprise Denial.

Example. The 2015 Russian attack on the Ukraine power grid is a prime example of a level 4 cyber attack. During this attack, Russia gained critical access to three primary Ukrainian power companies undetected. Once inside the networks, the malicious actors immediately targeted the systems used by internal operators to control the generation of power. The actors surveilled the system operators long enough to learn which interfaces were used to control the power generators. Once known, the attackers systematically shut the generators down and disabled remote access to the controlling computers.12 By preventing the power generator operators from remotely bringing the systems back online, technicians were required to physically travel and manually restart each generator, a process that took six hours to complete.13 What makes this example a level 4 attack instead of a level 2 is that the actors were specifically targeting those systems that were essential to the organization executing its core mission—generating power. If these same actions were conducted against systems not vital to this mission, they would be classified as a level 2 attack.

Tradeoffs. From an attacker's perspective, level 4 attacks are much more predictable than level 2 because of their precise nature. These attacks are far more likely to create the specific effect desired. Reducing the scope of an attack and executing with precision allows the attacker to tailor to specific strategic objectives and execute with a higher level of certainty. In contrast, level 2, Enterprise Denial, has the potential to prevent an organization from accomplishing its pri- The Spectrum of Cyber Attack AIR & SPACE POWER JOURNAL → WINTER 2020 97 mary mission, but only as a byproduct of the primary attack. It is easier for a victim to restore mission-critical functions following a level 2 attack because of the universal aspect of level 2 attacks versus the subtlety required for level 4. Level 2 attacks are far more common and less sophisticated, making them more likely to be anticipated and mitigated by network defenders. Level 4 attacks require notably longer time commitments than levels 1, 2, and 3. This is due to the in-depth understanding required to learn the specifics of how an organization conducts its mission and the time required to maneuver to those systems that enable that mission. These longer time commitments naturally cause the overall cost of operations to go up. The longer an actor must remain in a network, the more sophisticated their tools must be to stay undetected. Once a level 4 attack is executed, it will quickly be discovered by network defenders and the remedy will likely be straightforward. The effective downtime of the organization relies heavily on the extent of any physical damage and is further influenced by the scarcity of any specialized hardware required.

Level 5: Mission Manipulation Definition. A cyber attack that specifically manipulates the systems or processes critical to an organization's mission without being detected Description. Mission Manipulation is the most sophisticated and strategically complex cyber attack within the spectrum. Mission Manipulation allows for the repeated, sustained disruption of the fundamental mission of an organization.

Level 5 attacks are identical to level 4 except for the critical fact that they are executed

without being detected. This is a small distinction but is exceptionally difficult to achieve.

Example. The destruction of mission-critical systems and the manipulation required to hide those actions has only been demonstrated by one publicly disclosed cyber attack to date: Stuxnet. Extensively documented, Stuxnet is known for the physical destruction it inflicted on Iranian centrifuges from April 2009– June 2010.14 Yet, the true brilliance of Stuxnet was its skillful deception of the end-users of these systems. Stuxnet systematically destroyed these mission-critical centrifuges while at the same time manipulating the monitoring components to tell the engineers they were functioning properly. Because of the criticality of these centrifuges, the paired destruction and deception of Stuxnet disrupted the organization's ability to perform its primary mission and set back Iran's nuclear program a minimum of two years.15 The attack exacerbated financial burdens and according to a report by the Center for Security Studies, "likely culminated in an overall feeling of insecurity throughout Iranian society."16 Even after the discovery of Stuxnet, Iran was not able to fully trust their 98 AIR & SPACE POWER JOURNAL → WINTER 2020 Musielewicz systems—not knowing whether a failure was generated by human error or the actions of malicious code lurking in their systems.

Tradeoffs. Level 5 attacks require substantially more resources than any other level, both in time and human capital. Mission Manipulation is expected to require a combination of customized tools, in-depth knowledge, sophisticated cyber expertise, specialized engineering knowledge, and significant amounts of time. It requires time to gain network access, time to harvest information, time to develop tools, time to maneuver within the network, and time to execute. It was speculated that Stuxnet required the combined efforts of Israel and the United States17—two of the most technologically sophisticated nations in the world—a minimum of three years of preparation, a year of continuous execution, and an estimated $100 million dollars.18 The target knowledge, commitment, and technical expertise required to execute attacks at level 5 demands real-time development as the exact configurations and nuances of mission systems are almost impossible to know before accessing them. The skills and tools for such specialized or indigenous mission systems may be extremely hard to find, or may not exist, requiring them to be built from the ground up. In spite of these heavy constraints, a level 5 attack has the ability to cause massive high-level impacts that rival the sophistication of any operation in the other warfare domains. It can single-handedly achieve strategic objectives through nonkinetic means, and importantly, allow for plausible deniability that reduces the risk of retaliation and conflict escalation. As seen in the Stuxnet example, the culmination of such high levels of investment can produce powerful effects that last for years.

Cyber Crime:

Cybercrime is criminal activity that either targets or uses a computer, a computer network or a networked device.Cybercrime is committed by cybercriminals or hackers who wantto make money. Cybercrime is carried out by individuals or organizations.

Some cybercriminals are organized, use advanced techniques and are highly technically skilled. Others are novice hackers.

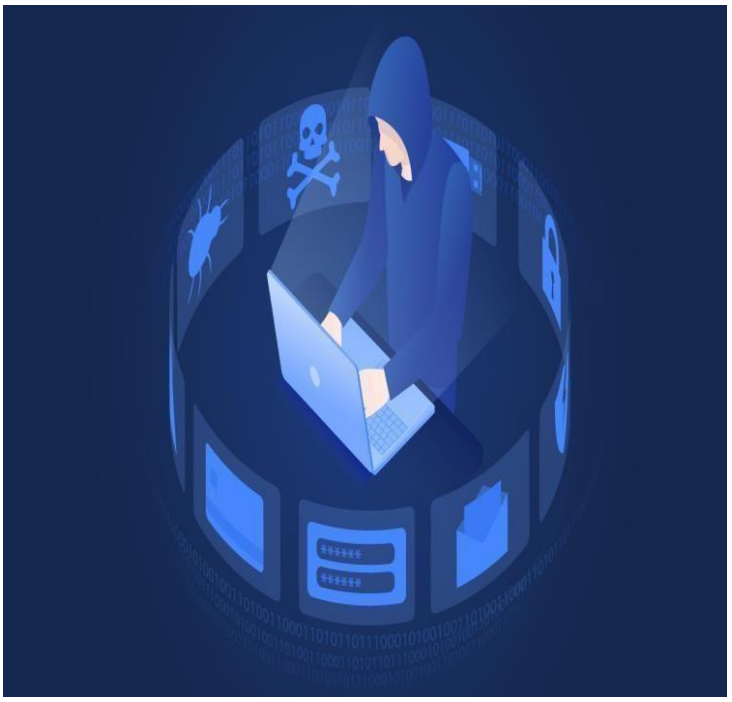
Cyber Terrorism:

Cyber terrorism is the convergence of cyberspace and terrorism. It refers to unlawful attacks and threats of attacks against computers, networks and the information stored therein when done to intimidate or coerce a government or its people in furtherance of political or social objectives.

Examples are hacking into computer systems, introducing viruses to vulnerablenetworks, web site defacing, Denial-of-service attacks, or terroristic threats made via electronic communication.

Cyber Espionage:

Cyber spying, or cyber espionage, is the act or practice of obtaining secrets and information without the permission and knowledge of the holder of the information from individuals, competitors, rivals, groups, governments and enemies for personal, economic, political or military advantage using methods on the Internet.



Security Policies:

Security policies are a formal set of rules which is issued by an organization to ensure that the user who are authorized to access company technology and information assets comply with rules and guidelines related to the security of information.

A security policy also considered to be a "living document" which means that the document is never finished, but it is continuously updated as requirements of the technology and employee changes.

We use security policies to manage our network security. Most types of security policies are automatically created during the installation. We can also customize policies to suit our specific environment.

Need of Security policies-

1) It increases efficiency.

2) It upholds discipline and accountability

3) It can make or break a business deal

4) It helps to educate employees on security literacy

There are some important cyber security policies recommendations describe below-

Virus and Spyware Protection policy:

- It helps to detect threads in files, to detect applications that exhibits suspiciousbehavior.
- Removes, and repairs the side effects of viruses and security risks by using signatures.

Firewall Policy:

- It blocks the unauthorized users from accessing the systems and networks that connectto the Internet.
- It detects the attacks by cybercriminals and removes the unwanted sources of networktraffic.

Intrusion Prevention policy:

- This policy automatically detects and blocks the network attacks and browser attacks.
- It also protects applications from vulnerabilities and checks the contents of one or more data packages and detects malware which is coming through legal ways.

Application and Device Control:

- This policy protects a system's resources from applications and manages theperipheral devices that can attach to a system.
- The device control policy applies to both Windows and Mac computers whereas application control policy can be applied only to Windows clients.

CYBERSPACE

Cyberspace can be defined as an intricate environment that involves interactions between people, software, and services. It is maintained by the worldwide distribution of information and communication technology devices and networks.

With the benefits carried by the technological advancements, the cyberspace today has becomea common pool used by citizens, businesses, critical information infrastructure, military and governments in a fashion that makes it hard to induce clear boundaries among these different groups. The cyberspace is anticipated to become even more complex in the upcoming years, with the increase in networks and devices connected to it.

REGULATIONS

There are five predominant laws to cover when it comes to cybersecurity:

Information Technology Act, 2000 The Indian cyber laws are governed by the Information Technology Act, penned down back in 2000. The principal impetus of this Act is to offer reliable legal inclusiveness to eCommerce, facilitating registration of real-time records with the Government.

But with the cyber attackers getting sneakier, topped by the human tendency to misuse technology, a series of amendments followed.

The ITA, enacted by the Parliament of India, highlights the grievous punishments and penalties safeguarding the e-governance, e-banking, and e-commerce sectors. Now, the scopeof ITA has been enhanced to encompass all the latest communication devices.

The IT Act is the salient one, guiding the entire Indian legislation to govern cybercrimes rigorously:

Section 43 - Applicable to people who damage the computer systems without permission from the owner. The owner can fully claim compensation for the entire damage in such cases.

Section 66 - Applicable in case a person is found to dishonestly or fraudulently committing any act referred to in section 43. The imprisonment term in such instances can mount up to three years or a fine of up to Rs. 5 lakh.

Section 66B - Incorporates the punishments for fraudulently receiving stolen communication devices or computers, which confirms a probable three years imprisonment. This term can also be topped by Rs. 1 lakh fine, depending upon the severity.

Section 66C - This section scrutinizes the identity thefts related to imposter digital signatures, hacking passwords, or other distinctive identification features. If proven guilty, imprisonment of three years might also be backed by Rs.1 lakh fine.

Section 66 D - This section was inserted on-demand, focusing on punishing cheaters doing impersonation using computer resources.

Indian Penal Code (IPC) 1980

Identity thefts and associated cyber frauds are embodied in the Indian Penal Code (IPC), 1860
- invoked along with the Information Technology

Act of 2000.The primary relevant section of the IPC

covers cyber frauds:

Forgery (Section 464)

Forgery pre-planned for cheating

(Section 468)False

documentation (Section 465)

Presenting a forged document as

genuine (Section 471)Reputation

damage (Section 469)

Companies Act of 2013

The corporate stakeholders refer to the Companies Act of 2013 as the legal obligation necessaryfor the refinement of daily operations. The directives of this Act cements all the required techno-legal compliances, putting the less compliant companies in a legal fix.

The Companies Act 2013 vested powers in the hands of the SFIO (Serious Frauds InvestigationOffice) to prosecute Indian companies and their directors. Also, post the notification of the Companies Inspection, Investment, and Inquiry Rules, 2014, SFIOs has become even more proactive and stern in this regard.

The legislature ensured that all the regulatory compliances are well-covered, including cyber forensics, e-discovery, and cybersecurity diligence. The Companies (Management and Administration) Rules, 2014 prescribes strict guidelines confirming the cybersecurity obligations and responsibilities upon the company directors and leaders.

NIST Compliance

The Cybersecurity Framework (NCFS), authorized by the National Institute of Standards and Technology (NIST), offers a harmonized approach to cybersecurity as the most reliable globalcertifying body.

NIST Cybersecurity Framework encompasses all required guidelines, standards,

and best practices to manage the cyber-related risks responsibly. This framework is prioritized on flexibility and cost-effectiveness.

It promotes the resilience and protection of critical infrastructure by: Allowing better interpretation, management, and reduction of cybersecurity risks – to mitigate data loss, data misuse, and the subsequent restoration costs Determining the most important activities and critical operations - to focus on securing them Demonstrates the trust-worthiness of organizations who secure critical assets Helps to prioritize investments to maximize the cybersecurity ROI Addresses regulatory and contractual obligations Supports the wider information security program By combining the NIST CSF framework with ISO/IEC 27001 - cybersecurity risk management becomes simplified. It also makes communication easier throughout the organization and across the supply chains via a common cybersecurity directivelaid by NIST.

Final Thoughts As human dependence on technology intensifies, cyber laws in India and acrossthe globe need constant up-gradation and refinements. The pandemic has also pushed much ofthe workforce into a remote working module increasing the need for app security. Lawmakershave to go the extra mile to stay ahead of the impostors, in order to block them attheir advent.

Cybercrimes can be controlled but it needs collaborative efforts of the lawmakers, the Internetor Network providers, the intercessors like banks and shopping sites, and, most importantly, the users. Only the prudent efforts of these stakeholders, ensuring their confinement to the lawof the cyberland - can bring about online safety and resilience.

ROLE OF INTERNATIONAL LAWS

In various countries, areas of the computing and communication industries are regulated by governmental bodies There are specific rules on the uses to which computers and computer networks may be put, in particular there are rules on unauthorized access, data privacy and spamming There are also limits on the use of encryption and of equipment which may be used to defeat copy protection schemes There are laws governing trade on the Internet, taxation, consumer protection, and advertising There are laws on censorship versus freedomof expression, rules on public access to government information, and individual access to information held on them by private bodies Some states limit access to the Internet, by law as well as by technical means.

INTERNATIONAL LAW FOR CYBER CRIME

Cybercrime is "international" that there are ‘no cyber-borders between countries’ The complexity in types and forms of cybercrime increases the difficulty to fight back fighting cybercrime calls for international cooperation Various organizations and governments have already made joint efforts in establishing global standards of legislation and law enforcement both on a

regional and on an international scale

THE INDIAN CYBERSPACE

Indian cyberspace was born in 1975 with the establishment of National Informatics Centre (NIC) with an aim to provide govt with IT solutions. Three networks (NWs) were set up between 1986 and 1988 to connect various agencies of govt. These NWs were, INDONET which connected the IBM mainframe installations that made up India's computerinfrastructure, NICNET (the NIC NW) a nationwide very small aperture terminal (VSAT) NW for public sector organisations as well as to connect the central govt with the state govts and district administrations, the third NW setup was ERNET (the Education and Research Network), to serve the academic and research communities.

New Internet Policy of 1998 paved the way for services from multiple Internet service providers (ISPs) and gave boost to the Internet user base grow from 1.4 million in 1999 to over150 million by Dec 2012. Exponential growth rate is attributed to increasing Internet access through mobile phones and tablets. Govt is making a determined push to increase broadband penetration from its present level of about 6%1. The target for broadband is 160 million households by 2016 under the National Broadband Plan.

NATIONAL CYBER SECURITY POLICY

National Cyber Security Policy is a policy framework by Department of Electronics and Information Technology. It aims at protecting the public and private infrastructure from cyberattacks. The policy also intends to safeguard "information, such as personal information (of web users), financial and banking information and sovereign data". This was particularly relevant in the wake of US National Security Agency (NSA) leaks that suggested the US government agencies are spying on Indian users, who have no legal or technical safeguards against it. Ministry of Communications and Information Technology (India) defines Cyberspace as a complex environment consisting of interactions between people, software services supported by worldwide distribution of information and communication technology.

VISION

To build a secure and resilient cyberspace for citizens, business, and government and also to protect anyone from intervening in user's privacy.

MISSION

To protect information and information infrastructure in cyberspace, build capabilities to prevent and respond to cyber threat, reduce vulnerabilities and

minimize damage from cyber incidents through a combination of institutional structures, people, processes, technology, andcooperation.

OBJECTIVE

Ministry of Communications and Information Technology (India) define objectives as follows

- To create a secure cyber ecosystem in the country, generate adequate trust and confidence in IT system and transactions in cyberspace and thereby enhance adoption of IT in all sectors of the economy.
- To create an assurance framework for the design of security policies and promotion and enabling actions for compliance to global security standards and best practices by way of conformity assessment (Product, process, technology & people).
- To strengthen the Regulatory Framework for ensuring a SECURE CYBERSPACE ECOSYSTEM.
- To enhance and create National and Sectoral level 24X7 mechanism for obtaining strategic information regarding threats to ICT infrastructure, creating scenarios for response, resolution and crisis management through effective predictive, preventive, protective response and recovery actions.

2 Cyberoffenses: How Criminals Plan Them

Learning Objectives

After reading chis chapter, you *will* be able co:

- Understand different cypes of cyberaccacks.
- Get an overview of che steps involved in planning cybercrime.
- Understand tools used for gathering information about the cacgec.
- Get ari overview on social engineering - what and how.
- Leacn about the role of cybercafes in cybercrime.
- Understand what cyberscalking is.
- Learn about Bomecs and attack vector.
- Gee an overview on cloud computing - what and how.

2.1 Introduction

Technology is a "double-edged sword" as it can be used for both good and bad purposes. People with the tendency to cause damages or carrying out illegal activities will use it for bad purpose. Computers and cools available in IT are also no exceptions; like ocher cool, they are used as either target of offense or means for commiHing an offense. In coday's world of Internet and computer networks, a criminal activiry can be carried out across national borders with "false sense of anonymity"; without realizing, we seem co pass on tremendous amoum of information about ourselves. Are we sure chis will never be misused? Figure 2. l gives us an idea about all chose agencies char collect information about the individuals (i.e., Personally ldentifiab'le Information such as dace of birth, personal E-Mail address, bank account details and/or credit card details, etc. explained in Section 5.3.l, Chapter 5).

Chapter I provided an overview of *hacking, industrial espionage, network intrusions, password miff ing, computer viruses,* etc. They are the most commonly occurring crimes that target the computer. Cybercriminal use rhe World Wide Web and lncernet to an optimum level for all illegal activities to score daca, contacts, account information, etc. 11,e criminals rake advantage of the widespread lack of awareness about cybercrimes and cyberlaws among the people who are constantly using che IT infrastructure for official and personal purposes. People who commit cybercrimes are known as "Crackers" (Box 2.1).

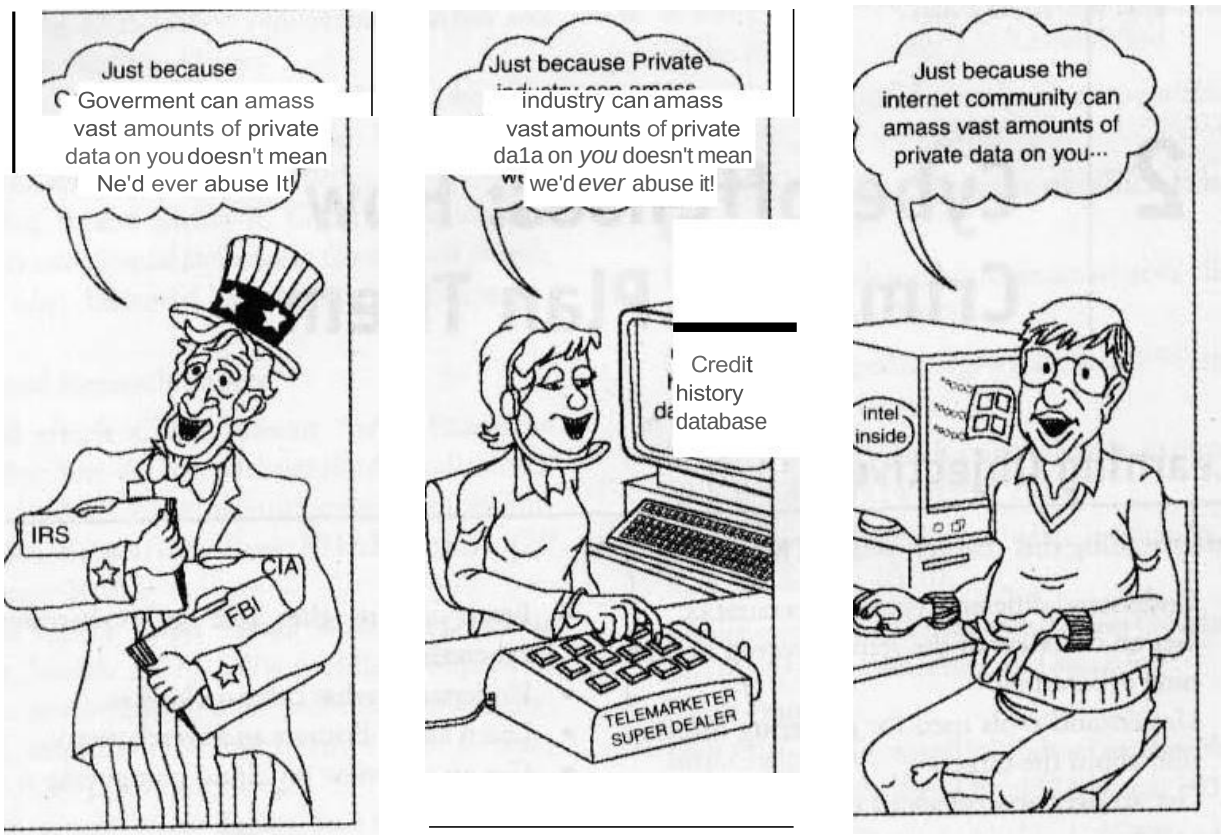


Figure 2.1 We all vouche for keeping your personal information secret!
Source: Nina Godbole (2009), *Information Systems Security: Security Management, Metrics, Frameworks and Best Practices* (Fig. 29.14), Wliey India.

Box 2.1 Hackers, Crackers and Phreakers

Hacker: A hockerisa personwith a stronginterest in computers who enjoys learning and experimenting with them. Hackers ore usually very talented, smart people who understand computers better than others. The term is often confused with crocker that defines someone who breaks into computers (refer to Box 2.2).

Brute force hacking: It is a technique used to find passwords or encryption keys. Brute force hocking involves trying every possible combination of letters. numbers. etc .. until the code is broken.

Cracker: A cracker is a person who breaks into computers. Crackers should not be confused with hackers. The term "crocker" is usually connected to computer criminals.Some of their crimesinclude vandalism. theft and snooping in unauthorized areas.

Cracking: It is the act of breaking into computers. Cracking is a popular. growing subject on the Internet. Many sites ore devoted to supplying crackers with programs that allow them to crack computers. Some of these programs contain dictionaries for guessing passwords. Others ore used to break into phone lines (called "phreoking"). These sites usually display warnings such as "These files ore illegal; we ore not responsible for what you do with them."

Cracker tools: These are programs used to break into computers. Cracker tools ore widely distributed on the Internet. They include password crackers. Trojans. viruses. war dialers and worms.

Phreaklng: Thisis the notorious art of breaking Into phone or other communication systems. Phreoking sites on the Internet are popular among crackers and other criminals.

War dialer: It is program that automatically dials phone numbers looking for computers on the other end. It catalogsnumbers so that the hackers con coll bock and try to break in.

Source: Nino Godbole 12009). *Information Systems Security: Security Management. Metrics. Frameworlcs and Best Practices* (Box 11.2). Wiley India.

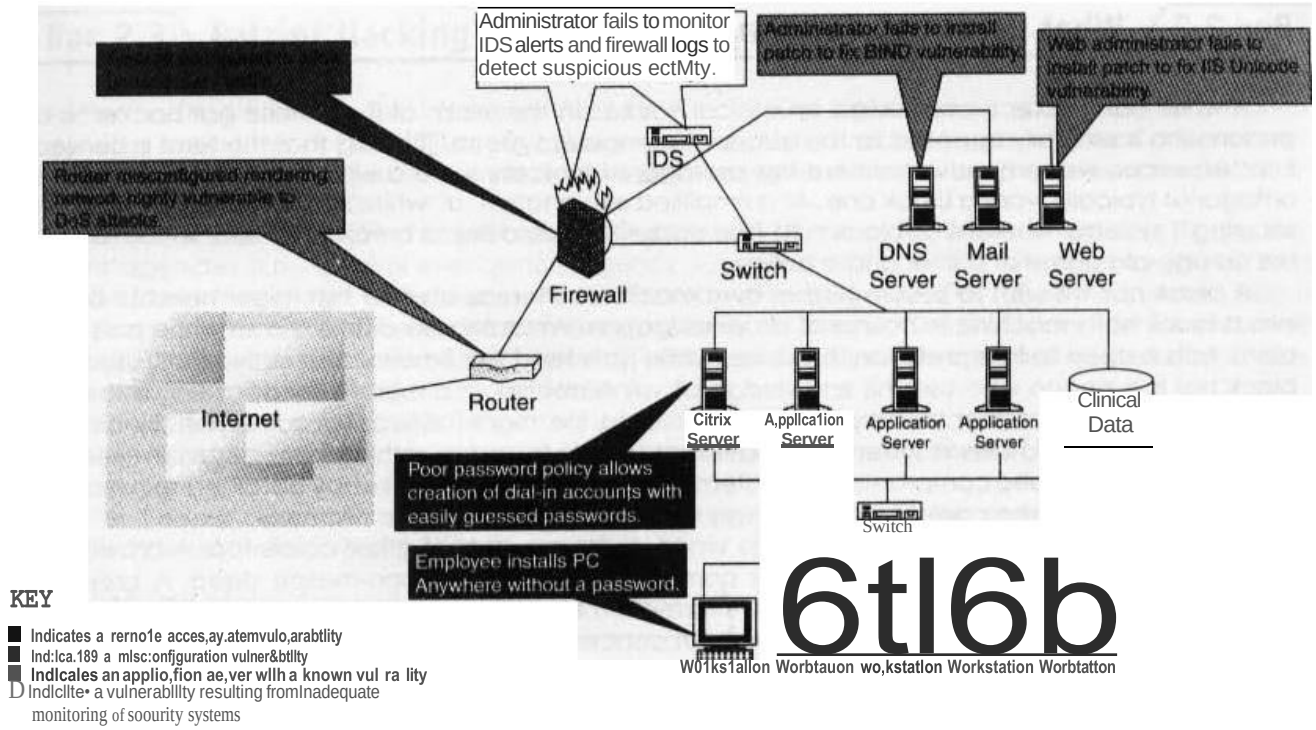


Figure 2.2 Network vulnerabilities - sample network.
Source: Nina Godbole (2009), *Information Systems Security: Security Management, Metrics, Frameworks and Best Practices* (Fig. 11.6), Wiley India.

An attacker would look co exploit the vulnerabilities in the networks, most often *so* because the networks are not adequately protected. The categories of vulnerabilities that hackers typically search for are the following:

1. Inadequate border protection (border as in the sense of necwork periphery);
2. remote access servers (RASs) with weak access controls;
3. application servers with well-known exploirs;
4. misconfigured systems and systems with default configurations.

To help the reader understand che necwork attack scenario, Fig. 2.2 iUustraces a small network highlighting specific occurrences of several vulnerabilities described above.

Box 2.2 What Color is Your Hat in the Security World?

When Edward De Bono wrote his epoch making the book *The Six Thinking Hots* most successful concept that helps people to be more productive, focused, and mindfully involved, little did he know that the hats would follow suit in other domains tool! Just read on to discover about the "hats" in security world. And not only that, but also be conscious to know if any of these hots are around you to jeopardize the security of your information assets on the network.

A *black hat* is olso called a "crocker" or "dark side hacker." Such a person is a malicious or criminal hocker. Typically, the term "cracker" is used within the security industry. However. the general public uses the term hacker to refer to the same thing. In computer jargon, the meaning of "hacker" con be much broader. The name comes from the opposite of "white hat hackers."

Box 2.2 **What Color … *(Continued)***

A *while hat hacker* is considered on *ethical hocker.* In the realm of IT. a "white hot hacker" is a person who is ethically opposed lo the abuse of computer systems. It is said that the term is derived from American western movies, where the protagonist typically wore o white cowboy hot and the ontogonisl typically wore a block one. Asa simplified explanation. a "white hot" generally focuseson securing ITsystems. whereas a "block hot" (the opposite) would like lo break into them. so thissounds like on age-old game of a thief and a police.

A *block hat* will wish to secure his/her own machine whereas a while hat might need to break into a block hat's machine in course of on Investigation. What exactly differentiates white hols and black hots is open lo interpretation; however, while hots tend to cite altruistic mollvotions. Usually a black hat is a person who uses his knowledge of vulnerabilities and exploits for private goin. rather than revealing them either to the general public or to the manufacturer for correction. Block hats may seek to expand holes in systems; any attempts mode lo patch software are generally done to prevent others from also compromising a system over which they have already obtained secure control. In the most extreme cases. black hats may work lo cause damage maliciously.

Interestingly. this is not all; in the security world. there ore hots of other colors too. A *brown hot* hocker is one who thinks before acting or commiltlng a malice or non-malice deed. A *grey haf* commonly refers to o hacker who releases Information aboul any exploits or security holes he/she finds openly to the public. He/she does so without concern for how the information is used in the end (whether tor patching or exploiting).

Source: Nino Godbole [2009). *Information Systems Security: Security* Monogement. *Metrics. Frameworks* ond *Bes/ Practices* [Box 17.3). Wliey India.

2.1.1 Categories of Cybercrime

Cybercrime c:in be caregorized based on the following:

1. The target of the crime and
2. whether the crime occurs as a single evenc or as a series of evencs.

As explained in Secrion 1.5, Chapter 1, cybercrime can be targeted against individu:ils (persons), assets (property) and/or organi7..ations (governmenc, business and social).

1. Crimes t.argeted at individuals: The goal is ro exploit human weakness such as greed and naivecy. These crimes include hnancial frauds, sale of non-existcm or s10lcn i[ems, child pornography (explained in SecLion 1.5.13, Chapter l), copyright violaLion, harassmenr, ere. wich che development in the IT and the lncernet; rhus, criminals have a new tool rhat allows chem 10 expand Lhe pool of potential victims. However, chis also makes difficult co Lrace and apprehend the crimin:11s.
2. Crimes targeted at property: This includes stealing mobile devices such as cell phone, laptops, personal digital assisranc (PDAs), and removable medias (CDs and pen drives); rransmhcing harmful programs rhat can disrupt Functions of che syscems and/or can wipe ouc data from hard disk, and can create the malfunctioning of che attached devices in the system such as modem, CD drive, etc.
3. Crimes targeted at organizations: Cyberterrorism is one of the di tinct crimes against organi,.ations/govemmenrs. Attackers (individuals or groups of individuals) use computer cools and che lncernet co u. ually terrorize the citiiens of a particular country by srcaling the private information, and also to damage the programs and files or plane programs to ger control of the network and/or system (see Box 2.3).

Box 2.3 Patriot Hack:ng

Patriot hacking[111] also known as *Digital Warfare.* is a form of vigilante computer systems' crocking done by individuals *or* groups (usually citizens or supports of a country) against a real or perceived threat. Traditionally. Western countries, that is, developing countries. attempts to launch attacks on their perceived enemies.

Although patriot hocking is declared as Illegal in the US. however, it is reserved only ror government agencies [i.e.. Central Intelligence Agency (CIA) and Notional Security Agency (NSA)] as a legitimate form of attack and defense. Federal Bureau of Investigation (FBI) raised the concern about rise in cyberottocks like website defacements (explained in Box 1.4. Chapter I) anddenial-of-service attacks (DoS - refer to Section 4.9, Chapter 4), which adds as fuel into increase in international tension and gets mirrored it into the online world.

After the war in Iraq in 2003. it is getting popular in the North America, Western Europe and Israel. These ore countries that have the greatest threat to Islamic terrorism and its aforementioned digital version.

The People's Republic of China is allegedly making attacks upon the computer networks of the US and the UK. Refer to Box 5.15 in Chapter 5.

For detailed information visit www.potriothacking.com

4. **Single event of cybercrime:** It is the.single event from the perspective of the victim. For example, unknowingly open an attachment that may contain virus that wiU infect the system (PC/laptop). This is known as hacking or fraud.
5, Series of events: This involves attacker interacting with the victims repetitively. For example, att cker interacts with the victim on the phone and/or via chat rooms co establish relationship first and then they exploit chat relationship to commit the exual assault (refer co Section 2.4 on "Cyberstalking").

2.2 How Criminals Plan the Attacks

Criminals use many methods and cools to locate the vulnerabilities of their target. The target can be an individual and/or an organization. (The custodian of a property can be an individual or an organization; for discussion purpose not mentioned here.) Criminals plan passive and active attacks (see Sections 2.2.2 and 2.2.3 for more details on these topics). Active attacks are usually used co airer the system (i.e., computer network) whereas passive attacks attempt to gain information about the target. Active-attacks may affect the availability, integrity and authenticity of data whereas passive attacks lead to breaches of confidentiality.

ln addjtion to the active and passive categories, attacks can be categorized as either inside or outside. An attack originating and/or attempted within the security perimeter of an organization is an inside arrack; it is usually attempted by an "insider" who gains access to more resources than expected. An outside attack is attempted *by* a source outside the security perimeter, maybe attempted by an insider and/or an outsider, who is indireccly associated with the organization, it is attempted through the lnternet or a remote access connection.

The following phases are involved in planning cybercrime:

1. Reconnaissance (information gathering) is the first phase and is treated as passive attacks.
2. Scanning and scrutinizing the gathered information for the validity of the information as well as to identify the existing vulnerabilities.
3. Law1ching an attack (gaining and maintaining the system access).

2.2.1 Reconnaissance

rhe lireral meaning of "Reconnaissance" is *an acr of reconnoitering - explore, often with the goal of finding something or somebody (especially to gain information about an enemy or potential enemy).*

In che world of "hacking," reconnaissance phase begins with *"Footprinting'* - chis is che preparation coward preatcack phase, and involves accumularing data about the target's environment and computer architecture to find ways to intrude into that environ enr. Footprinring gives an overview abouc system vulnerabilities and provides a judgment about possible exploirarion of those vulnerabilities. The objective of this preparacory phase is co understand the system, its networking ports and services, and any ocher aspects of its security char are needful for launching d1e arrack.

Thus, an attacker attempts co gather information in two phases: passive and active attacks. Lee us underscand these two phases.

2.2.2 Passive Attacks

A passive attack Lnvolves gathering information about a target withouc his/her (individual's or company's) knowledge. Ir can be as simple as watching a building to identify what time employees enrer the buildLng premises. However, it is usually done using Internee searches or by Googling (i.e., searching the required information with the help of search engine Google) an individual or company co gain information.

1. Google or Yahoo search: People search co locate information about employees (see Table 2.1).
2. Surfing online community groups like Orkut/Facebook will prove useful co gain the information about an individual.
3. Organization's website may provide a personnel directory or information about key employees, for example, contact details, E-Mail address, etc. 1l1ese can be used in a social engineering arrack co reach the carger (see Section 2.3).
4. Biogs, newsgroups, press releases, ere. are generally used as che mediums co gain information abour the company or employees.
5. Going chrough the job postings in particular job profiles for technical persons can provide information about rype of technology, mar is, servers or infrastructure devices a company maybe using on its network.

Box 2.4 Tips for Effective Search with "Google" Search Engine

The Google search engine can be used indigenously lo perform "Reconnaissance" phase of an attack. The following commands can be used effectively in the Google search engine.

http://groups.google.com: This site con be used to search the Google newsgroups.

Stte: If you include (site:) in your query. Google willrestrict the results to those websites in the given domain. For instance, [help site:www.google.com] will find pages about help within www.google.com. (help site:com) will find pages about help within .com URLs (uniform resource locator). Note that, there should be no space between the "site:" and the domain. This feature is also available through advanced search page. under Advanced Web Search> Domains.

Flletype: This will search within the text of a particular type of file. The file type to search must be typed otter the colon.

link: The query [link:] will list the webpoges that have links to the specified webpoge. Forinstance, [link: www.google.com) will list webpoges that hove links pointing to the Google homepage. Note that there con be no space between the "link:" and the webpoge URL. This tunclionolily is also accessible from the advanced search page, under Page Specific Search> links.

4010 5214

Box 2.4 r;ps for ... *(Continued)*

Inurl: If you include [inurl:J in your query, Google will restrict the results t d'o'tunfents containing that word in the URL. For instance, finurl:google search] will return documents that mention the word "google" in their URL. and mention the word "search" anywhere in the document (URL or no). Note that there should be no space between the "inurl:" and the following word. Putting "inurl:" in front of every word in your query is equivalent to putting "ollinurl:" in front of your query; this implies pnurl:google inurl:seorch] is the some os [ollinurl: google search}.

Cache: If you include other words in the query, Google will highlight those words within the cached document. For instance, [cache: www.google.com web] will show lhe cached content with the word "web" highlighted. This feature is also accessible by clicking on the "Cached" link on Google's main results page. The query [cache:] will show the version of the webpage that Google hos in its cache. For inslonce, [cache: www.google.com] will show Google's cache of the Google homepage. Note that there should be no space between the "cache:" and the webpage URL

Related: The query [related:] will list webpages that ore "similar" to o specified webpage. For instance, [related: www.google.com] will list webpages that ore similar to the Google homepage. Note that there should be no space between the "related:" and the webpage URL .rhis feature Is also accessible by clicking on the "Similar Pages" link on Google's main results page, and from the advanced search page. under Page Specific Search > Similar.

Info: The query (info:] will present some information that Google has about that webpoge. For instance, (info: www.google.com] will show information about the Google homepage. Note that there should be no space between the "info:" and the webpoge URL. This feature is also accessible by typing the webpage URL directly into a Google search box.

Define: The query (define:f will provide o definition of the word/phrase you enter ofter ii. gathered from various online sources. The definition will be for the entire phrase entered (i.e., it will include all the words in the exact order you typed them).

Stocks: If you begin a query with the [stocks:] operator, Google will treat the rest of the query terms as stock ticker symbols and will link to a page showing stock information for those symbols. For instance, (stocks: intc yhoo] will show information about Intel and Yahoo. (Note that you must type the ticker symbols, not the company name.] This feature is also available if you search just on the stock symbols (e.g., (intc yhoo]) and then click on the "Show sfock quotes" link on the results page.

Alllntltle: If you start a query with [allintitle:]. Google will restrict the results to those with all of the query words in the title. For instance, [ollintitle: google search] will return only documents that hove both "google" and "search" in the title. This feature is also available through advanced Search page. under Advanced Web Search > Occurrences.

tntltle: If you include [intitle:] in your query. Google will restrict the results to documents containing that word in the title. For instance, [intitle:google search] will return documents lhot mention the word "google" in their title and the word "search" anywhere in the document (title or no). Note that there should be no space between the "intitle:" and the following word. Putting [inlille:] in front of every word in your query isequivalent to putting [alliritille:] at the front of your query; this implies that fintille:google intitle:seorch] is the same as [allintitle: google search].

Alllnurl: If you start a query with [ollinurl:], Google will restrict the results to those with oil of the query words in the URL. For Instance, [allinurl: google search} will return only documents that have both "google" and "search" in the URL.

Note that [allinurl:] works on words, not on URL components. In particular, it ignores punctuation. Thus, [allinurl: foo/bor) will restrict the results to page with the words "too" and "bar" in the URL, but won't require that they be separated b¥ a slosh within that URL. that they be adjacent. or that they be in that particular word order. There is currently no way to enforce these constraints.

Source: http://www.google.com.tw/help/operators.html

Network sniffing is another means of passive attack to yield useful information such as Incerner Protocol (JP) address ranges, hidden servers or networks, and other available services on the system or network. The network traffic is sniffed for monitoring the traffic on the network - attacker watches the flow of data to see what time certain transactions cake place and where the traffic is going.

Along wich Google search, various other tools are also used for gachering information about the target/ victim (Table 2.1).

Table 2.1 J Tools used during passive attacks

Name of the Tool	*Brief Description*	*Remarks*
Google Earth	Google Earth is a virtual globe, map, and geographic informarion program. It maps the Earth by the superimposition of images obtained from sacellire imagery and provides aerial phorography of the globe. Ir is available under three differenr licenses: Google Earth, a free version with limiced functionality; Google Earch Plus (discontinued). with additional features; and Google Earth Pro intended for commercial use.	For more details on chis cool, visit: http://earth.google.com/ Like "Google Earth," similar details can be obcaiued &om http://www.wikimapia.org/ Indian Space Research Organization (lSRO) unveiled ics beca version of Bhuvan (meanjng Earth in Sanskrit), a Web-based cool like Google Earch, chat promises berter 3-D satellite imagery of Lndia than is currently being offered by Google Earrh and chat coo with India-specific features such as weather information and even administrative boundaries of all scares and districts, visit: hcrp://bhuvan.nrsc.gov.in/
Internee Archive	The Jncernet Archive is an 1nrerner library, with the purpose of offering permanent access for researchers, historians and scholars co historical collections chat exist in digiral format. It includes telCtS, audio, moving images, and software as well as archived webpages io our coUecrions.	An attacker gees the information about latest update made to the target's websire as well as can dig the information which maybe available in the history (e.g., concacc list of executives and higher management officials a.re always updated). For more deca ils on.chis tool, visit: http://www.archive.org/index.php
Professional Community	Linkedln is an interconnected 11erwork of experienced professionals &om around che world, representing 170 industries and 200 coumries.	One can find details about qualified professionals. For more derails on chis cool, visit: http://www.linkedin.com/
People Search	People Search provides details about personal information: dace of birch, residential address, contact number, ere.	To name a few, visit: • http://www.whicepagesinc.com • hrrp://www.incdius.com/ • hcrp://www.whirepages.com/
Domain Name Confirmation	To perform searches for domain names (e.g., website names) using multiple keywords. This hdps to enable to find every registered domain **name in "com," "net," "org," "edu," "biz," etc.**	For more derails on chis cool, visit: • http://www.namedroppers.com/ • http://www.binarypool.com/byces.hunl

(*Continued*) •

Table 2.1 *(Continued)*

Name of the Tool	Brief Description	Remarks
WHOIS	This is a domain registration lookup cool. This u.tiliry is used for communicating with WHOIS servers located around rhe world to obtain domain registration i.nformation. WHO ISsuppons IP address queries and automatically selects the appropriate WHOIS server for IP addresses. This tool will lookup information on a domain, IP address, or a domain registration information. You can select a speci£c WHOIS server, or you can use the "DeF.utlr" option which will select a server for you.	For more derails on chis tool, visit: • http://whois.domaintools.com/ • http://www.whois.net/ • http://www.samspade.org/ For further details of this lookup utility, visit: • http://resellers.rucows.com/opensrs/whois/ • http://www.nsauditor.com/docs/html/rools/\'v'hois.htm
Nslookup	The name nslookup means "name server lookup." The tool is used on Windows and Unix to query domain name system (DNS) servers to find DNS derails, including IP addresses of a particular computer and other technical derails such as mail exchanger (MX) records for a domain and name server (NS) servers of a domain.	For more details-on this cool, visit: • http://www.kloch.nee/services/nslookup.php • http://nslookup.downloadsofcware4free.com/
Dnsscuff	Using this tool, it is possible to extract DNS information about lP addresses, mail server extensions, DNS lookup, WHOIS lookups, ere.	For more derails on this tool, visit: http://www.dnssruff.com/
Traceroute	This is the best cool to 6nd rhe route (i.e., computer nem:ork path) to a target system. Ir determines the route taken by packers across an rP network.'	For more details on this tool, visit: http://www.rjsmich.com/tracene.hun1
VisualRome Trace	This is a graphical cool which determines where and how virtual traffic on the computer Lletwork is Aowing between source and target destination.	For more details on this tool, visit: htrp://www.visualware.com/
cMailTrackerPro	eMailTrackerPro analyzes the E-Mail header and provides the IP address of the system that sent the maiJ.	For more details on this cool, visit: http://www.emailtrackerpro.com/
HTTrack	"[his tool acts like an offiine browser. Ir can mirror the entire websire ro a desktop. One can analyze the entire websire by being offiine.	For more derails on this cool, visit: http://www.hrcrack.com/
Website Watcher	The tool can be used to keep the crack of fu.vorire websites for an update. When the website undergoes an update/change, d1is tool automarically detecrs it and saves the last rwo versions onto the desk1up.	For more detail.s on rhis cool, visit: http://www.aignes.com/
Competitive Intelligence	Competitive intelligence can provide information related co almost any product, information on recent industry trends, or information about geopolitical indications. Effective use of competitive imelligence can reve I attack against the website or an induscrial espionage.	To name a few, visit • http://bigiral.com/ • hrrp://www.amiry.edu/aici/

Nore: IP is Imemer Prorocol here.

2.2.3 Active Attacks

An active attack involves probing the network to discover indjvidual hosts co confirm the information (IP addresses, operating system type and version, and services on the network) gathered in the passive arrack phase. Ir involves che risk of detection and is also called *"Rattling the doorknobs"* or *"Active rrconnaissance."*

Acdve reconnrussance can provide confirmation co an attacker about security measures in place (e.g., whether the front door is locked?), but the process can also increase the chance of being caught or raise a suspicion.

Table 2.2 gives the list of cools used for active attacks- some of the mols are also used during "vulnerabiJicy assessment" and/or "penetration testing." Refer to Appenrux E i.o CD.

Table 2.2 Tools used during active attacks

Name of the Tool	*Brief Description*	*Remarks*
Arphound	lhis is a tool rhar lisrens to all rraffic on an Ethernet network interface. Ir reports IP/media access control (MAC) address pairs as well as events, such as IP conflicts, rP changes and IP addresses with no reverse DNS, various Address Resolution Prococol (ARP) Spoofing and packers not using the expected gateway.	This is open-source software. For more details on this cool and download, visit: http://www.nottale.net/index.php?projecr=arphound
Arping	This is a network cool char broadcasts ARP packers and receives replies similar to "ping." It Is good for mapping a local network and finding used IP space. It broadcasts a "who-has ARP packet on rhe nerwork and prints answers. It is very useful when rrying ro pick an UJ1used IP for a Net to which routing does not exist as yet.	lhis is open-source software. For more details on this cool and download,visit: http://www.habets.pp.se/synscan/programs.php?prog=:arping
Bing	Th.is is used for Bandwidth Ping. It is a point-to-point bandwidth measurement tool based on ping. Ir can measure raw throughput between any rwo network links. Bing determines the real (raw as opposed to available or average) throughput on a link by measuring Internet Control Message Protocol (ICMP) echo requcsa roundtrip times for different packet sizes for each end of rhe link.	lhis is open-source software. For installation and usage information, visit: http://ai3.asti.dosc.gov.ph/sar/bing.hunl
Buguaq	This is a database of known vulnerabilities and exploits providing a large quantity of technical information and resources.	This software is for free usage. Visit rhc following site for more details: http://www.sccuriryfocus.com/bid
Dig	This is used to perform dera..iled queries about ONS records and *wnes*, extracting configuration, and administrative information about a network or domain.	This is open-source software. For additional technical details, visit: http://www.isc.org/index.pl?/sw/bind/
DNSuaccr	This is a tool ro determine th.c data source for a given DNS server and follow the chain of DNS servers back ro the authoritative sources.	This is aJso open-source software. For additional rccbnical details, visit: http://www.maverju.org/unix/dnscracer.php

Table 2.2 *(Continued)*

Name of the Tool	*Brief Description*	*Remarks*
Dsnilf	This is a ner:work auditing wol co capture username, password, and authentication information on a local subnet.	This is open-source software. For additional technical details, visir: http://monkey.org/-dugsong/dsniff/
Filesnarf	This *is* a network auditing cool co capture file transfers and file sharing traffic on a local subnet.	This is also open-source software. For additional technical derails, visit: http://monkey.org/-dugsong/dsniff/
FindSMB	This is used to find and describe server message block (SMB) servers on che local nerwork.	le is open-source software; visit che following site for downloads: hrrp://us3.samba.org/samba/
Pping	This is a ucility similar to ping used to perform parallel necwork discovery.	For this open-source ftware, visit: hrrp://www.fping.com/
Fragroute	This intercepts, modifies and rewrites egress traffic destined for a specified hose, implementing several intrusion derection system (fDS) evasion techniques.	This is another open-source material; visit.: hctp://www.monkey.org/-dugsong/&agroute/
Fragtest	This rescs the IP fragment reassembly behavior of the Transmission Control Protocol (TCP) stack on a target. Ir intercepts, modifies and rewrites egress traffic destined for a specified host, implementing most of the attacks.	For more details on this open-source software, visit: http://www.monkey.org/-dugsong/fragroure/
Hackboc	This is a hose exploration cool, simple vulnerability scanner and banner logger.	Another open-source software, whose details can be found ar: hrtp://freshmeat.net/projects/hackbot/
Hmap	This is used co obtain derailed fingerprinting of web servers co identify vendor, version, patch level, including modules and much more. *Hmap* is a web server fingerprinting tool.	Details of chis open-source software can be found ac: http://ujeni.murkyroc.com/hmap/
Hping	This is a TCP/JP packet assembler and analyzer. Ic can perform firewall ruleset resting, pore scanning, network type of service/quality-of-service (TOS/QOS) testing, maximum transmission unit (MTU) discovery, alcernace-protocol tracerouce, TCP stack auditing, and much more. Using *hpingyou* can do the following: • Firewall testing; • advanced port scanning; • network testing, using different protocols, TOS, fragmentation; • manual path MTU discovery; • advanced craceroure, under all the supported protocols; • remote OS fingerprinting; • remote uptime guessing; • TCP/IP stacks auditing; • hping can also be useful co scudenrs chat are learning TCP/JP.	This is open-source sofcware. For additional technical details, visit: htrp://www.hping.org/

(*Continued*)

Table 2.2 j *(Continued)*

Name of the Tool	Brief Description	Remarks
	Hping works on che following Unix-like systems: Linux, FreeBSD, NecBSD, OpenBSD, Solaris, MacOs X, Windows.	
Huping	This is similar co "ping," char is, hping, bur for HTTP requests. Ithows how long a URL will rake to connect, send a request, and receive a reply.	This is open-source sofrware. For additional technical **derails,** visit: hrrp://www.vanheusden.com/hrrplng/
Hunc	This is a cool for exploiting well-known wc:iknessc-s in the TCP/rP protocol suirc.	This is also open-source software. For additional rcchnical details, vislc: http://lin.fsid.cvut.cz1- kra/indcx.hrml
Libwhisker	This is an application library designed co assisr in scannabilirics.	Details of this open-source software can be found at: http://www.wirctrip.net/rfp/lw.asp
Mailsnarf	lnis is a nerwork auditing tool to capture SMTmg for CCI/web vulnerP and POP3 E-Mail traffic (induding message headers, bodies, and attachments) on a local subnet.	For this open-source software, you can visir: http://monkey.org/-dugsong/dsniff/
Msgsnarf	This **is a** nerwork auditing tool ro capture instant **message** (Yahoo, MSN, ICQ, iChar, AJM, and many more) traffic on a local subnet.	Same *as* above
NBTScan	This is a utility for scanning networks for NetBIOS information. Ir reports lP address, NerBIOS name, logged-in username, and MAC addrc$s.	Derails of this open-source material can be found at: hrrp://www.inercat.org/software/nbtscan.hunl
Nessus	This is a powerful, fast, and modular security scanner that tests for many thousand of vulnerabilities. ConrrolScam' system can also be used co create cusrnm Nessus reports.	To know more abour this open-source ulility, visit: hrrp://wv,w.nessus.org/
Ncccar	This is a utility to read and wrire custom TCP/ User Datagr.im Protocol (UDP) dara packets across a nerwork cormecrion for network debugging or exploration.	Explore more details of thi. open-source utility at: hrtp://www.acsrakc.com/ research/cools/ neiwork_urilitie\/
Nikto	'Ibis is a web server vulncrabiliry scanner that tests over 2,600 potentially dangerous 61es/CGls on over 625 types of servers. This tool also performs comprehensive rests against web serve formultiple items :ind version-specific problems on over 230 servers. Scan items and plugins are frequenrly updated and cu1 be automalicilly updated (if desired).	Nikro is an open-source web server scanner; visit rhc following site for more dcrnil: hrrp://www.clrc.net/codc/nikro.shrrnl
Nmap	–1his is a port scanner, operating tcm fingcrprinrcr. service/version identifier, and much more. Nmap is designed to rapidly scan large networks.	For derails of this open-source wfrwart", visit: http://insecure.org/nmap/

(umri11ued)

Table 2.2 *(Continued)*

Name of the Tool	Brief Description	Remarks
Pathchar	This is a network cool for inferring the characteristics of Internet paths, including Layer 3 hops, bandwidth capacity, and autonomous system information.	For further details, visit: http://ee.lbl.gov/
Ping	This is a standard nerwork urility to send ICMP packets to a cargec hose.	For further details, visit: http://www.controlscan.com/auditingcools.html#
ScanSSH	This supports scanning a list of addresses and nerworks for open proxies, SSH Protocol servers, and Web and SMTP servers. **Where** possible, it displays the version number of the running services. ScanSSH supports the following features: • Variable scanning speed: per default, ScanSSH sends out I 00 probes per second; • open proxy detection; • random sampling: it is possible to randomly sample hoses on the Internet.	The fuse version of the ScanSSH Protocol scanner was released in September 2000. For further details and downloading the current version, visit: http://www.monkey.org/-provos/scanssh/
SMBclienc	This helps a client co talk to an SMB (Samba, Windows File Sharing) server. Operations include getting files from the server, purring files on the server, retrieving directory information, and much more. le is an open-source/free software suite that has, since 1992, provided file and print services to all types of SMB/common Internet file system (CIFS) clients, including the numerous versions of Microsoft Windows operating systems. Samba is freely available under the GNU General Public License.	
SMTPscan	This is a rool to determine the type and version of a remote Simple Mail Transfer Protocol (SMTP) mail server based on active probing and analy-ting error codes of the target SMTP server.	Por further details, visit: hrcp://www.greyhars.org/outils/smrpscan/
TCPdump	Ir is a nerwork rool for che prorocol packet capture and dumper progran,.	For further details, visit: htrp://ee.lbl.gov/
TCPreplay	This is a utility to read captured TCPdump/pcap data and "replay" it back onto the nerwotk at arbitrary speeds. TCPreplay is a suite of licensed tools written by Aaron Turner for Unix operating systems. le gives you the ability co use previously captured traffic to test a variety of network devices. le allows you to classify traffic as clienr or server: rewrite open system interconnection (OSI) Layers 2, 3 and 4 headers; and finally replay rhe traffic back onto the nerwork and through other	TCPreplay suite includes the following cools: • TCPprep: le is a multi-pass packet capture (pcap) file preprocessor which determines packets as client or server and creates cache files used by TCPreplay and TCPrewrite. • TCPrewrite: It is a pcap file ediror which rewrites TCP/IP and Layer 2 packet headers.

(Co11rinu;!d)

Table 2.2 *(Continued)*

Name of the Tool	Brief Description	Remarks
	devices such as swicches, routers, firewalls, network-based inrrusion de1eccion system (NIDS), and intrusion prevention syscem (IPS). TCPreplay supporcs both single and dual NIC modes for testing both sniffing and inline devices. TCPreplay is used by numerous firewalls, lDS, IPS, and ocher networking vendors, enterprises, universic.ics, laboratories, and open-source projeccs.	• TCPreplay: It replays pcap files at arbicrary speeds onto the network. • TCPreplay-edit: It replays and edits pcap files at arbitrary speeds onto the nerwork. • TCPbridge: It bridges two network segmencs wich the power ofTCPrewrice. For further details, vi it: http://tcpreplay.synfin.nee/uac/
THC-Amap	This is a scanner co remotely fingerprint and identify network applications and services.	For further details, visit: http://freeworld.thc.org/releases.php
Traceroute	This is a scandard network ucilicy to crace the logical path co a target host by sending ICMP or UDP packets with incrementing tunneled transport layer security (TTLs).	For further details, visit: hrtp://ee.lbl.gov/
URL.snarf	This is a net'\'vork auditing tool to capture HTTP traffic on a local subnet.	For further details, visit: http://monkey.orgd/ugsong/dsniff/
XProbe2	This is a cool employing several techniques co actively fingerprint *the* operating system of a targec hosr.	For further details, visit: hrep://www.sys-securicy.com/hrml/projects/X.html

Note: IP is Incerner Prorocol here.
Source: Nina Godbole (2009), *Information Systmis Security: Security Management, Metrics, Frameworks and8e1t l'mcrim* (Table 35.2), Wiley lnd ia.

2.2.4 Scann;ng and Scrutin;z;ng Gathered Information

Scanning is a key step to examine intelligently while gathering information about the target. The objectives of scanning are as follows:

1. **Port scanning:** Identify open/close pores and services. Refer co Box 2.5.
2. **Network scanning:** Understand IP Addresses and related information about d1e computer network systems.
3. **Vulnerability scanning:** Understand the existing weaknesses in the system.

Box 2.5 Ports and Ports Scanning

A port is an interface on a computer to which one can connect a device. TCP/IP Protocol suite made out of the two protocols, TCP and UDP. is used universally to communicate on the Internet. Each of these has ports O through 65536 (i.e., the range is from 2° to i^6 for binary address calculation). The port numbers are divided into three ranges:

Box 2.5 Ports and;Ports ... *(Continued)*

1. Well-known ports (from Oto I023);
2. registered por1s:
3. dynamic and/or private ports.

The list of well-known port numbers and short description about the services offered by each of these ore provided in Tobie 2.3.

Table 2.3 Well-known port numbers

Port Number	Port Description	Port Number	Port Description
1	TCP port service multiplexer (TCPMUX)	118	Struccured query lanb>uage (SQL) services
5	Remote *job* entry (RJE)	119	NNTP (Newsgroup)
7	ECHO	137	NetBIOS name service
18	Message Send Prorocol (MSP)	139	NerBIOS datagram service
20	FTP-Daca	143	lncerner Message Access Prorocol (IMAP)
21	FTP - Control	150	NetBIOS session service
22	Secure shell (SSH) remote log-in prorocol	156	SQLserver
23	Telnet	161	Simple Network Management Prorocol (SNMP)
25	Simple Mail Transfer Protocol (SMTP)	179	Border Gareway Protocol (BGP)
29	MSGICP	190	Gateway Access Control Protocol (GACP)
37	Time	194	Internet relay chat (IRC)
42	Namcserv (hosr name server)	197	Direcrory location service (DLS)
43	WHOIS	389	Lightweight Directory Access Prorocol (LDAP)
49	Log-in (log-in hosr protocol)	396	Novell netware over IP
53	Domain name system (DNS)	443	Secure Hypenex1 Transfer Protocol (S-HTTP)
69	Trivia.I File Transfer Prorocol (TFTP)	444	Simple Network ()aging Prorocol (SNPP)
70	Gopher services	445	Microsoft-OS
79	Finger	458	Apple quick time
80	HTTP	546	DHCPclienc
103	X.400 Standard	547	OHCP server
108	SNA gateway access server	563	SNEWS
109	POP2	569	MSN
110	POP3	1080	Socks
115	Simple File Transfer Protocol (SFTP)		

Source: Nina Godbole (2009), *Information Symms Security: Security Mnnagemem, Metrics, Frnmrn,orks 11nd Bm !'r11aices* (Chapter]5, p. 774). Wiley India.

Box 2.5 Ports and Ports ... *(Continued)*

There ore some well-known IP ports (0-999) that require scanning owing to vulnerabilitiesknown about them. In TCP/IP and UDP networks, a port is on endpoint to a logical connection and the way a client program specifies a specific server program on a computer in a network. Some ports hove numbers that ore preassigned to them by the Internet Assigned Numbers Authority (IANA), on organization working under the auspices of the Internet Architecture Boord (IAB), responsible for assigning new Internet-wide IP addresses.

Tobie 2.3 lists the well-known ports along with the services run on them. Although public servers ore important for communication and data transfer over the Internel. they open the door to potenliol security breaches by threat agents, such as malicious hackers. Vulnerability scanning employs software lhot seeks out security flaws based on o database of known flows. testing systems for the occurrence of these flaws, and generating o report of the findings that an individual or on enterprise con use to tighten the network's security.

Port Scanning

A "port" is a place where information goes into and out of a computer and so. with port scanning, one can identify open doors lo a computer. Ports are basically entry/exit points that any computer has. lo be able to communicate with external machines. Each computer is enabled with three or more external ports. These are the ports used by the computer to communicate with the other computers, printer, modem, mouse, video game, scanner, and other peripherals. The important characteristic about these "external ports" is that they ore indeed external and visible to the naked eye. Port scanning is often one of the first things an attacker will do when attempting to penetrate a particutor computer. Tools such as Nmap (Table 2.2 lists a few vulnerability assessment tools) offer an automated mechanism for on attacker to not only scan the system to find out what ports are "open" (meaning being used), but also help to identify what operating system (OS) is being used by the system.

Port scanning is similar lo a thief going through your neighborhood and checking every door and window on each house to see which ones are open and which ones ore locked. Port scanning is an act of systematically scanning a computer's ports. In technological terms, "port scanning" refers to the oc1 of using various open-ended technologies, tools, and'commands to be able to communicate with another remote computer system or network, in a stealth mode, without being apparent, and be able lo obtain certain sensitive information about the functions of system and the properties of the hardware and the software being used by the remote systems.

In *"portscan,"* a host scans for listening ports on a single target host. In "portsweep," a host scars multiple hosts for a specific listening port. The result of o scan on o port is usually generalized into one of the following three categories:

1. **Open or accepted:** The host sent a reply indicating that a service is listening on the port.
2. **Closed or not listening:** The host sent a reply indicating that connections will be denied to the porl.
3. **Flttered or blocked:** There was no reply from the host.

TCP/IP suite of protocols ls used to communicate with other computers for specific message formats. Most of these protocols are tied to specific port numbers that ore used to transfer particular message formats as data. Security administrators as well os attackers hove o special eye on few well-known ports and protocols associated with ii.

1. Ports 20 and 21 - File Transfer Protocols (FTP) - are used for uploading and downloading of information.
2. Port 25 - Simple Moil Transfer Protocol (SMTP) - is used for sending/receiving E-Mails.
3. Port 23 - Telnet Protocol - is used to connect directly to a remote host and Internet control message.
4. Port 80 - II is used for Hypertext Transfer Protocol (HTTP).
5. Internet Control Message Protocol (ICMP) - It does not hove a port abstraction and is used for checking network errors, for example, ping.

Box 2.5 Ports and Ports ... *(Continued)*

Open ports present two vulnerabilities of which administrators must be wary:

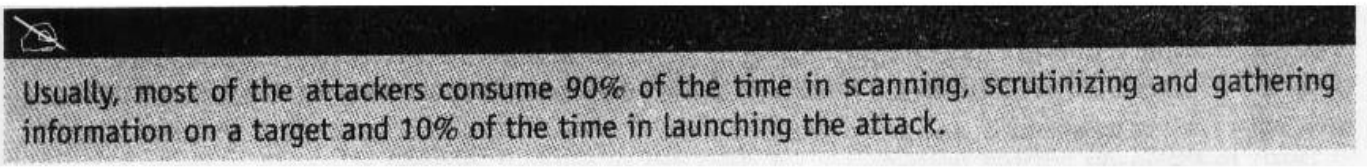
1. Vulnerabilities associated with the program that is delivering the service.
2. Vulnerabilities associated with the OS that is running on the host.

Closed ports present only the lotter of the two vulnerabilities that open ports do. Blocked ports do not present any reasonable vulnerabilities. There is also the possibility that there are no known vulnerabilities in either the software (program) or the OS at the given timeF

The scrutinizing phase is always called "enumeration" in the hacking world. llw objt:ttivc b ·hind this srep is ro identify:

1. 1he valid user accounts or groups;
2. network resources and/or shared resources;
3. OS and djfferent applicarions that are running on the OS.

Most of che tools listed in Table 2.2 arc used for computer network scanning as well.



2.2.5 Attack (Gaining and Maintaining the System Access)

After the scanning and enumeration, the attack is launched using the following steps:

1. Crack the password (we will address it in Chapter 4);
2. exploit the privileges;
3. execute the malicious commands/applications;
4. hide the files (if required);
5. cover the rracks - delete the access logs, so char there is no trail illicit activity.

2.3 Social Engineering

Social engineering is che"technique ro influence" and "persuasion to deceive" people toobtain the information or perform some action. Social engineers exploit **the** natural tendency of a person co crust social engineers' word, rather than exploiting computer security holes. lr is generally agreed that people are chc weak link in securicy and this principle makes social engineering possiBle. A social engineer usually uses celecommunication (i.e., telephone and/or cell phone) or Internet to get them ro do something that is against the security practices and/or policies of the organization.

Social engineering involves gafoing sensirive information or unauthorized access privileges by building inappropriate trust relationships wicl1 insiders. Ir is an art of exploicing the trust of people, which is noc doubced while speaking in a normal manner. The goal of a social engineer is ro fool someone inro providing valuable information or access to thac information. Social engineer studies the human behavior so that

Box 2.6 Social Engineering Example

Mr. Joshi: Hello?

The Caller: Hello, Mr. Joshi. This is Geeta Thomas from Tech Support. Due to some disk space constraintson the file server, we will be movinA few user's home directories to another disk. This activity will be performed tonight at 8:00 p.m. Your accounl will be a part of this move and will be unavailable temporarily.

Mr. Joshi: Ohh ... okay. I will be at my home by then, anyway.

Caller: Great!!! Please ensure lo log off before you leave office. We just need to check a couple of' things. What is your username?

Mr. Joshi: Username is "pjoshi." None of my files will be lost in !he move, right?

Caller: No sir. But we will nave to check your account to ensure the same. What is the password of that account?

Mr. Joshi: My password is "ABCDI965," all characters in upper case.

Caller: Ok, Mr. Joshi. Thank you for your cooperation. We will ensure that all the files ore there.

Mr. Joshi: Thank you. Bye.

Caller: Bye and have a nice day.

people will help because of tbe desire co be helpful, rhe attitude to trust people, and the fear of getting into trouble. The sign of truly successful social engineers is that they receive information without any suspicion. A simple example is calling a user and pretending to be someone from the service desk working on a network issue; the attacker then proceeds co ask questions about what the user is working on, wbat file shares he/she uses, what his/her password is, and so on (see Box 2.6).

2.3.1 Classification of Social Engineering

Human-Based Soda[Engineering

Human-based social engineering refers ro person-co-person inceracrion co gee che required/desired informacion. An example is calling the help desk and crying to find our a password.

1. Impersonating an employee or valid user: "lmpersonation" (e.g., posing oneself as an employee of the same organization) is perhaps che greacest cechnique used by sociaJ engineers co deceive people. Social engineers "take advantage" of rhe face that rnosc people are basically helpful, so icseems harmless co cell someone wbo appears to be lost where the compucer room is locaced, or to let someone into the building who "forgot" bis/her badge, ecc., or pretending co be an employee or valid user on tbe system.
2. **Posing as an important user:** 'TI1e attacker pretends co be an important user - for example, a Chief Executive Officec (CEO) or high-level manager who needs immediate assistance co gain access ro a system. The attacker uses intimidation *so* that a lower-level employee such as a help-desk worker will help him/her in gaining access co che system. Most of the low-level employees will nor ask any question to someone who appears co be in a position of authority.
3. **Using a third person:** An attacker pretends co have permission from an authorized source co use a syscem. This trick is useful when the supposed authorized personnel is on vacation or cannot be comacced for verification.
4. Calling technical support: Calling the technical support for assistance is a classic social engineering example. Help-desk and technical suppor.r personnel are trained to help users. which makes them good prey for social engineering attacks.



Shoulder surfing refers to •using direct observation techniques, such as looking over someone'shoulder, to get information.• Look around your desk, when you enter your passwords. The attacker may be right next to you.

Social Engineering may start right at worklll

Figure 2.3 Social engineering - shoulder surfing.

5. Shoulder surfing: It is a technique of gathering information such as usernames and passwords by watching over a person's shoulder while he/she logs into the system, thereby helping an attacker to gain access to the system (Fig. 2.3).
6. Dumpster diving: Tc involves looking in the crash for information written on pieces of paper or c;omputer printouts. This is a typical North American term; it is used to describe the practice of rummaging through commercial or residential trash to find°useful free items that have been discarded. le is also called dumpsrering, binning, crashing, garbing or garbage gleaning. "Scavenging" is another term to describe these habits. Jn the UK, the practice is referred to as "binning" or "skipping" and the person doing it is a "binner" or a "skipper."

In practice, *dumpstmng* is more like fishing around than diving in. Usually, people dumpster dive to search the items, co reclaim those, which have been disposed of but can still be pur co further use, for example, E-\'v'aste, furniture, clothes, etc. The term "dumpster diving" may have originated from the notional image of someone leaping intolarge rubbish bins, the best known of which are produced under the *name* "dumpster." "Scavenging" is equivalent of"dumpster diving," in the digital world. It is a form in which discarded articles and information are scavenged in an attempt to obtain/recover advantageous dara, ifit is possible to do so. Consider, for example, going through someone's trash to re.cover docurnenration of his/her criticaJ data [e.g., social security number (SSN) in the US, PAN number in India, credit card identity OD) numbers, etc.]. According to a definition in the glossary of terms for the convoluted terminology of information warfare, "scavenging" means "searching through object residue (e.g., discarded disks, rapes, or paper) ro acquire sensitive data without authorization."

Computer-Based Soda[Engjneering

Computer-based social engineering refers to an attempt made to get the required/desired information by using computer sofrware/Tnrernec. For example, sending a fake E-Mail to the user and asking him/her to re-enter a password in a webpage to confirm it.

1. Fake E-Mails: '111c a1tacker scnds fake £-Mails (sec Box 2.7) ro numerous users in $uch ch,u che u finds ic as a legi1im:ue mail. l]1is acriviry is also called "Phishing" (we shall address ir in Chaprer 5). It is an Rttempt to entice rhc Internet useri; (netizens) co rt:Yeal chcir sensitive personal information, sud1a-; user-namcs, passwords and credit card derails by impersonating as a rruscworchy and legitimate organization and/or an individual. Banks, financial institutes and payment gateways are d1e common targecs. Phishing is typically carried out through E-Mails or insrant messaging and often direcrs users LO enter deca.ils at a website, usually designed by che attacker wich abiding rhe look and feel of die original website.]1ius, Phishing is also an example of social engineering techniques IL ro fool netizens. The term "Phishinf has lx.-cn evolved from che analogy that Internet scammers are using E-Mails lures to *ji;·h*for passwords and financial daca from the sea of Incemet users (i.e., neciz.ens). The term was coined in 1996 by hackers who werestealing AOL lnrernec accounrs by scamming passwords wirhout che knowledge of AOL users. As hackers have a tendency of replacing "f' with "ph_," the cerm "Phishinf came into being.

Box 2.7 Fake E-Mails

Free websites ore available to send fake E-Mails. From Fig. 2.4. one con notice that "To" in the text box is a blank space. Hence. anyone con fill any E-Moil address with the intention of fooling the receiver of the E-Mail. In such a case when the receiver willread the mall. he/she would think Ihot the E-Mail has been received from a legitimate sender.

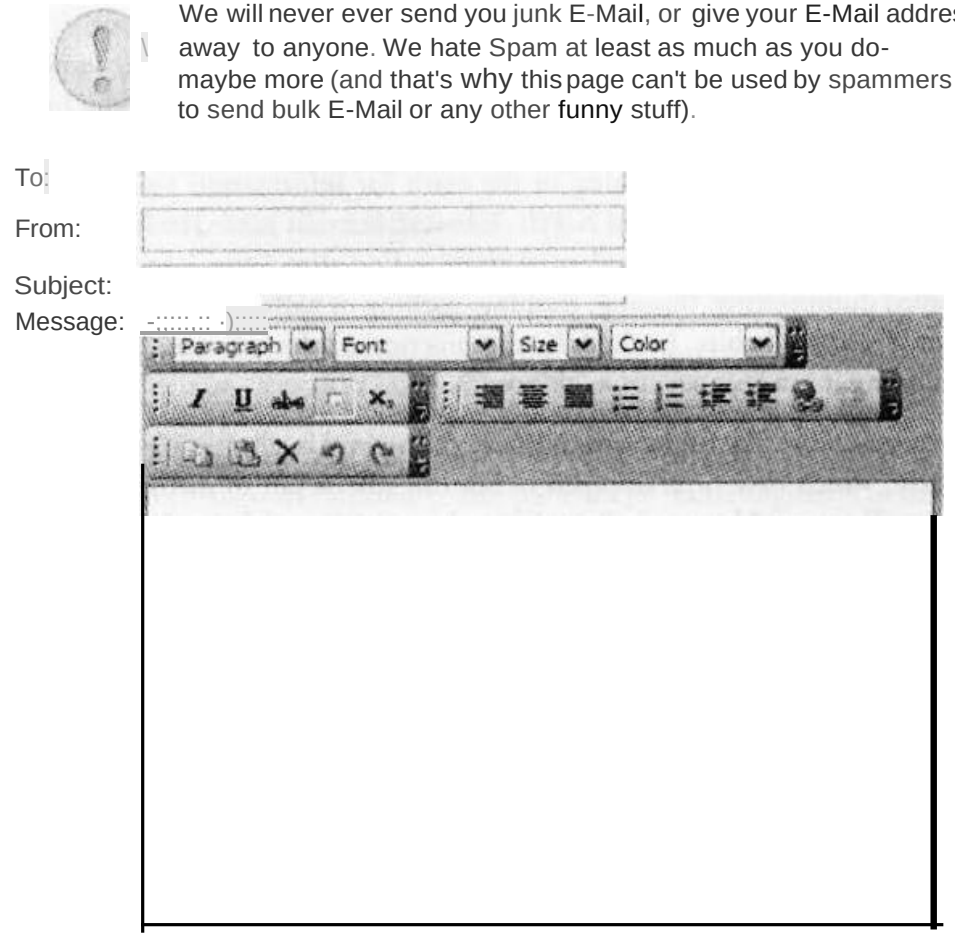


Figure 2.4 Sending fake E-Mails.
Source: http://deadfake.com/Send.aspx (2 April 2009).

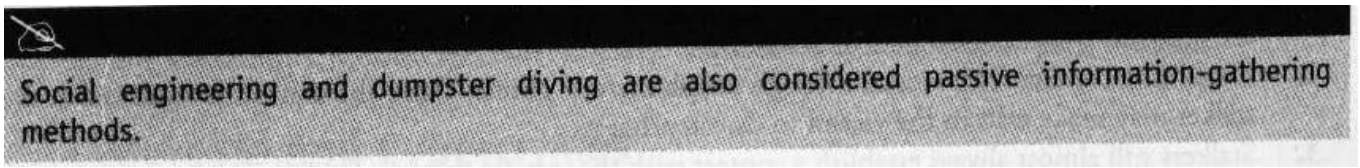
2. **E-MaiJ attachments:** E-Mail accachmencs are used to *send* malicious code co a victim's system, which will automatically (e.g., keylogger utility ro capture passwords) gee executed. Viruses, Trojans, and worms can be included cleverly into the actachmenrs co entice a victim to open the attachment. We will address keylogger, viruses, Trojans, and worms in Chapter 4.
3. **Pop-up windows:** Pop-up windows *are* aJso used, in asimilar manner co E-Mail attachments. Pop-up windows with special offers or free scuff can encourage a user to unincencionally install malicious software.

Social engineering indeed is a serious concern as revealed by the following past statistics on numbers:

1. *As* per Microsoft CQrporation recent (October 2007) research, there is an increase in the number of security attacks designed to steaJ personal information (PI) or the instances of tricking people co provide it through social engineering. According to an FBI survey, on average 41 % of security-rdated losses are the direct result of employees stealing information from their companies. The average cost per internaJ incident was US$ 1.8 million.
2. The FederaJ Trade Commission (ITC) report of 2005 shows chat ..more than one million consumer fraud and ID theft complaints have been filed with federal, state, and locaJ law enforcemenr agencies and private organizations" (2005, Consumer Fraud and Identity Theft section, para I; *we* will discuss ID Theft in Chapter 5).
3. According to a 2003 *survey* [released on 2 April 2006 by the United States Department of Justice (Identity Theft Hits Three Percent, para l)], "An estimated 3.6 million - or 3.1 % - of American households became victims of ID theft in 2004." This means that now, more than ever, individuals are at a hjgh risk of having their Pl stolen and used by criminals for their own personal gain.

TypicaJly, many organizations have information vaJuable enough ro justify expensive prorecrion mechanisms/ security mechanisms. Critical information may include patienr records in the medical and healthcare domain [known as protected heaJth information (PHI)), corporate financial data, decrronic funds cransfers, access co financial assets in the financial services domain, and PI about clients or employees. Compromising critical information can have serious consequences, including the loss of customers, criminal actions being brought against corporate executives, civil law cases against the organization, loss of funds, loss of crust in che organization, and collapse of the organization. To respond to rhe threats, organizations implement lnfoSec plans co establish control of information assets. However, "social engineers" try co device a way to work their way around chis to obtain the vaJuabJe information, an illidt act on echicaJ grounds.

Social engineering succeeds by exploiting the crust of the vicrim. Hence, continuous training/awareness sessions about such attacks are one of the effective countermeasures. Strict policies about service desk staff never asking for personally identifying information, such as username and passwords, over the phone or in person can aJso educate potential victims and recognize a social engineering attempt.


Social engineering and dumpster diving are also considered passive information-gathering methods.

2.4 Cyberstalking

The dictionary meaning of "stalking" is an *"act or process of following prey stealthily- trying toapproach somebody or something."* Cyberstalkiog has been defined as the use of information and communications ced10ology, particularly the Incernec, by an individuaJ or group of individuaJs co harass another individual, group

of individuals, or organization. The behavior includes false accusarlons, monitoring, transmission of threats, [0 theft, damage to data or equipment, solicitation of minors forsexual purposes, and gathering informacion for harassment purposes.[131]

Cyberscalking refers to the use of Internet and/or ocher electronic communications devices to scalk another person. It involves harassing or threatening behavior that an individual will conduce repeatedly, for example, following a person, visiting a person's home and/or ac business place, making phone calls, leaving written messages, or vandalizing against the person's property. As the Internet has become an integral part of our personal and professional lives, cyberstalkers cake advantage of ease of communication and an increased access co personal information available with a few mouse clicks or keystrokes.

2.4.1 Types of Stalkers

There are primarily rwo types of stalkers.

1. **Online stalkers:** They aim co start the interaction with the victim directly with the help of the Internet. E-Mail and char rooms are the most popular communication medium m get connected with the victim, rather than using traditional insmunenration like telephone/cell phone. The stalker makes sure chat the victim recognizes che attack attempted on him/her. The stalker can make use of a third parry co harass the victim.
2. **Offiine stalkers:** The stalker may begin the attack using traditional methods such as following che victim, watching the daily routine of the victim, etc. Searching on message boards/newsgroups, personal websites, and people finding services or websites are most common ways co gather information about the victim using the Internet (see Table 2. I). The victim is not aware that the Internet has been used to perpetuate an attack against chem.

2.4.2 Cases Reported on Cyberstalking

The majority of cyberstalkers are men and the majority of their victims are women. Some cases also have been reported where women act as cybersralkers and men as the victims as well as cases of same-sex cyberscalking. In many cases, the cyberstalker and the victim hold a prior relationship, and che cyberstalking begins when the victim attempts to break off the relationship, for example, ex-lover, ex-spouse, boss/subordinate, and neighbor. However, there also have been many instances of cyberstalking bystrangers.

2.4.3 How Stalking Works?

It is seen chat stalking works in the following ways:

1. Personal information gathering about the victim: Name; family background; contact details such as cell phone and tdephone numbers (of residence as well as office); address of residence as well as of the office; E-Mail address; date ofbirth, etc.
2. Establish a contact with victim through telephone/cell phone. Once the contact is established, the stalker may make calls co che *victim* to threaten/harass.
3. Stalkers will almost always establish a contact with the victims through E-Mail. The letters may have the tone of loving, threatening or can be sexually explicit. The stalker may use multiple names while contaccing the victim.
4. Some stalkers keep on sending repeated E-Mails asking for various kinds of favors or threaten the victim.

Box 2.8 Cyberbullying

The Notional Crime Prevention Council defines *Cyberbullying* as "when the Internet. cell phones or other devices are used lo send or post text or images intended to hurt or embarrass another person."

www.StopCyberbulfying.org. an expert organization dedicated to Internet safety, security, and privacy defines cyberbullying as "a situation when a child, tween, or teen is repeatedly 'tormented, threatened. harassed, humiliated, embarrassed, or otherwise targeted' by another child. tween, or teen using text messaging, E-Mail, instant messaging. or any other type of digital technology."

The practice of cyberbullying is not limited to children and, while the behavior is Identified by the some definition in adults. the distinction In age groups is referred to as cyberstolking or cyberhoross-ment when perpetrated by adults toward adults.I◂I

Source: http://en.wikipedlo.org/wilc:i/Cyber-bullylng (2 April 2009).

5. The stalker may pose che victim's personal information on any website related co illicit services such as sex-workers' services or dating services, posing as if the victim has posted th information and invite rhe people to call the victim on the given contact details (telephone numbers/cell phone numbers/E-Mail address) co have sexual services. The stalker will use bad and/or offensive/attractive language co invite the interested persons.
6. Whosoever comes across rhe information, start calling rhe victim on the given contact details (telephone/cell phone nos), asking for sexual services or relationships.
7. Somestalkers subscribe/register the E-Mail account of the victim to innumerable pornographic and sex sites, because of which victim will starr receiving such kind of unsolicited E-Mails (refer to Chapter 5).

2.4.4 Real-Life Incident of Cyberstalking

Case Study

The Indian police have registered first case of cyberstalking in Delhi[151] - the brief account of the case has been mentioned here. To maintain confidentialityand privacy of the entities involved, we have changed their names.

Mrs. Joshi received almost 40 calls in 3 days mostly at odd hours from as far away as Kuwait, Cochin, Bombay, and Ahmadabad. The said calls created havoc in the personal Life destroying mental peace of Mrs. Joshi who decided to register a complaint with Delhi Police.

A person was using her ID to char over the Internet at the website www.mirc.com, moscly in the Delhi channel for four consecutive days. This person was chatting on the Internet, using her name and giving her address, talking in obscene language. "ll1e same person was also deliberately giving her telephone number ro other chatters encouraging chem co call Mrs. Joshi at odd hours.

This was the first rime when a case of cyberstalking was registered. Cyberstalking does nor have a standard definition but it can be defined co mean rb.reaceoing, unwarranted behavior, or advances directed by one person toward another person using Internet and other forms of online communication channels as medium.

2.5 Cybercafe and Cybercrimes

In February 2009, Nielsen survey[161] on the profile of cybercafes users in India, it was found char 90% of rhe audience, across eight cities and 3,500 cafes, were male and in the age group of 15-35 years; 52% were graduates and postgraduates, though almost over 50% were scudencs. Hence, it is extremely important ro understand the JT security and governance practiced in the cybercafes.

In rhe past several years, many instances have been reported in India, where cybercafes are known to be used foe either real or fulse terrorist communication. Cybercrimes such as stealing of bank passwords and subsequem fraudulent wirhdrawaJ of money have also happened rhrough cybercafes. Cybercafes have also been used regularly for sending obscene mails co harass people.

Public computers. usually referred to the)'Stems, available in cybercafes, hold cwo types of risks. First, *we* do not know what programs are installed on the computer - char is, risk of malicious programs such as *keylor,gers* or *Spy1uare,* (we will discuss it in Chapter 4) which maybe running ac che background that can capture the keystrokes to know the passwords and ocher confidential information and/or monitor the browsing behavior. Second, over-the-shoulder peeping (i.e., shoulder surfing) can enable ochers to find our your passwords. 11,erefore, one bas co be extremely careful about procccccing his/her privacy on such systems, as one does nor know who will use rhe computer after him/her.

Indian lnformacion TcclrnoJogy Ace (ITA) 2000[171](iris discussed in great detail in Chapter 6) does not define cyhercafes and incerprecs cybercafes as "nerwork service providers" referred co under the erstwhile Section *79,* which imposed on chem a responsibility for "due diligence" fuiling which they would be liable for the offenses committed in their network. The concept of"due dili?,ence" was interpreted Ii-om the various provisions in cybercafe regulations where available or normal responsibilities were expected from network service providers.

Cybercriminals prefer cybercafes to carry out rheir activiries. The criminals tend to identify one particular personal computer (PC) co prepare it for cheir use. Cybercriminals can either install malicious programs such :1s keyloggers and/or Spyware or launch an accack on rhe target - techniques used for chis are discussed in Chapter 4. CybercriminaJs will visit these cafes at a panicuJar rime and on the prescribed frequency, maybe alternate day or twice a **week.**

A recenr survey conducted in one of rhe metropolitan cities in India reveals the following facts (this is an eye-opener after going through che following observations:

1. Pirated software(s) such as OS, browser, office automation software(s) (e.g., Microsoft Office) arc installed in all rhe computers.
2. Anrivirus software is found to be nor updared co the latest patch and/or antivirus signature.
3. Several cybercafes had installed the software *called* "Deep Freeze" for protecting the computers from prospective mahvare attacks. Although such inrenc is noble, thissoftware happens to help cybercriminals hoodwink the investigating agencies. Deep Freezecan wipe our tbe details of all activities carried out on the computer when one clicks on the "restart" burcon.[181]Such practices present challenges ro tht police or crime invescigacors wh_en rhey visic the cybercafes co pick up dues after the lnrerer Service Provider (ISP) points to a particular IP address from where a threat mail was probably senr or an online Phishing arrack (Phisbing attacks are explained in Chapter 5) wa. carried out, to retrieve logged *files.*
4. Annual maintenance contract (AMC) found to be not in a place for servicing tbe computers; hence, hard disks for all the computers are nor formatted unless rhe computer is down. Nor having che AMC is a risk from cy-bercrimc perspective because a cybercriminal can inscaJJ a Malicious Code on a computer and conduct criminal activities without any interruption.
5. Pornographic websites and ocher similar websites with indecent contents are not blocked.
6. Cybercafe owners have very less awareness about rT Security and -TT Governance.
7. Governmenc/TSPs/Scace Police (cyber cell wing) do not seem to provide IT Governance guidelines co cybercafe owners.
8. Cybercafe association or State Police (cyber cell wing) do nor seem to conduct periodic visits to cybercafcs - one of tbe cybercafe owners whom we interviewed expressed a view chat the police will nor visit a cybercafe unless criminal activity is registered by filing an First Information Report (FIR). Cybercafe owners feel chat police either have a very little knowledge about the technical aspects involved in cybercrimes and/or about conceptual understanding ofIT security.

There are thousands of cybercafes across India. In the evenc that a cenrral agency cakes up the responsibility for moniroring cybercafes, an individual should cake care while visiting and/or operating from cybercafe.

There is an expectation that the Indian Computer Emergency Team referred to under Section 70B of ITA 2008 may itself be designated as the agency of the Central Government with a national jurisdiction and (Computer Emergency Response Team) CERT, and may itself be stepping into the shoes of the Indian Computer Emergency Team.[7,8]

Here are a few rips for safety and security while using che computer in a cybercafo:

I. Always logout: While checking E-Mails or logging into charting services such as inseam messaging or using any ocher service rhac requires a username and a pa sword, always click "logout or "sign ouc" before leaving rhe sysrem. Simply closing che browser window is not enough, because if somebody uses che same service after you then one can ger an easy access co your account. However, do noc save your login information through options char allow automatic login. Disable such options before logon.

2. Stay with the computer: While surfing/browsing, one should not leave the syscem unattended for any period of time. If one has co go ouc, logout and close all browser windows.

3. Clear history and temporary fiJes: lncernec Explorer saves pages that you have visited in che history folder and in temporary Internet files. Your passwords may aJso be scored in the browser if char option has been enabled on the computer that you have used. Therefore, before you begin browsing, do the following in case of the browser Internet Explorer:
   - Go to *Tools Internet options* click rhe *Content* t'ab click *AutoComplete.* If the checkboxes for passwords are selected, deselect them. Click *OK* twice.
   - After you have finished browsing, you should clear the history and temporary Internet files folders. For chis, go to *Tools Internet options* again dick the *General* tab go to *Tempora,-y Internet Files* click *Dekte Fil.es* and then dick *Delete Cookies.*
   - Then, under history, click clear history. Wair for the process to finish before leaving the computer.

4. **Be alert:** One should have to stay alert and aware of the surroundings while using a public computer. Snooping over the shoulder is an easy way of getting your username and password.

5. **Avoid online financial transactions:** Ideally one shouJd avoid online banking, shopping or ocher transactions char require one co provide personal, confidential and sensitive information such as credit card or bank account derails. ln case of urgency one has to do it; however, one should cake the precaution of changing all the passwords as soon as possible. One should change the passwords using a more trusted computer, such as at home and/or in office.

6. Change passwords: The screenshoc displayed in Fig. 2.5 by ICICI Bank abouc changing the bank account/transaction passwords is cbe best practice co be foUowcd.[191]

7. **Virtual keyboard:** Nowadays almost every bank has provided the vircual keyboard on their website. The advanta es of utilizing virtual keyboard and its functions arc di.splayed in the screenshocshown in Fig. 2.6.[111]

8. **Security warnings:** One should cake urmosc care while accessing the websites of any banks/financial institution. The screenshor in Fig. 2.7 displays security warnings very clearly (marked in bold rectangle), and should be followed while accessing these financial accounts from cybercafe.

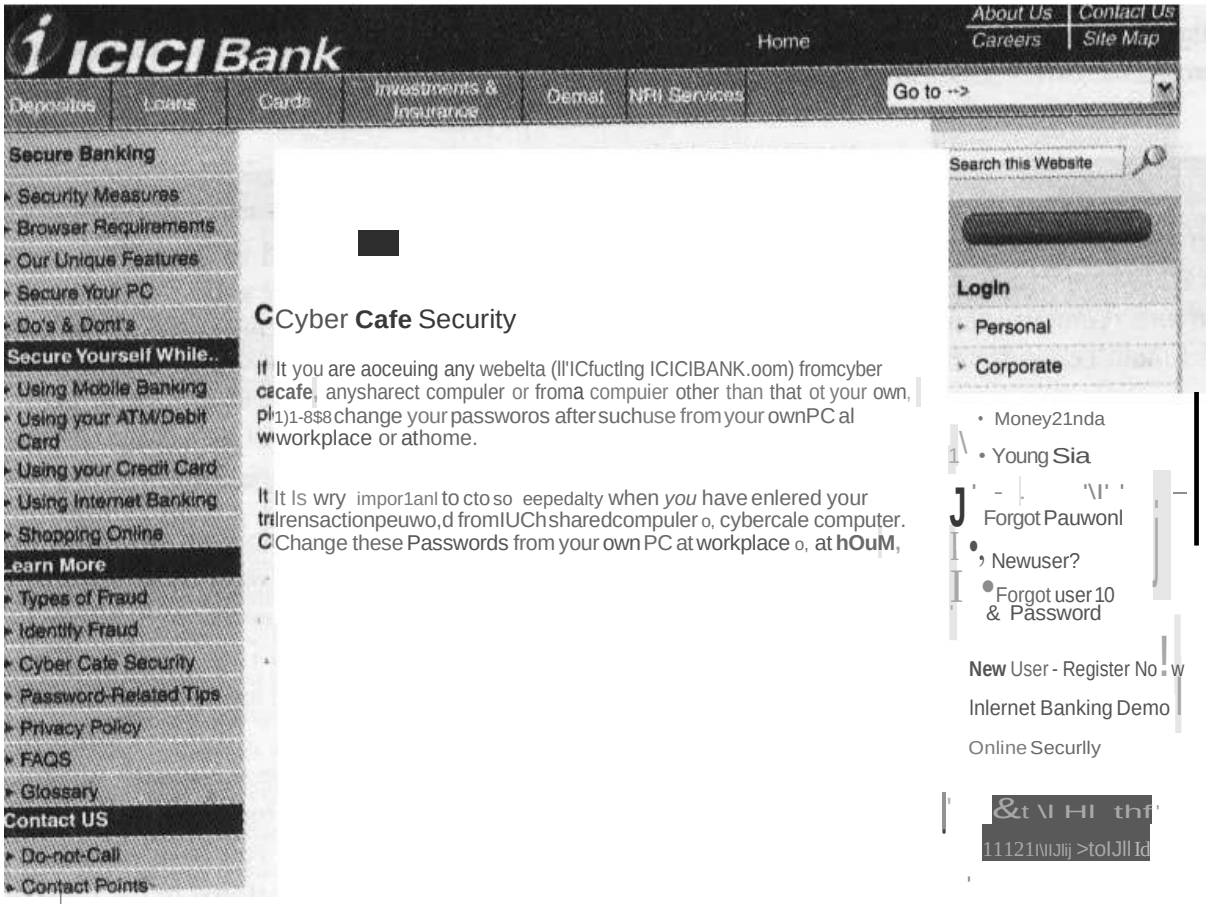
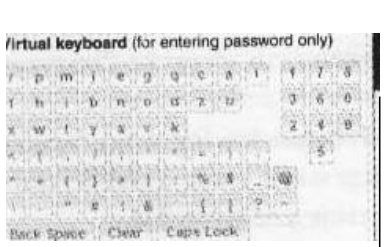


Figure 2.5 Cybercafe security.

Source: http://www.icicibank.com/pfsuser/temp/cybersec.htm (27 June 2009).



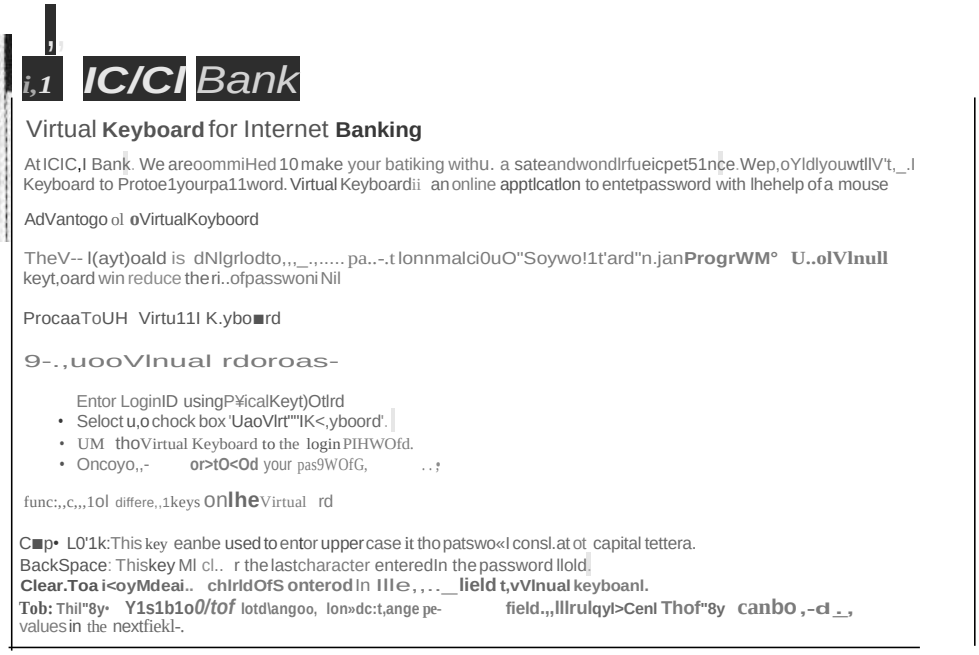


Figure 2.6 Virtual keyboard.

Source: http://www.icicibank.com/pfsuser/Webnews/Virtualkeyboad.htm (27 June 2009).

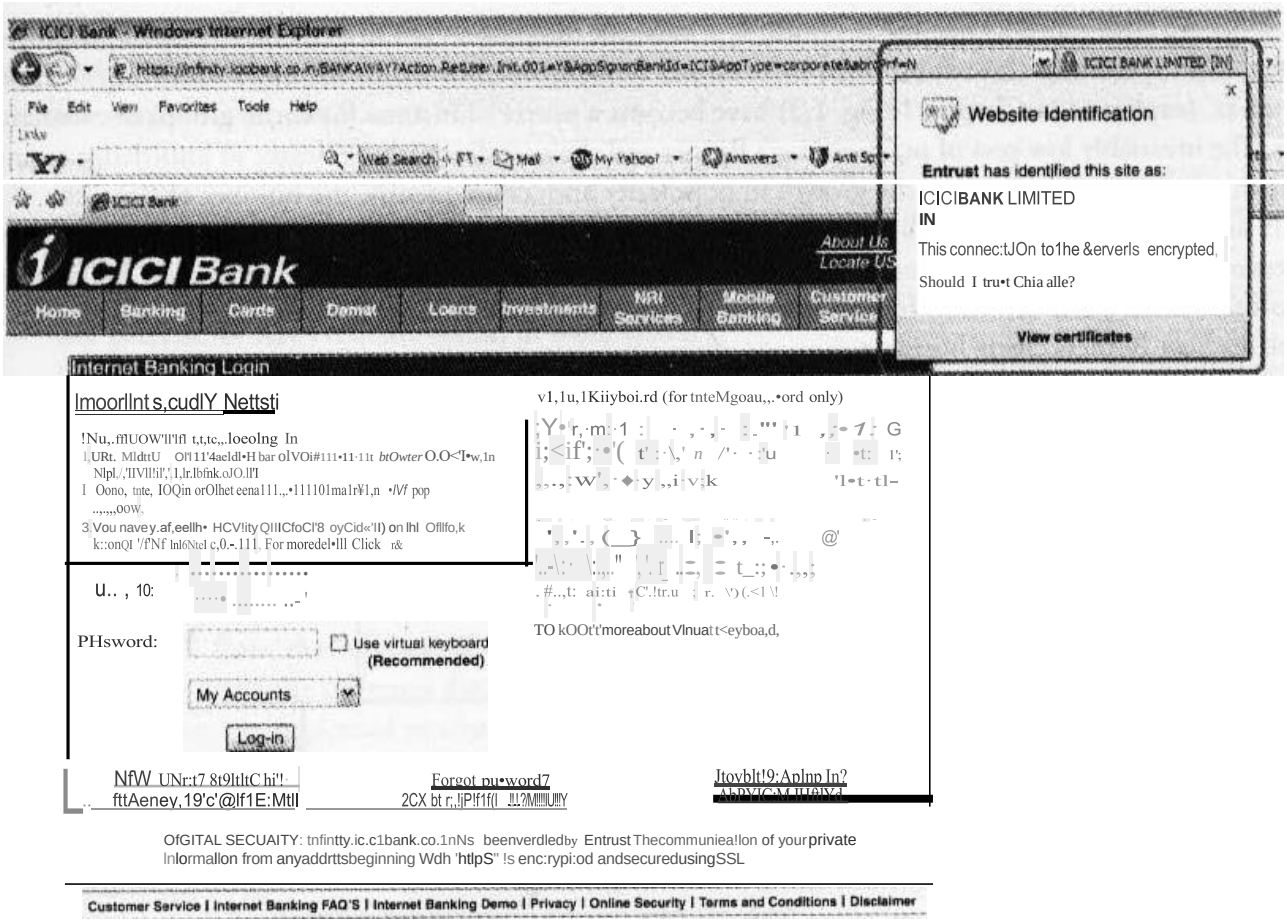


Figure 2.7 Security warnings.
Source: http://www.icicibank.com/pfsuser/webnews/virtualkeyboad.htm (27 June 2009).

Individual should rake care while accessing computers in public places, chat is, accessing the fncernet in public places such as bocels, libraries and holiday resorts. Moreover, one should not forget that whatever is applicable for cybercafes (i.e., from information security perspective) is also true in che case of all other public places where the Internet is made available (refer co Appendix J in CD). Hence, one should follow all tips about safery and security while operating the systems from these facilities.

2.6 Botnets: The Fuel for Cybercrime

2.6.1 Botnet

The dictionary meaning of Boe is*"(computing) an ,zutomated program far dfling some_particular task, often over a network."*

Botner is a term used for collection of software robots, or Boes, that run autonomously and automatically. The term is often associated with malicious software but can also refer co the network of computers using distributed computing software.[11 1)]

ln simple terms, a Bot is simply an automated computer program (explained in Box 1.2, Chapter l). One can gain rhe control of your computer by infecting chem with a *virus* or other Malicious Code chat gives rhe access. Your computer system maybe a pare of a Botner even though it appears co be operating normally. Bomecs are often used co conduct a range of activities, from distributing Spam and viruses ro conducting denial-of-service (DoS) attacks (the term is discussed in detail in Chapter 4).

A Bomec (also called as z.ombic ncrwork) is a nerwork of compurers infecred wirh a malicious program chat allows cybcrcriminals co concrol the infected machines remotely withour d1c users' knowledge. *"Zombir nnworks"* (explained in Chapter I, Fig. 1.3) have become a source of income for encire groups of cybercriminals. Tue invariably low cost of maintaining a Bomer and che ever diminishing degree of knowledge requfred ro manage one arc conducive to chc growth in popularjry and, consequently, the number of Botner$.

If someone wanrs co srarr a "business" and has no programmfog skills, there are plenty of "Bot for sale" offers on forums. Obfuscation and encryption of dlcse programs' code can also be ordered in rhe same way ro protect chem from detection by antivirus tools. Another option is to sreal an existing Bomer. Figure 2.8 explains how Botners create business.

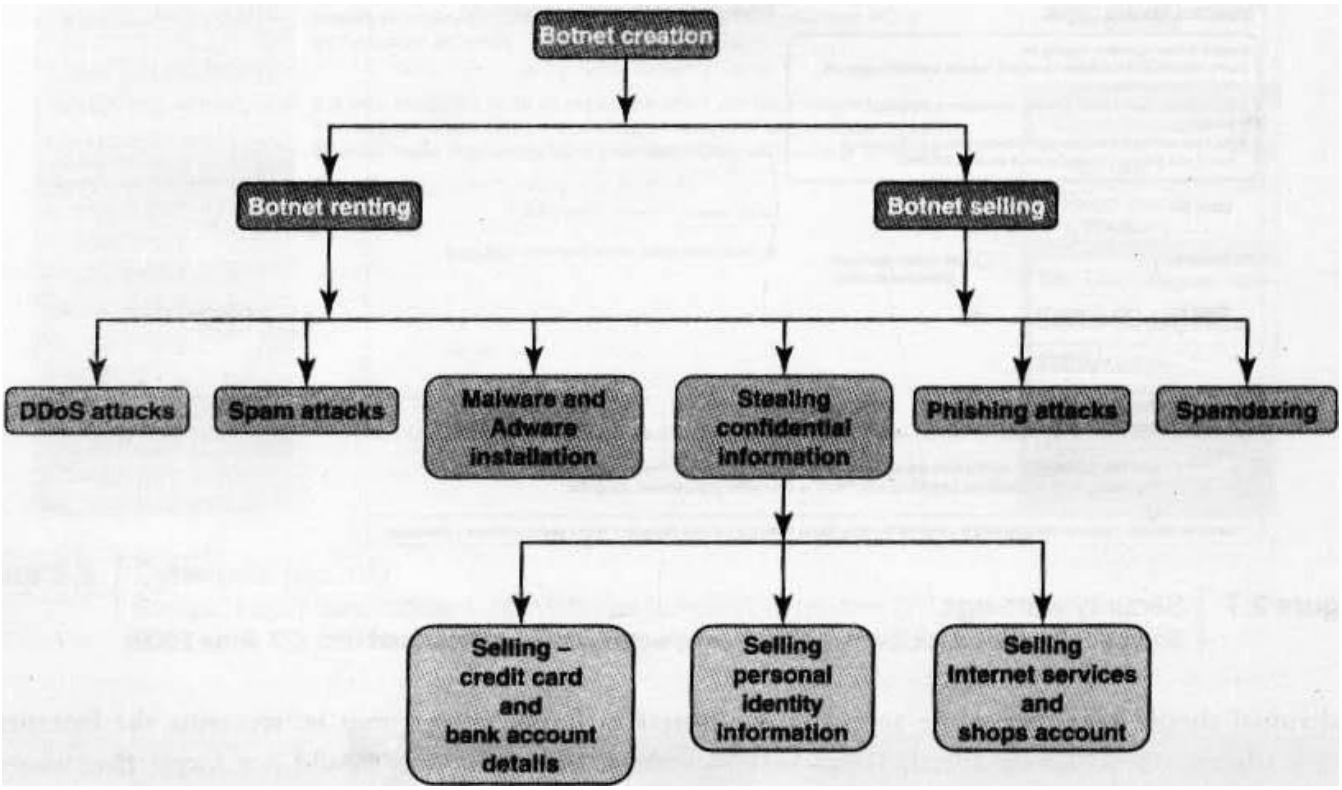


Figure 2.8 Botnets are used for gainful purposes.

Box 2.9 Explanation for Technical Terms used in Fig. 2.8

Malware: If is malicious *software.* designed to damage *a* computer system without the owner's informed consent. Viruses and worms ore the examples of molwore.

Adware: It is *advertising-supported software,* which automatically ploys, displays, or downloads advertisements lo a computer ofter the software is installed on it or while the application is being used. Few Spywores are clo ifled as Adware.

Spam: It means unsolicited or undesired E-Mail messages (this is discussed in detail in Chapter 5).

Spamdexing: It ls also known as search Spam or search engine Spam. It involves a number of methods. such as repeating unrelated phrases. to manipulate the relevancy or prominence of resources indexed by o search engine in a manner inconsistent with the purpose of the indexing system.

DDoS: Distributed denial-of-service attack (DDoS) occurs when multiple systems flood the bandwidth or resources of a targeted system, usually one or more web servers. These systems ore compromised by attackers using a variety of methods (this is discussed in details in Chapter 4).

One can reduce the chances of becomjng part of a Bot by limjring access into the system. Leaving your lnrernet connection ON and unprotected is just like leaving the front door of the house wide open. One can ensure following to secure rhe system: [112.n.1]

1. **Use antivirus and anti-Spyware software and keep it up-to-date:** le is important ro remove and/or quarantine the viruses. The settings of rhese softwares should be done during the installations *so* rhac these softwares get updared automatically on a daily basis.
2. **Set the OS to download and install security patches automatically:** OS companies issue rhe security patches for Raws chat are found in these systems.
3. **Use a firewall to protect the system &om hacking attacks while it is connected on the Internet:** A firewall is a software and/or hardware that is designed to block unauthorized access while permirring authorized communications. Tc is a device or set of devices configured co permit, deny, encrypt, decrypt, or proxy all (in and out) computer traffic between different security domains based upon a set of rules and other criteria. A firewall is different from anrivirus protection. Antivirus software scans incoming communications and files for troublesome viruses vis-a-vis properly configured firewall chat helps to block all incoming communications from unauthorized sources.
4. **Disconnect from the lnternet when you are away from your computer:** Attackers cannot gee into the system when the system is disconnected from the liiternet. Firewall, antivirus, and ami-Spyware softwares are not foolproof mechanisms co get access co the system.
5. **Downloading the freeware only from websites that are known and trustworthy:** It is always appealingco download free software(s) such as game.s, file-sharing programs, customized toolbars, etc. However, one should remember that many free software(s) contain other software, which may include Spyware.
6. Check regularly the folders in the mail box - "sent items" or "outgoing" - for those messages you did not send: If you do find such messages in your ourbox, it is a sign that your system may have infected with Spyware, and maybe a part of a Borner. This is not foolproof; many spammers have learned tO bide their unauthorized access.
7. Takean immediate action if your system is infected! If your system is found to be infected bya virus, disconnect it from tf:ie lnterner immeruacely. Then scan the entire system with fuUy updated amivirus and anti-Spyware software. Report the unauthorized accesses to ISP and to the legal authorities. There is a possibility that your passwords may have been compromised in such cases, so change all the passwords immeruarely.

2.7 Attack Vector

An "arrack vector" is a path or means by which an attacker can gain access co a computer or to a network server to deliver a payload or ma.licious outcome. Attack vecrors enable attackers to exploit system vulnerabilities, including the human element. Attack vectors include viruses, E-M J attachments, webpages, pop-up windows, instant messages, chat rooms, and deception. All of these methods involve programming (or, in a few cases, hardware), except deception, in which a human operator is fooled into removing or weakening system defenses.[1141]

To some extent, firewalls and antivirus software can block attack vectors. However, no protection method is totally attack-proo(A defense method chat Is effective today may not remain so **for** long because attackers are constantly updating attack vectors, and seeking new ones, in their quest to gain unauthorized access to computers and servers. Refer to Box 2.10.

Box 2.10 Zero-Day Attack

A zero-day (or zero-hour) ottock[1171]Is o computer threat which attempts to explolt computer application vulnerabilities that ore unknown to anybody in the wor1d (i.e.. undisclosed to the software vendor and software users) and/or for which no patch (i.e.. security fix) Is available. Zero-day exploits ore used or shored by attackers before the software vendor knows about ihe vulnerability.

Sometimes software vendors discover the vulnerability but developing a patch con toke time. Alternatively, soltware vendors con also hold releasing the patch reason to avoid the flooding the customers with numerous individual updates. A "zero-day" attack is launched Just on or before the first or "zeroth" day of vendor awareness, reason being the vendor should not get any opportunity to communicate/distribute o security fix to users of such software. If the vulnerability is not porticulorty dangerous, software vendors prefer to hold until multiple updates (I.e.. security fixes commonly known as patches) are collected and then release them together aso package.

Malwore writers ore able to exploit zero-day vulnerabilities through several different attack vectors.

Zero-day emergency response team (ZERT): This is a group of software engineers who work to release non-vendor patches for zero-day exploits. Nevada is attempting to provide support with the Zerodoy Projecl at www.zerodayproject.com. which purports to provide information on upcoming a1tacks and provide support to vuineroble systems. Also visit the weblink http://www.isotf.org/zert to get more information about it.

Source: http://en.wikipedio.org/wikf/Zero_doy_ottock (9 October **2009}.**

The most common malicious payloads are viruses (which can function as their own arcack vectors), Trojan Horses, worms, and Spyware (refer to Chapter 4). If an arcack vecror is thought of as a guided missile, its payload can be compared ro che warhead in the tip of rhe missile.

In the technical terms, *payload* is che necessary data being carried within a packet or orher transmission unit - in this scenario (i.e., arrack vecror) payload means the malicious activity 1hat che arcack performs. From the technical perspective, payload does not include che "overhead" data required to gee the packer ro irs destination. Payload may depend on rhe following poinr of view: Whar constiLUces it?" To a communications Layer rhac needs some of the overhead dam ro do its job, the payload is sometimes considered to include char part of the overhead data chat this layer handle. . However, i.n more general usage, the payload is rhe bits' that gee delivered to the end-user ac che desrinarion.[11 .161]

The arrack vectors described here are how mosr of rhem are launched.[11c'.181]

1. Auack by E-Mail: ·n,e hostile content is either embedded in the message or linked ro by cbe message. Somerimes accacks combine rhe two vectors, so thar if che message does no1 gcr you. rhe arrnchmem will. Spam is almost always carrier for scams, fraud, dirty rricks, or malicious action of some kind. Any link rhat offers something "free" or tempting is a suspec1.
2. Attachments (and other files): Malicious arracbments install malicious computer code. The code could be a virus, Trojan Horse, Spyware, or any orher kind of malware. Attach111enrs attempt ro install their payload as soon as you open rhem.
3. Arrack by deception: Deception is a.imed at the user/operator as vulnerable enrry point. h is nor just malicious computer code char one needs co monitor. Fraud, scams. hoaxes, and co some extenr Spam, not to mention viruses. worms and such require rhe unwitting cooperation of the computer's operator to succeed. Social engineering and hoaxes are ocher forms of deception char are often an attack vector roo.
4. **Hackers:** Hackers/crackers are a formidable attack vector because, unlike ordinary Malicious Code, people are Aexible and they can improvise. Hackers/crackers use a variety of hacking tools, heuristics,

and social engineering co gain access to compucers and online accounrs. They often install a Trojan Horse to commandeer the computer for their own use.

5. **Heedless guests {attack by webpage):** Counterfeit websites are used to extract personal inf9rmation. Such websites look very much like rhe genuine websites they imitate. One may think he/she is doing business with someone you trust. However, he/she is really giving their personal information, like address, credit card number, and expiration dare. They are often used in conjunction with Spam, which gets you there in the first place. Pop-up webpages may install Spyware, Adware or Trojans.
6. Attack of the worms: Many worms are delivered as E-Mail attachments, but network worms use boles in network protocols directly. Any remote access service, like file sharing, is likely to be vulnerable ro chis sort of worm. In most cases, a firewall will block system worms. Many of these system worms install Trojan Horses. Next they begin scanning che Internee from cbe computer they have just infected, and start looking for other computers to infect. If the worm is successful, it propagates rapidly. The worm owner soon has thousands of "zornbie" computers rouse for more mischief.
7. **Malicious macros:** Microsoft Word and Microsoft Excel are some of cbe example schat allow macros. A macro does so ething like automating a spreadsheet, for example. Macros can also be used for malicious purposes. All Internee*services* like instant messaging, Internee Relay Chart (lRC), and P2P file-sharing networks rely on cozy connections between the computer and cbe ocher computers on the Internee. If one is using P2P software then his/her system is more vulnerable to hostile exploits.
8. **Foistware (sneakware):** Foistware is the software char adds hidden components ro the system on the sly. Spyware is the most common form of foisrware. Foistware is quasi-legal software bundled with some attractive software. Sneak software often hijacks your browser and diverts you co some "revenue opportunity" rhac the foistware has sec up.
9. **Viruses:** These are malicious computer codes chat hicch a ride and make the payload. Nowadays, virus vectors include E-MaiJ acrachmencs, downloaded files, worms, ecc.

2.8 Cloud Computing

The growing popularity of cloud computing and vinualization among organizations have made it possible, the next target of cybercriminals. Cloud computing services, while offering considerable benefits and cost savings, move servers outside che organizations security perimeter, which makes ic easier for cybercriminals to attack these systems.

Cloud comriuting is Internet {"cloud")-based development and use of computer cechnology ("computing").[191] The term cloud is used as a metaphor for che Internee, based on cbe cloud drawing used ro depict the Internet in computer networks. Cloud computing is a term used for hosted services delivered over che Internet. A cloud service bas three distinct characteristics which differentiate ic from traditional hosting:

1. le is sold on demand - typically by cbe minute or cbe hour;
2. it is elastic in terms of vsage - a user can have as much or as little of a *service* as he/she wanes at any given time;
3. the service is fuJly managed by the provider - a user just needs PC and Interneeconnection.

Significant innovations into distributed computing and virtualization as well as improved access speed over the lncernec have generated a great demand for cloud computing.

2.8.1 Why Cloud Computing?

The cloud computing has following advantages[1201]:

1. Applications and data can be accessed from anywhere at any rime. Dara may noc be held on a hard drive on one user's computer.
2. le could bring hardware coses down. One would need the [ncernet connection.
3. Organizations do noc have to buy a sec of software or software licenses for every employee and the organizations could pay a metered fee co a cloud computing company.
4. Organizations do not have co rent a physical space co store servers and databases. Servers and digital scorage devices take up space. Cloud computing gives the option of scoring data on someone else's hardware, thereby removing the need for physical space on the front end.
5. Organizations would be able co save money on IT suppon because organizations will have ro ensure about the desktop (i.e., a client) and continuous Internet connectivity instead of servers and ocher hardware.

The cloud computing services can be either priv:ite or public. A public cloud sells services co anyone on che Internet (see Table 2.4 for cloud computing service providers). A private cloud *is* like a proprietary network or a daca center that supplies che hosted services ro a limited number of people. When a ser- vice provider uses public cloud resources ro create a private cloud, che result is called a "virtual private cloud." The goal of cloud computing is to provide easy, scalable access co the computing resources and IT services.

Table 2.4 j Cloud computing service providers

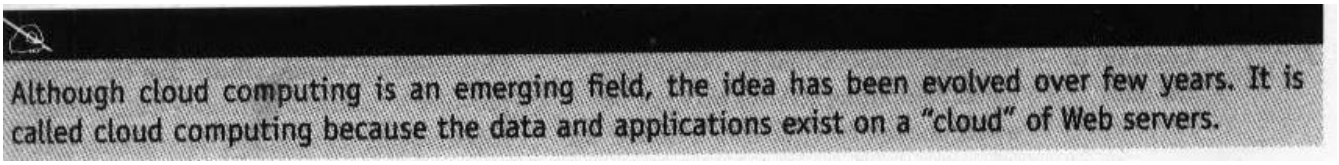
ir. No.	Service Providers	Weblink
I.	Amazon: Ir offers flexible, simple, and easy computing environment in the cloud that allows dcvdopmcm of applications.	hctp://aws.amazon.com/ec2/
2.	3Tera: It offers AppLogic grid OS that enables infrastructure solutions according to che changing needs of business.	hrcp://www.3cera.com/
3.	Force.com: le allows building of core business applications like enterprise resource planning (ERP). human re. ource management (HRM). and supply chain management (SCM).	htcp://www.salesforce.com/platform/
4.	Appiscry-Cloud Computing Middlewarc: It allows easily scalable cloud computing for a wide variety of applications and services for both public and private clouds.	hrrp://www.appisrry.com/
5.	Microsoft Live Mesh: This cloud setup synchronizes rhc 6Jes with chc all users' devices like laptop, Mac, mobile phone, or orhe.rs and allows ro access the files from any device as well as enables sharing of files.	hrcps://www.mesh.com/Welcome/defaulc.aspx
6.	**AppNexus:** This helps a user to launch scveraJ operacing systems, run a variety of applications, load baJance these applications, and store huge amounr of secure data.	hcrp://www.appnexus.com/

(Contin11ed)

Table 2.4 *(Continued)*

Sr. No.	ervice Providers	Weblink
	Flexiscale: It *is* self-service through conrrol panel or API - feacures full self-service - starc/srop/delete, change memory/CPU/srorage/IPs of virtual dedicated servers.	hrcp://www.flexiscale.com/
8.	GoogleApp Engine: This is a free setup that allows the users ro run their web applicacion on Google infrastructure.	hrcp://www.google.com/apps/inrl/cn/business/index.hrml
9.	GoGrid: It offers unique multiscrvcr control panel thar enables the user to deploy and manage load-balanced cloud servers.	hrrp://www.gogrid.com/
JO.	Terremark Enterprise Cloud: le provides rhe power to rhe user for computing resources for user's mission-critical applications.	http://w, w.terremark.com/serviccs/cloudcomputing/thecnterprisecloud.aspx

Sourct: hnp://blog.taragana.corn/indcx.php/archive/top-10-cloud-compuring-mvice-providcr/ (9 October 2009).



2.8.2 Types of Serv;ces

Services provided by cloud computing are as follows[1191]:

1. Infrastructure-as-a-service (laaS): It is like Amazon Web Services rhac provide virtual servers with unique JP addresses and blocks of storage on demand. Customers benefit from an Application Programmable Interface (AP!) from which they can concrol their servers. As customers can pay for exactly the amount of service they use, like for deccricity or water, this service is also called utility computing.
2. Platform-as-a-service (PaaS): It is a set of software and development cools hosted on rhe provider's servers. Developers can create applications using the provider's AP!s. Google Apps is one of the mosr famous PaaS providers. Developers should rake notice that there are not any inreropcrabilicy stan- dards; therefore, some providers may not allow you co cake your application and pur it on another platform.
3. Software-as-a-service (SaaS): Jr is the broadest market. In chis case, the provider allows the customer only ro use its applications. The sofrware interacts with the user through a user interface. These applications can be anything from Web-based E-Mail to applications such as Twitter or Lasc.fm.

2.8.3 Cybercrime and Cloud Comput;ng

Nowadays, prime area of the risk in cloud computing is protection of user data. See Table 2.5 ro understand major areas of concerns in cloud computing domain.

Table 2.5 Risks associated with cloud computing environment

Sr. No.	Area	What is the Risk?	How to Remediate the Risk?
I.	Elevated user acccs	Any data processed outside the urganiz.1Lion brings with ic an inherent level of risk, as outsourced services may bypass rhc physical, logical, and personnel controls and will have elevaccd user access rosuch daca.	Customer should obtain as much i11focmation as he/she can about the service provider who will be managing the data and scrutinizing vendor's monimring mech:mism about hiring and oversight of privileged adminisrmors, and IT controls over the access privileges.
2.	Regulatory compliance	Cloud computing service providers are noc able and/or nor willing to undergo external a..-.scssmcnts. This can resulc into non-compliance with various standards/ laws like che US govemmenr's Health Insurance Porrability and Accouncabiliry Act (HfPAA), or Sarbanes-Oxley; the European Union's Dara Procecrion Directive or the credit card indusny's Payment Card lndusrry Data Security Standard (PCI DSS).	11,e organization is cnrircly responsible for the security and integrity of their own data, even when ir i. held by a service provider. Hence, organization should force cloud computing service providers ro undergo external audics and/or securicycerrificarions and submit the report on pe.riodic basis.
3.	Location of 1·he data	The organizations chat are obtaining cloud computing services may not be aware aboucwhere the dara is hosted and may noc even know in which country ic is hosted.	Organizations should ensure thar rhe service provider is commiucd ro obey local privacy requirements on behalf of rhe organization to store and process the data in the specific jurisdicrions.
4.	Segregation of daca	As chc daca will be scored under scored environment, encryption mechanism should be srrong enough coscg.rcgate the data from 0th.er organizations, whose dara are also Stored wider che same server.	Organi7.ation should **be aware** of the arrangements made by the service provider aboucsegregation of the data. In case of encryption mechanism,"'the service provider should display encryption schemes and testing of the mechanism by the experts.
	Recovery of rhe data	Business continuity in case of ,any disascer - availability of the services and data without any disruption. Application environment and IT infrastruaure across multiple sites are vulnerable to a total failure.	Organization should ensure the enforcement of contraccual Habili.ty over the service provider about complete restoration of data within sripularcd timeframe. Organization should also be aware of Business Continuity Plan/Di.saner Recovery Plan (BCP/DRP) established by the service provider.
6.	Information security violation reportS	Due ro complex. JT environment and several customers logging in and logging out of the hoses, it becomes djfficult ro rrace inappropriate and/or illegal activity.	Organization should enforce the conuaccual liability coward providing security violation log_ at frequent intervals.
7.	Long-renn viability	In case ofany major change in the cloud computing scrvict provider (e.g., acquisition and merger, panncrship breakage), the service provided is at the srakc.	Organiution should ensure gening their data in ase of such major events.

Sourre: bccp://www.lnfoworld.com/d/securicy-central/garmcr•sevcn•cloud-compuring-security•risks-853 (9 Ocrobcr 2009).

The risk areas identified in Table 2.5 are considered to be key obstacles ro adoption of cloud computing and making it an area of active research across the globe.

SUMMARY

In this chapter we have discussed how technology is used in a different way for conducting illegal activities againsr a person, property, and/or organizations including governments. Considerable amount of rime is spent in gathering information about a rarget. Therefore. one should have adequate knowledge about the technology to use, the different tools and techniques. Public networks and cybercafes are used to hide the ID for infor- mation gathering as well as launching attacks and hence it becomes important to take utmost care while operating/surfing through such facilities. People are che weakest link in che security domain and, hence, they gee either exploited/deceived to obtain the required information; chus, this is called social engineering. Cyberstalking is another way through which criminals interact with vic- tims directly, avoiding face-to-face conversa- tion. Criminals do this either for harassing and/ or threatening behavior or to get the information from the victim. The Internet has become an inte- gral part of the lifestyle nowadays and IT is found to be pervasive - the result is cloud computing; however, we should also be aware of threats induc- ing from such technologies like Bocnecs and attack vectors. Every technology has some limitations and attackers having good amoum of knowledge will always cry co exploit it.

REVIEW QUESTIONS

I. How are cybercrimes classified? Explain with example .
2. Explain the difference between passive and active attacks. Provide examples.
3. What is social engineering?
4. What is cyberstalking? As per your understanding is it a crime under the Indian IT Act?
5. Explain how Botnets can be used as a fuel to cybercri me.
6. What are the different attacks launched wirh attack vector. Explain.
7. Explain cloud computing and cybercrime.

REFERENCES

[I] To know more on patriot hacking, visk http:// en.wikipedia.org/wiki/Pauiot_hacking(25 June 2009).

[2] To know more on port scanner, visit: http:// en.wikipedia.org/wiki/Porc_scanner (I 0 February 2010).

[3] To know more on cyberstalking, visit: http:// en.wikipedia.org/wiki/Cyberscalking (2 April 2099).

[41 To know more on cyberbullying, visit: http:// en.wikipedia.org/wiki/Cyber-bullying (2 April 2009).

[5] To know more on cyberstalking, visit: http:// cyberlaws.net/cyberindia/2CYBER27.hem (2 April 2009).

[6] To know more on cybercafe, visit: http://www. business-stand rd.com/india/ news/cyber-cafe-audience-captive-power/35I936/ (25June 2009).

[7] To know more on cybercafe, visit: http://www. merinews.com/catFull.jsp?arciclefD:::J 55371 (25 June 2009).

[8] To know more on cybercafe, visit: http://punekar. in/sire/2009/02/04/ciry-cyber-cafes-inscall-deep-freeze-software-for-securiry/ (27June 2009).

[9] To know more on cybercafe, visit: hccp://www.icicibank.com/pfsuser/cemp/cybersec.htm (27 June 2009).

[10) To know more on cybercafe, visit: http://www.icicibank.com/ptsuser/webnews/vircualkey-boad.btm (27 June 2009).

(11) To know more on Bomet, visit: http://en.wikipedia.org/wiki/Botnet (19 March 2009).

[12] To know more on Bomer, visit: http://www.ftc.gov/bcp/edu/pubs/consumer/alerts/ale132.shtm (30 March 2009).

[13] To know more on Bornet, visit: hnp://www.viruslist.com/en/analysis?pubid=204792068 (30 March 2009).

[14) To know more on arrack vector, visit: hrrp://searchsecuJ·iry.rech target.com/diccionary/definition/I 005812/anack-vecror.hcml# (17 July 2009).

[15] To know more on attack vector, visir: hrrp://searchsecuriry.tech ta rget.com/sOefinirion/0,,sid14_gci214475,00.hcml (17July 2009).

[16] To know more on arrack vecror, visir: hrcp://www.nec-security.org/article.php?id=949 (17 July 2009).

(17] To know more on zero-day arrack, visit: hrcp://en.wikipedia.org/wiki/Zero_day_arrack (9 Ocrober 2009).

[18] To know more on attack vector, visir: hctp://cybercoyore.org/securiry/vecrors.shcml (17 July 2009).

[19] To know more on cloud computing, visic: http://cn.wi ki ped ia .org/ wiki/ Cloud_computing (9 Ocrober 2009).

[20] To know more on cloud computing, visit: hnp://com municarion.howsruffworks.com/cloud-compuring2.htm (9 October 2009).

FURTHER READING

Books

1. Godbole, N. (2009) *lnfannation Systems Secttrity: Semrity Management, Metrics, Frameworks and Best Practices,* Wiley lndia, New Delhi.
2. Graves, K. (2007) *CEH - Official Certified Ethical Hacker Review Guide,* Wiley Publishing Inc., IN, USA.
3. Milhorn, H.T. (2007) *Cybercrime: How to Avoi.d Becoming a Victim,* UniversaJ Publishers, USA.

The appendices that serve as eJCtended materi al for rhe topic addressed in this chapcer are: A, B, C, D, E, F, J, L.'lbese are provided in the companion CD.

Unit III

CYBERCRIMES: MOBILE AND WIRELESS DEVICES

INTRODUCTION. Why should *mobile devices* be protected? Every day, *mobile devices* are lost, stolen, and infected. *Mobile devices* can store important business and personal *information*, and are often be used to access University systems, email, banking

Proliferation of mobile and wireless devices:

- people hunched over their smartphones or tablets in cafes, airports, supermarkets andeven at bus stops, seemingly oblivious to anything or anyone around them.
- They play games, download email, go shopping or check their bank balances on thego.

They might even access corporate networks and pull up a document or two on their mobile gadgets

Today, incredible advances are being made for mobile devices. The trend is for smaller devices and more processing power. A few years ago, the choice was between a wireless phone and a simple PDA. Now the buyers have a choice between high-end PDAs with integrated wireless modems and small phones with wireless Web-browsing capabilities. A long list of options is available to the mobile users. A simple hand-held mobile device provides enough computing power to run small applications, play games and music, and make voice calls. A key driver for the growth of mobile technology is the rapid growth of business solutions into hand-held devices.

As the term "mobile device" includes many products. We first provide a clear distinction among the key terms: mobile computing, wireless computing and hand-held devices. Figure below helps us understand how these terms are related. Let us understand the concept of mobilecomputing and the various types of devices.

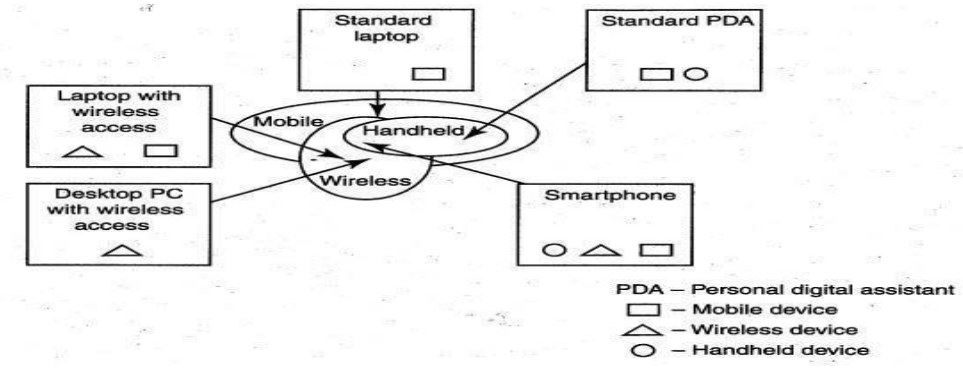


Figure : Mobile, Wireless and hand-held Devices

Mobile computing is "taking a computer and all necessary files and software out into the field." Many types of mobile computers have been introduced since 1990s. They are as follows:

1. Portable computer: It is a general-purpose computer that can be easily moved from one place to another, but cannot be used while in transit, usually because it requires some "setting-up" and an AC power source.

2. Tablet PC: It lacks a keyboard, is shaped like a slate or a paper notebook and has features of a touchscreen with a stylus and handwriting recognition software. Tablets may not be best suited for applications requiring a physical keyboard for typing, but are otherwise capable of carrying out most tasks that an ordinary laptop would be able to perform.

3. Internet tablet: It is the Internet appliance in tablet form. Unlike a Tablet PC, the Internet tablet does not have much computing power and its applications suite is limited. Also it cannot replace a general-purpose computer. The Internet tablets typically feature an MP3 and video player, a Web browser, a chat application and a picture viewer.

4. Personal digital assistant (PDA): It is a small, usually pocket-sized, computer with limited functionality. It is intended to supplement and synchronize with a desktop computer, giving access to contacts, address book, notes, E-Mail and other features.

5. Ultramobile (PC): It is a full-featured, PDA-sized computer running a general-purpose operating system (OS).

6. Smartphone: It is a PDA with an integrated cell phone functionality. Current Smartphones have a wide range of features and installable applications.

7. Carputer: It is a computing device installed in an automobile. It operates as a wireless computer, sound system, global positioning system (GPS) and DVD player. It also contains word processing software and is Bluetooth compatible.

8. Fly Fusion Pentop computer: It is a computing device with the size and shape of a pen. It functions as a writing utensil, MP3 player, language translator, digital storage device and calculator.

Trends in Mobility:

Mobile computing is moving into a new era, third generation (3G), which promises greater variety in applications and have highly improved usability as well as speedier networking. "iPhone" from Apple and Google-led "Android" phones are the best examples of this trend and there are plenty of other developments that point in this direction. This smart mobile technologyis rapidly gaining popularity and the attackers (hackers and crackers) are among its biggest fans.

It is worth noting the trends in mobile computing; this will help readers to readers to realize the seriousness of cybersecurity issues in the mobile computing domain. Figure below shows the different types of mobility and their implications.

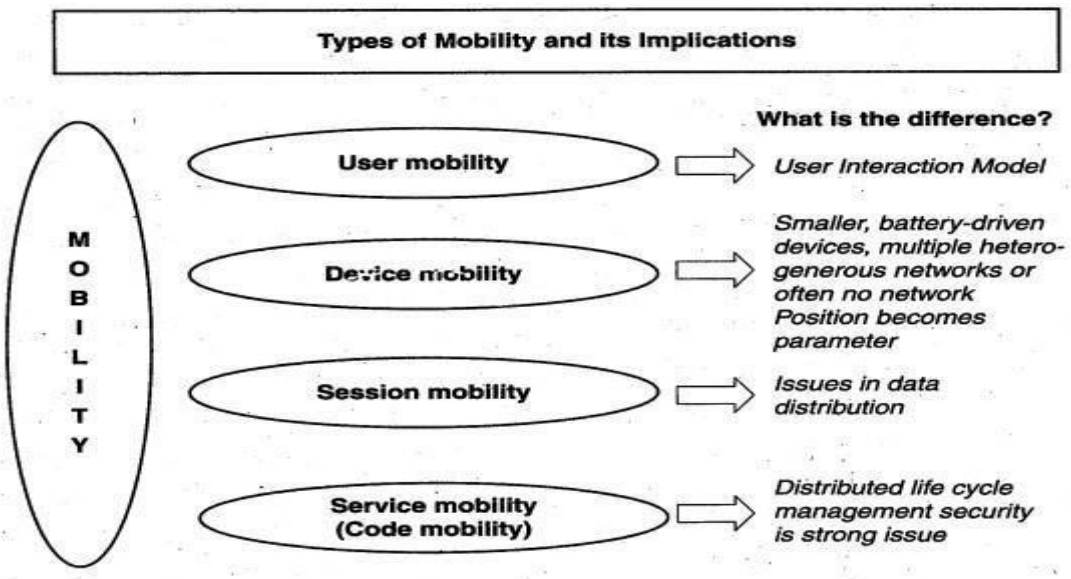


Figure: Mobility types and implications

The new technology 3G networks are not entirely built with IP data security. Moreover, IP data world when compared to voice-centric security threats is new to mobile operators. There are numerous attacks that can be committed against mobile networks and they can originate from two primary vectors. One is from outside the mobile network - that is, public Internet, private networks and other operator's networks - and the other is within the mobile networks- that is, devices such as data-capable handsets and Smartphones, notebook computers or even desktopcomputers connected to the 3G network.

Popular types of attacks against 3G mobile networks are as follows:

1. Malwares, viruses and worms: Although many users are still in the transient process of switching from 2G,2.5G2G,2.5G to 3G,3G, it is a growing need to educate the community people and provide awareness of such threats that exist while using mobile devices. Here are few examples of malware(s) specific to mobile devices:

- ***Skull Trojan:*** I targets Series 60 phones equipped with the Symbian mobile OS.
- ***Cabir Worm:*** It is the first dedicated mobile-phone worm infects phones running on Symbian OS and scans other mobile devices to send a copy of itself to the first vulnerable phone it finds through Bluetooth Wireless technology. The worst thing aboutthis worm is that the source code for the Cabir-H and Cabir-I viruses isavailable online.
- ***Mosquito Trojan:*** It affects the Series 60 Smartphones and is a cracked version of "Mosquitos" mobile phone game.
- ***Brador Trojan:*** It affects the Windows CE OS by creating a svchost. exe file in the Windows start-up folder which allows full control of the device. This executable file is conductive to traditional worm propagation vector such as E-Mail file attachments.
- ***Lasco Worm:*** It was released first in 2005 to target PDAs and mobile phones running the Symbian OS. Lasco is based on Cabir's source code and replicates over Bluetooth connection.

2. Denial-of-service (DoS): The main objective behind this attack is to make the system unavailable to the intended users. Virus attacks can be used to damage the system to make thesystem unavailable. Presently, one of the most common cyber security threats to wired Internetservice providers (iSPs) is a distributed denial-of-service (DDos) attack .DDoS

attacks are used to flood the target system with the data so that the response from the target system is either slowed or stopped.

3. Overbilling attack: Overbilling involves an attacker hijacking a subscriber's IP address and then using it (i.e., the connection) to initiate downloads that are not "Free downloads" or simplyuse it for his/her own purposes. In either case, the legitimate user is charged for the activity which the user did not conduct or authorize to conduct.

4. Spoofed policy development process (PDP): These of attacks exploit the vulnerabilities in the GTP [General Packet Radio Service (GPRS) Tunneling Protocol].

5. Signaling-level attacks: The Session Initiation Protocol (SIP) is a signaling protocol used in IP multimedia subsystem (IMS) networks to provide Voice Over Internet Protocol (VoIP) services. There are several vulnerabilities with SIP-based VolP systems.

Credit Card Frauds in Mobile and Wireless Computing Era:

These are new trends in cybercrime that are coming up with mobile computing - mobile commerce (M-Commerce) and mobile banking (M-Banking). Credit card frauds are now becoming commonplace given the ever-increasing power and the ever-reducing prices of the mobile hand-held devices, factors that result in easy availability of these gadgets to almost anyone. Today belongs to "mobile compüting," that is, anywhere anytime computing. The developments in wireless technology have fuelled this new mode of working for white collar workers. This is true for credit card processing too; wireless credit card processing is a relatively new service that will allow a person to process credit cards electronically, virtually anywhere. Wireless credit card processing is a very desirable system, because it allows businesses to process transactions from mobile locations quickly, efficiently and professionally. It is most often used by businesses that operate mainly in a mobile environment

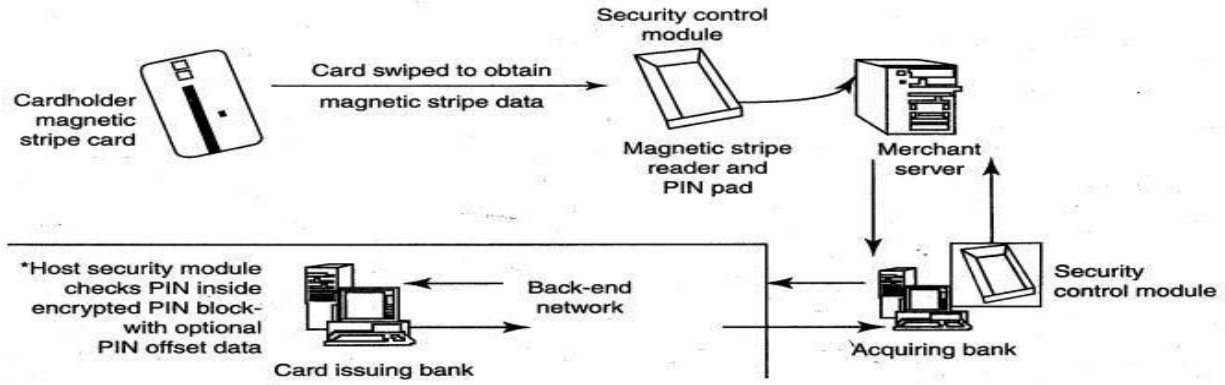


Figure : Online environment for credit card transactions

There is a system available from an Australian company "Alacrity" called closed-loop environment for for wireless (CLEW). Figure above shows the flow of events with CLEW which is a registered trademark of Alacrity used here only to demonstrate the flow in this environment.

As shown in Figure, the basic flow is as follows:

1. Merchant sends a transaction to bank
2. The bank transmits the request to the authorized cardholder
3. The cardholder approves or rejects (password protected)

4. The bank/merchant is notified
5. The credit card transaction is completed.

Security Challenges Posed by Mobile Devices:

Mobility brings two main challenges to cybersecurity: first, on the hand-held devices, information is being taken outside the physically controlled environment and second remote access back to the protected environment is being granted. Perceptions of the organizations to these cybersecurity challenges are important in devising appropriate security operating procedure. When people are asked about important in managing a diverse range of mobile devices, they seem to be thinking of the ones shown in below figure. As the number of mobile device users increases, two challenges are presented: one at the devicelevel called "micro challenges" and another at the organizational level called "macro- challenges."

Some well-known technical challenges in mobile security are: managing the registry settings and configurations, authentication service security, cryptography security, Lightweight Directory Access Protocol (LDAP) security, remote access server (RAS) security, media player control security, networking application program interface (API), security etc.

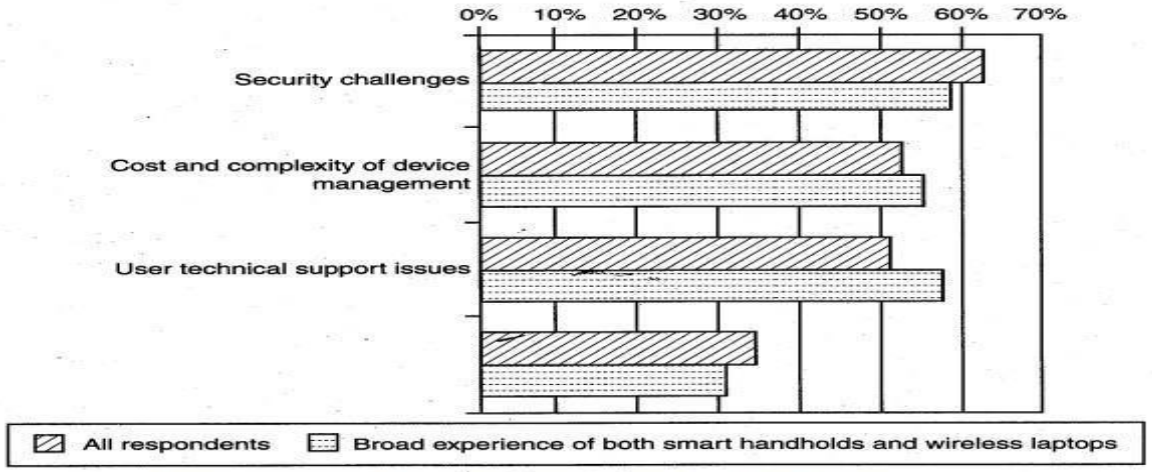


Figure: Important issues for managing mobile devices

Registry Settings for Mobile Devices:

Let us understand the issue of registry settings on mobile devices through an example: Microsoft Activesync is meant for synchronization with Windows-powered personal computers (PCs) and Microsoft Outlook. ActiveSync acts as the "gateway between Windows-powered PC and Windows mobile-powered device, enabling the transfer of applications such as Outlook information, Microsoft Office documents, pictures, music, videos and applicationsfrom a user's desktop to his/her device.

In addition to synchronizing with a PC, ActiveSync can synchronize directly with the Microsoft exchange server so that the users can keep their E-Mails, calendar, notes and contacts updated wirelessly when they are away from their PCs. In this context, registry setting becomes an important issue given the ease with which various applications allow a free flow of information.

Authentication Service Security:

There are two components of security in mobile computing: security of devices and security in networks. A secure network access involves authentication between the device and the

basestations or Web servers. This is to ensure that only authenticated devices can be connected to the network for obtaining the requested services. No Malicious Code can impersonate the service provider to trick the device into doing something it does not mean to. Thus, the networks also play a crucial role in security of mobile devices.
Some eminent kinds of attacks to which mobile devices are subjected to are: push attacks, pullattacks and crash attacks.
Authentication services security is important given the typical attacks on mobile devices through wireless networks: Dos attacks, traffic analysis, eavesdropping, man-in-the-middle attacks and session hijacking. Security measures in this scenario come from Wireless Application Protocols (WAPs), use of VPNs, media access control (MAC) address filtering and development in 802.xx standards.

Attacks on Mobile-Cell Phones:

- **Mobile Phone Theft:**

Mobile phones have become an integral part of everbody's life and the mobile phone has transformed from being a luxury to a bare necessity. Increase in the purchasing power and availability of numerous low cost handsets have also lead to an increase in mobile phone users. Theft of mobile phones has risen dramatically over the past few years. Since huge section of working population in India use public transport, major locations where theft occurs are bus stops, railway stations and traffic signals.
The following factors contribute for outbreaks on mobile devices:

1. **Enough target terminals:** The first Palm OS virus was seen after the number of Palm OS devices reached 15 million. The first instance of a mobile virus was observed during June 2004 when it was discovered that an organization "Ojam" had engineered an antipiracy Trojan virus in older versions of their mobile phone game known as Mosquito. This virus sent SMS text messages to the organization without the users' knowledge.

2. **Enough functionality:** Mobile devices are increasingly being equipped with office functionality and already carry critical data and applications, which are often protected insufficiently or not at all. The expanded functionality also increases the probability of malware.

3. **Enough connectivity:** Smartphones offer multiple communication options, such as SMS, MMS, synchronization, Bluetooth, infrared (IR) and WLAN connections. Therefore, unfortunately, the increased amount of freedom also offers more choices for virus writers.

- **Mobile - Viruses**
- **Concept of Mishing**
- **Concept of Vishing**
- **Concept of Smishing**
- **Hacking - Bluetooth**

Organizational security Policies and Measures in Mobile Computing Era:
Proliferation of hand-held devices used makes the cybersecurity issue graver than what we would tend to think. People have grown so used to their hand-helds they are treating them like wallets! For example, people are storing more types of confidential information on mobile

computing devices than their employers or they themselves know; they listen to musicusing their-hand-held devices.One should think about not to keep credit card and bank account numbers, passwords, confidential E-Mails and strategic information about organization, merger or takeover plans and also other valuable information that could impact stock values in the mobile devices. Imagine the business impact if an employee's USB, pluggable drive or laptop was lost or stolen, revealing sensitive customer data such as credit reports, social security numbers (SSNs) and contact information.

Operating Guidelines for Implementing Mobile Device Security Policies

In situations such as those described above, the ideal solution would be to prohibit all confidential data from being stored on mobile devices, but this may not always be practical. Organizations can, however, reduce the risk that confidential information will be accessed fromlost or stolen mobile devices through the following steps:

1. Determine whether the employees in the organization need to use mobile computing devices at all, based on their risks and benefits within the organization, industry and regulatory environment.
2. Implement additional security technologies, as appropriate to fit both the organization and the types of devices used. Most (and perhaps all) mobile computing devices will need to have their native security augmented with such tools as strong encryption, device passwords and physical locks. Biometrics techniques can be used for authentication and encryption and have great potential to eliminate the challenges associated with passwords.
3. Standardize the mobile computing devices and the associated security tools being used with them. As a matter of fundamental principle, security deteriorates quickly as the tools and devices used become increasingly disparate.
4. Develop a specific framework for using mobile computing devices, including guidelines for data syncing, the use of firewalls and anti-malware software and the typesof information that can be stored on them.
5. Centralize management of your mobile computing devices. Maintain an inventory so that you know who is using what kinds of devices.,
6. Establish patching procedures for software on mobile devices. This can often be simplified by integrating patching with syncing or patch management with the centralized
7. Provide education and awareness training to personnel using mobile devices. People cannot be expected to appropriately secure their information if they have not been toldhow.

Organizational Policies for the Use of Mobile Hand-Held Devices

There are many ways to handle the matter of creating policy for mobile devices. One way is creating distinct mobile computing policy. Another way is including such devices existing policy. There are also approaches in between where mobile devices fall under both existing policies and a new one.In the hybrid approach, a new policy is created to address the specific needs of the mobile devices but more general usage issues fall under general IT policies. As a part of this approach, the "acceptable use" policy for other technologies is extended to the mobile devices.

Companies new to mobile devices may adopt an umbrella mobile policy but they find over time the the they will need to modify their policies to match the challenges posed by differentkinds of mobile hand-held devices. For example, wireless devices pose different challenges than non-wireless Also, employees who use mobile devices more than 20%% of

the time will have different requirements than less-frequent users. It may happen that over time, companiesmay need to create separate policies for the mobile devices on the basis of whether they connect wirelessly and with distinctions for devices that connect to WANs and LANs .

Concept of Laptops:

As the price of computing technology is steadily decreasing, usage of devices such as the laptops is becoming more common. Although laptops, like other mobile devices, enhance the business functions owing to their mobile access to information anytime and anywhere, they also pose a large threat as they are portable Wireless capability in these devices has also raisedcyber security concerns owing to the information being transmitted over other, which makes ithard to detect.

The thefts of laptops have always been a major issue, according to the cybersecurity industry and insurance company statistics. Cybercriminals are targeting laptops that are expensive, to enable them to fetch a quick profit in the black market. Very few laptop. thieves. are actually interested in the information that is contained in the laptop. Most laptops contain personal andcorporate information that could be sensitive..

Physical Security Countermeasures

Organizations are heavily dependent upon a mobile workforce with access to information, no matter where they travel. However, this mobility is putting organizations at risk of having a data breach if a laptop containing sensitive information is lost or stolen. Hence, physical security countermeasures are becoming very vital to protect the information on the employeeslaptops and to reduce the likelihood that employees will lose laptops.

1. Cables and hardwired locks: The most cost-efficient and ideal solution to safeguard any mobile device is securing with cables and locks, specially designed for laptops. Kensington cables are one of the most popular brands in laptop security cable. These cables are made of aircraft-grade steel and Kevlar brand fiber, thus making these cables 40%% stronger than any other conventional security cables. One end of the security cable is fit into the universal securityslot of the laptop and the other end is locked around any fixed furniture or item, thus making aloop. These cables come with a variety of options such as number locks, key locks and alarms.

2. Laptop safes: Safes made of polycarbonate - the same material that is used in bulletproof windows, police riot shields and bank security screens-can be used to carry and safeguard the laptops. The advantage of safes over security cables is that they protect the whole laptop and its devices such as CD-ROM bays, PCMCIA cards and HDD bays which can be easily removedin the case of laptops protected by security cables.

3. Motion sensors and alarms: Even though alarms and motion sensors are annoying owing to their false alarms and loud sound level, these devices are very efficient in securing laptops. Once these devices are activated, they can be used to track missing laptops in crowded places. Also owing to their loud nature, they help in deterring thieves. Modern systems for laptops aredesigned wherein the alarm device attached to the laptop transmits radio signals toa certain range around the laptop.

4. Warning labels and stamps: Warning labels containing tracking information and identification details can be fixed onto the laptop to deter aspiring thieves. These labels cannotbe removed easily and are a low-cost solution to a laptop theft. These labels have an identification number that is stored in a universal database for verification, which, in turn

makes the resale of stolen laptops a difficult process. Such labels are highly recommended forthe laptops issued to top executives and/or key employees of the organizations.

5. Other measures for protecting laptops are as follows:

- Engraving the laptop with personal details
- Keeping the laptop close to oneself wherever possible
- Carrying the laptop in a different and unobvious bag making it unobvious to potential thieves
- Creating the awareness among the employees to understand the responsibility of carrying a laptop and also about the sensitivity of the information contained in the laptop
- Making a copy of the purchase receipt, laptop serial number and the description of thelaptop
- Installing encryption software to protect information stored on the laptop
- Using personal firewall software to block unwanted access and intrusion
- Updating the antivirus software regularly
- Tight office security using security guards and securing the laptop by locking it down in lockers when not in use
- Never leaving the laptop unattended in public places such as the car, parking lot,conventions, conferences and the airport until it is fitted with an anti theft device;
- Disabling IR ports and wireless cards and removing PCMCIA cards when not in use.

Information systems security also contains logical access controls. This is because, information, be it corporate or private, needs high security as it is the most important asset ofan organization or an individual. A few logical or access controls are as follows:

1. Protecting from malicious programs/attackers/social engineering.
2. Avoiding weak passwords/ access.
3. Monitoring application security and scanning for vulnerabilities.
4. Ensuring that unencrypted data/unprotected file systems do not pose threats.
5. Proper handing of removable drives/storage mediums /unnecessary ports.
6. Password protection through appropriate passwords rules and use of strongpasswords.
7. Locking down unwanted ports/devices.
8. Regularly installing security patches and updates.
9. Installing antivirus software/firewalls / intrusion detection system (IDSs).
10. Encrypting critical file systems.

4 Tools and Methods Used in Cybercrime

Learning Objectives

After reading this chapter, you will be able to:

- Understand about proxy servers andanonymizers.
- Learn about password cracking.
- Learn what keyloggers and Spywares do.
- Ger an overview of virus and worms.
- Learn about Trojan Horses and backdoors.
- Understand what sceganography is.
- Learn about DoS and DDoS attacks.
- Learn about SQL injection.
- Understand buffer overflow.
- Gee an overview of wireless necwork hacking.

4.1 Introduction

In Chapter 2, we have learnt about how criminals/arrackers plan c.,-yberoffenses against an individual and/or against an organization. fn Chapter 3, we have learnt how mobile technology plays an important role to launch cyberarracks. With this background, in chis chapter, we will focus upon different forms of acracks through which attackers target the computer systems. There are various tools and techniques (see Box 4.1) and complex methodologies used ro launch arcacks against the carger. Although discussing all of them is virtually impossible in a single chapter, yet still, we have provided an insight coward these techniques co enable the reader co understand how the computer is an indispensable tool for almost all cybercrimes. *As* the Internet and computer necworks are integral pares of information systems, arrackers have in-depth knowledge about the technology and/or they gain thorough knowledge about it. (See Section 10.4.2, Chapter 10 in CD.)

Nerwork attack incidents reveal that arcackers are often very systematic in launching their attacks (see Section 7.13, Chapter 7). The basic stages of an attack are described here co understand how an attacker can compromise a network here:

1. **Initial uncovering:** We have explained this in Chapter 2. Two steps are involved here. Ln the firsr step calJed as *reconnaissance*, the arcacker gathers information, as much as possible, about the target by legitimate means - searching the information about the target on the Jnternet by Googling social networking websites and people finder websites. The information can also be gathered by surfing the public websites/searchjng news articles/press releases if the target is an organization/institute. In the second step, the attacker uncovers as much informariou as possible on the company's internal n,.rwork, such as, Internet domain, machine names and the company's Internee- Protocol (IP) address ranges. From prevention perspective, at chis stage, it is really not possible to detect the accackers because they have done nothing illegal as yei and so their information requests are considered legitimate.

Box 4.1 Scareware, Malvertising, Clickjacking and Ransomware

1. **Scareware:** It comprises several classes of scorn software with malicious payloads (explained in chapter I), or of limited or no benefit. which ore sold to consumers via certainunethical marketing practices. The selling approach uses social engineering to cause shock, anxiety or the perception or o threat, generally directed at on unsuspecting user. Some forms of Spywore and Adwore also use scarewore tactics. Some websites display pop-up advertisement windows or banners with text such as: "Your computer may be infected with harmful Spywore programs. Immediate removal may be required. To scan, click 'Yes' below." These websites con go as for as saying that o user's job, career or marriage would be al risk. Webpoges displaying such advertisements for such prod• ucts ore often considered as scorewore. Serious scorewore applications qualify asrogue software.
2. **MalvertIslng:** It is o malicious advertising - molwore +advertising - on online criminal methodology that appears focused on the installation of unwonted or outright malicious software through the use of Internet advertising media networks, exchanges and other user-supplied content publishing services common to the social networking space. Cybercriminols attempt to distribute molwore through advertising. Possible vectors of attack include Malicious Code hidden within on advertisement, embedded into a webpoge or within software which is available for download.
3. **CIlckjackIng:** II is a malicious technique of tricking netizens into revealing confidential information and/or toking control of their system while clicking on seemingly innocuouswebpoges.Clickjacking tokes the form of embedded code and/or script which is executed without netizen·s knowledge Cybercriminots toke the advantage of vulnerability across o variety of browsers and ptotforms to launch this type of aHock. for example clicking on a button that appeors to perform another function. The term "clickjocking" was coined by Jeremiah Grossman and Robert Honsen in 2008. The exploit is also known as User-Interface (UI) redressing.
4. **Ransomware:** II is computer motwore that holds o computer system. or the data ii contains. hostage against its user by demanding o ransom for its restoration. II lypicolly propagates as a conventional computer worm, entering o system through, for example, vulnerability in a network service or an E-Mail attachment. II may then
   - disable an essential system service or tock the display al system start-up and
   - encrypt some of the user's personal files.

   In both cases, the malwore may extort by
   - prompting the user to enter o code obtainable only ofter wiring payment to the attacker or sending an SMS message and accruing o charge;
   - urging the user to huy a decryption or removal tool.

Sources: http://en.wik1pedia.org/wiki/Scoreware (10 Jonuory lO): http://www.anti-malvertising.com/ [10 Januory 10); http://en.wikipedia.org/wiki/Cllckjocking (10 February I 0): hl1p;//en.wikipedio.org/wild/Ronsornware_(molwo1e) (10 January 10)

2. **Network probe:** Ar the network probe scage, the accackcr uses more invasive techniq11 s ro scan the information. Usually, a "ping sweep" of the network IP addresses is performed co seek out potencial cargea;, and then a "pon scanning" tool (see Table 2.2) is used co discover exactly which services are running on the target system. Ar this point, the arcacker has still not done anything char would be considered as an abnormal activicy on Lhe ncrwork or anything rhar can be classified as an intrusion.
3. Crossing the line toward electronic crime (frcrime): Now the attacker is coward cor.imicring whar is technically a "computer crime." He/she does chis by exploiting possible holes on the target system. The anacker usually goes through several stages of exploics co gain access co t.he system. Cerra.in programming errors can be used by arrackers co compromise a sysrem and are quite common in practice (see1able 4.1 for lisr of website... commonly browsed by attackers co obtain rhe information on che vulnerabilities). Exploits usually include vulnerabilities in common gateway inrcrfuce (CCI) scripts or well-known bufter-overflow holes, but the easiest way co gain an emry is by checking for dcfuulr login accouncs with easily guessable (or empcy) passwords. Once the attackers are able to access a user accoum without many privi-leges, they will attempt further exploits to ger an adminismuor or "root" access. RoOl access *is* a Unix rerm

Table 4.1 Websites and tools used to find the common vulnerabilities

Website	Brief Description
http://www.us-cert.gov/	US-CERT is the operational arm of the National Cyber Security Division (NCSD) at the Department of Homeland Security (OHS). US-CERT also provides a way for ciri1.ens, businesses and other insrirurions to communicate and coordinate directly with the US government about cybersecurity. US-CERT publishes information about a variety of vulnc:rabiliries under "US-CERT Vulnerabilities Notes."
http://eve.micre.org/	Common Vulnerabilities and Exposures (CVE) is a dictionary of publicly known information security vulnerabilities and exposures and free for public use. *CVE's* common Identifiers enable dara exchange between security produces and provide a baseline index point for evaluating coverage of tools and services.
http://secunia.com/	It has thousands of vulnerability lists char are updated periodic.illy. le has vulnerability database and provides in-depth analysis about virus, worm alerts and sofrware vulnerability.
hrep://www.hackcmorm.com/	This website was created for open-source vulnerability database (OSVBD) rool. Since then it has grown in popularity and provides additional information about penetration resting. The sire is updated with whole bunch of news and alercs about vulnerability research.
http://www.hackerwatch.org/	le is an online community where lnrernet users can report and share information to block and identify security threats and unwanted traffic.
http://www.wne-h.org/	It reporcs on recent web attacks and cybercrimcs and lisu them on the website. One can view numerous defaced webpages and derails about them.
hrrp://www.milworm.com/	le *contains* day-wise information about exploirs.
htrp://www.osvdb.org/	OSVDB: This is an open-source vulnerability database providing a large quantity of rechnical information and resources about thousands of vulnerabilities.
hrrp://www.metasploit.com/	Metasploir *is* an open-source computer security project chat provides information about security vulnerabilities and aids in penerration resting. Its most well-known subproject is the Metasploir Framework, a tool for developing and executing exploit code against a remote rarget machine. The Metasploir Project is also well-known for antiforensic and evasion rools, some of which are built inro the Metasploit Framework.
http://www.wOOwOO.org/files/LibExploit	LibExploir is a generic exploit creation library. Ir helps cybersecurity community when writing exploits ro **rest** vulnerability.
http://www.immunitysec.com/products-canvas.shrml	Canvas is a commercial vulnerability exploitation tool from Dave Aitd's lmmunitySec. le includes more than 150 exploir and also available are Visua!Sploir Plugio for drag and drop CUI exploit creation (optional).
http://www.coresecurity.com/concent/core-impact-overview	Core Impact is widely considered to be che most powerful exploitation rool available. It spores a large, regularly updated database of professional exploics. and can do neat tricks such as exploiting one system and then establishing an encrypted tunnel through that system ro rt"ach and exploit ocher systems.

and *is* associated with rhe sysrem privileges required lo run all services and access all files on the sys1em (readers are expected to have a basic fumiliaricy with Unix-based systems). "Roor" is basically an administrator or super-user access and grants them the privileges to do anything on thesystem.

4. Capturing che network: Ar chis stage, the attacker attempts to "own" the nelwork. The auacker gains a foothold in rhe internal network quickly and easily, by compromising low-priority target systems. The next step is co remove any evidence of the an:ack. "llie anacker will u. ually install a set of cools chat replace existing files and services with Trojan files (*Trojan **Hurse**is* fonJ1er discussed in derail in chis chapter) and service..-. char have a backdoor password. There are a number of"hacking mols" which can clean up log fib an<l remove any crace of an inuusion; most of Lhe time, they a.re individual programs wrirren by backers. Such cools provide copies of sysrem files chat look and ace like real thing, bul in fucr they provide the a1rackcr a backdoor entry into che system and bide proce..'iSe.s he/she mighr be running on char system and his/her user information. 1bis allows the attacker to return ro rhe system at will, which means char the arracker has "captured" the network. Once the attacker has gained ac ro one system, he/she will then repeat the process by using the system as a stepping stone co access ocher ryscems deeper wiLhin Lhe network, as mosc networks have fewer defen against anacks from inccmal sources.
5. **Grab** the data: Now that the attacker has "captured the network," he/she cakes ad vanrage of his/her position co sreal confidential data, customer credit card information, deface webpages, alter processes and even launch arracks ar other sites from your network, causing a potentially expensive and embarrassing siruation for an individual and/or for an organization.
6. Covering cracks: This is rhe lase seep in any cyberacrack, which refers co the accivities undertaken by the attacker to extend misuse of the system without being detected. 1he attacker can remain underecled for long periods or use this phase either to scarr a fresh reconnaissance lo a related target system or continued use of resources, removing evidence of hacking, avoiding legal action, ecc. (See lable 4.210 know cools used co cover crack. .)

During chi enrire process, the anacker takes optimum care to bide bis/her identity (ID) from the first step itself. How is it possible is described in the nexr section.

Table 4.2 | Tools used to cover tracks

r. No.	Website	Brief Description
	bnp://www.ibr.ku.dk/jesper/ EL.Save/	**ELSave: Ir** is a cool to save and/or dear an NT evenr log. El.Save is wrirten by Jesper Lauritsen. 111c executable is available on the weblink, but source code is nor available.
2	http://ncsccuriry.nu/ roolbox/winzapper/	WinZapper: This roof enables co erase event records selectively from rhe security log in Windows NT 4.0 and Windows 2000. This program corruprs rhe event logs, therefore, they musr be cleared complerely.
.3	http://www.cvidence-eliminator.com/	Evidence eliminator. le is simple and one of the rop-qualiry professional PC cleaning program char *is* capable of defeating aU known invesrigalivc Forensic Software. Evidence eliminator permanently wipes out evidence *so* chat forensic analysis becomes impossible.
	hnp://www.traceless.com/ compurer-forcnsics/	Tracele. s: It is a privacy cleaner for Internet explorer (lE) thac can delete common Internet tracks, including hislory, cache, q•ped URLs, cookies, etc.

(Continued)

Table 4.2 *(Continued)*

Sr. No.	Website	Brief Description
5	http://www.acesofr.net/	Tracks Eraser Pro: It de.letes following history data: • Delete address bar history of IE, Netscape, AOL, Opera. • Delete cookies oflE, Netscape, AOL, Opera. • Delete lnternet cache (temporary Internee files). • Delete fnternet history files. • Delete Internee search history. • Delete history of aucocomplete. • Delete IE plugins (selectable). • Delete index.dac file. • Delete hisrory of start menu run box. • Delete hisrory of scan menu search box. • Delete windows temp files. • Delete history of open/save dialog box. • Empty recycle bin.

4.2 Proxy Servers and Anonymizers

Proxy server is a computer on a necwork which aces as an intermediary for connections wich ocher computers on chat necwork.

The attacker first connects to a proxy server and establishes a connection with the target system through existing connection with proxy. *1his* enables an attacker to surf On the Web anonymously and/or hide the arrack. A client connects to the proxy server and requests some services (such as a file, webpage, connec-cion or ocher resource) available from a different server. 1l1e proxy server evaluates the request and provides the resource by establishing the connection to the respective server and/or requests the required service on behalf of the diem. Using a proxy server can allow an attacker to hide ID (i.e., become anonymous on the network).

A proxy server has following purposes:

1. Keep the systems behjnd the curtain (mainly for security reasons).
2. Speed up access to a resource (through "caching"). It is usually used to cache the webpages from a web server.
3. Specialized proxy servers are used to filter unwanted content such as advertisements.
4. Proxy server can be used as IP address multiplexer co enable co connect number of computers on the internet, whenever one has only one IP address (visit hrtp://www.multiproxy.org/mu1t iproxy.htm for more information).

One of the advantages of a proxy server is chat its cache memory can serve all users. If one or more websites are requested frequently, may be by different users, ic is likely to be in the proxy's cache memory, which will improve user response time. In face chere are special servers available known as *cache servers.* A proxy can also do logging.

Listed are few websites where free proxy servers can be found:

1. http://www.proxy4free.com
2. http://www.publicproxyservers.com

3. htcp://www.proxz.com
4. http://www.anonymitychecker.com
5. hrcp://www.surf14h.com
6. hrcp://www.hidemyass.com

An anonymiur or an anonymous proxy is a cool chat attempts co make activity on the Internee untraceable. le accesses the Internee on the user's behalf, protecting personal information by hiding the source compurer's identifying informacion.[1 1] Anonymizers are services used to make Web surfing anonymous by utilizing a website char aces as a proxy server for the web client. In 1997 che first anonymizer software cool was created by Lance Cottrell, developed by Anonymizer.com. The anonymiu:r hides/removes all the identifying information from a user's computer while che user surfs on che lnrernec, which ensures the privacy of the user. (See Section 9.7, Chapter 9.)

Listed are few websites where more information about anonymizers can be found:

I. hrrp://www.anonymizer.com
2. http://www.browzar.com
3. http:/ www.anonymize.net
4. http://www.anonymouse.ws
5. http://www.anonymousindex.com

Box 4.2 Be;ng Anonymous While Searching on Google!

Google Cookie

Google was the first search engine to use a cookie.'2[1]Google set the standard and nowadays cookies are commonplace among search engines. This cookie places a unique ID number on your hard disk. Anytime you visit Google, user gets a Google cookie if a user doesn't already have one. If a user has one then ii will read and record the unique ID number. Google can build a detailed list of your search terms over many years. (Google's cookies ore set to expire by the year 2038. unless a user deletes before its expiry.)

Cookie

Cookie (also know as HTTP cookie/browser cookie) is a small text file that contains a string of alphanumeric characters and is used for storing netizen's website preferences/authentication while visiting the some webpage again and again or also acts as identifier for server-based session - such browser mecl1onism of se1ting and reading cookies invites attackers to use these cookies as "Spywore." There ore two types of cookies:

1. Persistent cookie and
2. session cookie.

Persistent cookie is stored by the web browser into the cookie folder on the PC's hard disk. It remains under the cookie folder. whichismaintained by the web browser. Session cookie is a temporary cookie and does not reside on the PC once the browser is closed (see Boxes 9.2, 9.3 and 9.4, Chapter 9).

DoubleClick

It is a subsidiary of Google and provides Internet ad-serving services and paid search products listing (DART Seorch[131]) and utilize the cookies, which are called DART cookie. Internet Advertising Network was storled by Kevin O'Connor and Dwight Merriman in 1995. IAN and the DoubleClick division of Poppe.Tyson were merged into a new corporation named DoubleClick in I 996. DoubleCllck was first in the online media representative business, that is, representing websites to sell advertising space lo marketers. In 1997 ii began offering the online ad serving and management technology they had

Box 4.2 Being Anonymous ... *(Continued)*

developed to other publishers as the DART services. The DART cookie is a persistent cookie, Which consists of the name ot the domain that has set the cookie. the lifetime of the cookie and a "value." DoubleClick's DART mechanism generates a unique series of characters for the "value" portion of the cookie. These DoubleClick DART cookies help marketers learn how well their Internet advertising campaigns or paid search listings perform. Many marketers and Internet websites use DoubleClick's DART technology to deliver and serve thair advertisements or manage their paid search listings. DoubleClick'sDART products set or recognize a unique. persistent cookie when on ad is displayed or a paid listing is selected. The information that the DART cookie helps to give marketers includes the number of unique users their odvertisemen1s displayed to. how many users clicked on their Internet ads or paid listings and which ads or paid listings they clicked on.

G-Zapper

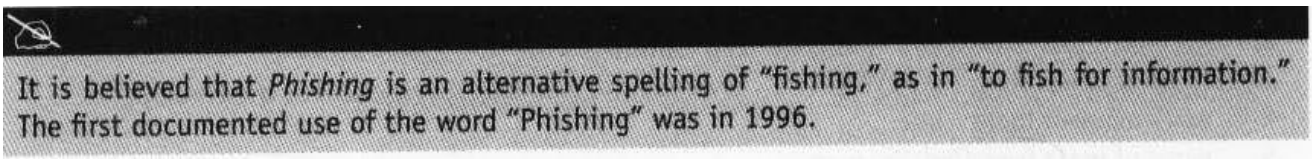
G-Zopper[141] utility helps to stay anonymous while searching Google. Google stores a unique identifier in a cookie on the computer (i.e.. on the hard disk) which allows to track keywords that are searched for. This information is used to compile reports, track user habits and test features. In the future, it would be possible that this Information is sold and/or shored with others.

G-Zopper helps to protect users' ID and search history. G-Zopper reads the Google cookie Installed on users' PC, displays the dote it was installed, determines how long user searches have been tracked and displays Google searches. G-Zapper allows user to automatically delete or entirely block the Google search cookie from future installation.

Thisutility con be downloaded from http://www.dummysoftwore.com/gzopper.html

4.3 Phishing

While checking eleccronic mail (E-Mail) one day a user finds a message from che bank chreatenlng him/her co close the bank account if he/she does not reply immediately. Although the message seems to be suspicious from the contencs of the message, ic is difficult to conclude chat it is a fake/false E-Mail. This message and ocher such messages are examples of Phishing - in addition co stealing personal and financial data - and can infect systems with viruses and also a method of online ID theft in various cases. Most people associate Phishing with E-Mail messages rhat spoof or mimic banks, credit card companies or ocher business such as Amazon and eBay. These messages look authentic and attempt to get users co reveal rheir personal information.



4.3.1 How Phishing Works?

Phishers work in the following ways[S]:

1. **Planning:** Criminals, usually called as phishers, decide the target **(i.e.,** specific business/business house/an individual) and determine how l0 get E-Mail address of that cargec or customers of chat business. Phishers often use mass mailing and address collection techniques as spammers.
2. Setup: Once phishers know which business/business house co spoof and who their victims are, rhey will create methods for delivering rl1e message and lo collect the data about the rarger. Mosr often this involves E-Mail addresses and a webpage.

3. **Attack:** 1l1is is che seep people are most familiar wich - che phisher sends a phony message chat appears co be from a reputable source.
4. ColJection: Phishers record che information of vicrims entering into webpages or pop-up windows.
S. Identity theft and fraud: Phishers use the information char they have gacl1ered to make illegal purchases or commit fraud.

Phishing started off as being part of popular hacking culture. Nowadays, more and more organizations/instiwres provide greater online access for their customers and hence criminals arc successfully using Phishing techniques 10 steal personal information and conduct ID theft at a global level. We have explained Phishing and ldemiry 1l1er1 in detail in Chapter 5.

4.4 Password Cracking

Password is like a key to gee an entry into compurerjzed systems like a lock. Password cracking is a process of recovering passwords &om data chat have been stored in or cransmined by a computer system.[161] Usually, an :macker follows a common approach - repeatedly making guesses for the password. The purpose of password cracking is as follows:

1. lo recover a forgotten password.
2. As a preventive measure bysystem administrators to check for easily crackable passwords.
3. To gain unauthorized access to a system.

Manual password cracking *is* co attempt 10 logon with different password. . The arrackcr follows the following seeps:

1. Find a valid user account such as an Adminiscraror or Guest;
2. create a list or possible passwords;
3. rank the passwords from high co low probabilicy;
4. key-in each password;
S. cry again uncil a successful password is found.

Passwords can be guessed sometimes with knowledge of the user's personal information (explained in Chapter 5). Examples of guessable passwords include:

1. Blank (none);
2. che words like "password," "passcode" and "admin";
3. series of lercers from the "QWERTY" keyboard, for example, qwerry, asdf or qwercyuiop;
4. user's name or login name;
S. name of user's friend/relative/per;
6. user's birthplace or dare of birth, or a rdacive's or a friend's;
7. user's vehicle number, office nun1ber, residence number or mobile number;
8. name of a celebrity who is considered co be an idol (e.g., actors, actress, spiriruaJ gurus) by me user;
9. simple modification of one of che preceding, such as suffixing a digit, particularly J, or reversing the order ofleners.

An arracker can also create a script file (i.e., aucomaced program) which will be executed to try each password in a lisc.'Ihis is srill considered manual cracking, is time-consuming and not usually effective.

Passwords are srored in a database and password verification process is established into rhe system when a user anemprs to login or access a restricted resource. To ensure confidencialicy of passwords, the

password veri6carion dara is usually not stored in a clear text format. For example, one-way function (which may be either an encryption function or a cryptographic hash) is applied co the p:issword, possibly in combination with other dara, and the resulting value is scored. Wl1en a user attempts ro login to rhe system by entering the password, the same funcrion is applied co rhe entered value and the result is compared with the stored value. If they march, user gains the access; this process is called *authentication.*

Even though these functions create hashed passwords, which may be crypt0graphically secure, an aLtacker attempts co gee possession of the hashed password, which will help co provide a quick way IO rest guesses for the password by applying the one-way function to each guess and comparing the result to rhe verificacion data. The most commonly used hash functions can be computed rapidly and the :macker can test these hashes with the help of passwords cracking rnols (see Table 4.3) to gee the plain rext password.

Table 4.3 Password cracking tools

Vebsite	Brief Description
www.defauhpassword.com	Default password(s): Network devices such as switches, hubs and routers are equipped with "default passwords" and usually these passwords arc not changed after commissioning dicse devices into the network (i.e., inro LAN). The intruders can gain the access using these defuulr passwords by visiting the said website.
lmp://www.oxid.ir/cain.html	Cain & Abel: This password recovery rool is rypically used for Microsoft Operaring Systems (OSs). It allows ro crack rhc passwords by sniffing lhc nerwork, cracking encrypted passwords using dictionary, hruce force anacks, decoding scrambled passwords and recovering wireless nerwork keys.
lmp://www.openwall.com/john	John the Ripper: This is :1 free and open-source software - fosc password cracker, compatible with many *OSs* like different Aavors of Unix, Windows. DOS. BcOS and OpenVMS. lrs primary purpose is ro detect weak Unix passwords.
h11p://frecworld.tbc.org/thc-hydra	THC-Hydra: It is a very fast nerwork logon cracker which supports many different services.
lmp://www.aircrack-ng.org	Aircrack-ng: It is a set of cools used for wireless networks. This cool is med for 802.11a/big wired equivalent privacy (WEP) and Wi-Pi Protected Access (Wl'A) cracking. le can reoover a 40 through 512-bic WEP key once enough encrypted packets have been gaihered. Ir can al o arrack WPA I or 2 networks using advanced cryprographic merhods or by brure force.
lmp://www.lOpbtcrack.com	L0phtCrack: It is used co crack Windows passwords from hashes which it can obtain from stand-alone Windows work.nacions, nerworked servers, primary domain controllers or Acrive Direcrory. le also has numerous merhods of generating password guesses (dictionary, brurc force, ecc.).
lmp://airsnort.shmoo.oom	**AirSnort:** It is a wireless LAN (WLAN) cool which recovers c11cryption keys. It operates by passively moniroring transmissions. computing che encryption key when enough packets have been garhered. It require approximately 5-10 million cncrypred packers robe gathered. Once enough packets have been gathered, AirSnorr can guess chc encryption password in under a second. It runs under Wmdows or Linux.

(Cimtinutd)

Table 4.3 *(Continued)*

Website	Brief Description
http://www.solarwinds.com	**SolarWinds:** le is a plethora of network discovery/monitoring/attack cools and has created dozens of special-purpose cools cargeced ac sysrems administrators. Securiry-rdaced cools include many nerwork discovery scanners, a Simple Network Management Protocol (SNMP) brute force cracker, router password decry'ption and more.
hccp://www.foofus.net/fiugig/pwdump	Pwdump: It is a Window password recovery tool. Pwdurnp is able 10 extract NTLM and LanMan hashes from a Windows target, regardless of whether Syskcy is enabled. le is *also* capable of displaying password histories if they arc available.
hnp://projecc-rainbowcrack.com	RainbowCrack: It is a hash cracker that makes use of a large-scale time-memory trade-off. A traditional brute force cracker tries all possible plain rexes one by one, which can be time-consuming for complex passwords. RainbowCrack uses a time-memory trade-off *to* do alJ the cracking-time computation in advance and score the results in so-called "rainbow cables. It docs take a long time to prccomputc the tables but RainbowCrack can be hundreds of times faster than a brute force cracker once rhe prccompuration *is* finished.
hccp://www.hoobie.nec/bru cus	Brutus: It is one of the fastest, most Aexiblc remote password crackers available for **free.** le is available for Windows 9x, NT and 2000. Ir supporcs HTTP, POP3, FTP, SMB, TELNET, IMAP, NTP and more.

Password cracking attacks can be classified under three categories as follows:

1. Online attack ;
2. offiine attacks;
3. non-electronic attacks (e.g., social engineering, shoulder surfing and dumpster diving are explained in Chapter 2).

4.4.1 Online Attacks

An attacker can create a script file (i.e., automated program) that will be executed co cry each password in a list and when matches, an attacker can gain the access co the system. 'The most popular online attack is man-in-the middle (MITM) attack, also termed as "bucket-brigade attack" or sometimes "Janus attack." le is a form of active eavesdropping[7l in which the attacker establishes a connection between a victim and the server co which a victim is connected. When a victim client connects co the fraudulent server, the MJTM server intercepts the call, hashes the password and passes the connection co the victim server (e.g., an attacker within reception range of an unencrypted Wi-Fi wireless access point can insert himself as a man-in-the-middle). This type of attack is used co obtain the passwords for E-Mail accounts on public websites such as Yahoo, Hounail and Gmail and can also used to gee the passwords for financial websites thar would like co gain the access to banking websites.

4.4.2 Offline Attacks

Mosely offiine attacks are performed from a location ocher than the target (i.e., either a computer system or while on the network) where Lhese passwords reside or arc used. Offiine anacks usually require physical

Table 4.4 Types of password cracking attacks

ype of Attack	Description	Example of a Password
Dictionary atcack	Atcempcs co macch all the words from che dictionary to get che password	Adminiscracor
Hybrid anack	Subsritutes numbers and symbols 10 get che password	Adm In lscrator
Bruce force attack	Attempcs all possible pcrmucacion-combinations oflener. . numbers and special characters	Adm!n@09

access co che computer and copying the password file from the system onto removable media. Different rypes of offiine password attacks are described in Table 4.4. Few cools listed in Table 4.2 also use these techniques to gee the password in the clear text formar.

4.4.3 Strong, Weak and Random Passwords

A weak password is one, which could be easily guessed, shore, common and a system defaulL password that could be easily found by executing a brute force attack and by using a subset of all possible passwords, such as words in the dictionary, proper names and words based on the username or common variarions on these themes. Pas.-.words chat can be easily guessed by acquaintances of the netizens (such as dace of birch, pet's name and spouses' name) are considered co be very weak. Here are some of the examples of "weak pa. swords":

1. Susan: Common personal name;
2. aaaa: repeated letters, can be guessed;
3. rover: common name for a pet, also a dictionary word;
4. abcJ 23: can be easily guessed;
5. admin: can be easily guessed;
6. 1234: can be easily guessed;
7. QWERTY: a sequence of adjacent letters on many keyboards;
8. 12/3/75: dace, possibly of personal importance;
9. nbusrl23: probably a username, and if *so*, can be very easily guessed;
10. **p@$$\/\/Ord:** simple letter substitutions are preprogrammed into password cracking cools;
11. password: used very ofren - crivialJy guessed;
12. Decemberl2: using the dare of a forced password change *is* very common.

A strong password is long enough, random or otherwise difficulr co guess - producible only by the user who chooses it. The length of dme deemed to be too long will vary wirh the attacker, the attacker's resources, che ease with which a password can be tried and the value of the password ro the attacker. A student's password might nor **be** worth more than a few seconds of computer rime, while a password controlling access to a large bank's electronic money transfer system might be worth many weeks of computer time for trying co crack ir. Here are some examples of strong passwords:

1. Convert_£100 co Euros!: Such phrases are long, memorable and contain an exrended symbol co increase the strengrh of rhe password.
2. 382465304H: Ir is mix of numbers and a lerrer ar the end, usually used on mass user accounts and such passwords can be generated randomly, for example, in schools and business.
3. 4pRte!ai@3: Ir is nor a dictionary word: however it has cases of alpha along wich numeric and punctuation characters.

4. MoOoOAn245679: It is long with both alphabets and nwnerals.
5. t3wabSetyeT4: It is not a dictionary word; however, it has both alphabets and numerals.

Visit hrrp://www.microsofr.com/protec1/fraud/p words/checker.aspx co check the strength of your password.[181]

4.4.4 Random Passwords

We have .explained in the previous eccion how mosc secure passwords are long wich random strings of characters and how such passwords are generally most difficult co remember. Password is stronger if ir indudes a mix of upper and lower case letters, muubers and ocher symbols, when allowed, for the same number of characters. The difficulty in remembering such a password increases the chance char rhe user *will* write down rhe password, which makes it more vulnerable ro a different accack (in this case, rhe paper being lose or scolcn and the password discovered). Whether chis represencs a nee reduction in security depends on whether rhe primary d1reat co security is internal (e.g., social engineering) or excernal. A password can, at first sight, be random, buc if you really examine ir, it is just a pattern. One of these types of passwords is 26845. Although short, it is not easily guessed. However, the person who created che password is able co remember ic because it is just rhe four direction keys on the square number board (found at the right of most keyboards) plus a five in rhe middle. If you practice it, ic is just one swift motion of moving cwo fingers around the board (which is very *easy* 10 use). Forcing users ro use syscem-creared random passwords ensures that the password will have no connection with chac user and should not be found in any dictionary. Several O5s have included such a feature. AJmost all the OSs also include password aging; the users are required co choose new passwords regularly, usually afcer 30 or 45 days. Many users dislike these measures, particularly when they have nor been taken through security awareness training. The imposition of strong random passwords may encourage the users to write down passwords, score chem in personal digital assistanrs (PDAs) or cell phones and share chem with ochers against memory failure, increasing the risk of disclosure.

The general guidelines applicable to the password policies, which can be implemenced organization-wide, are as follows:

1. Passwords and user logon idenricies (1Os) should be unique to each authorized user.
2. Passwords should consist of a minimwn of eight alphanumeric characters (no common names or phrases).
3. Thereshould be computer-controlled liscs of prescribed password rules and periodic resting (e.g., letter and number sequences, character repetition, initials, common words and standard names) to ide cify any password weaknesses.
4. Passwords should be kept private, rhac is, not shared with friends, colleagues, etc. They shall not be coded imo programs or noted down anywhere.
5. Passwords shall be changed every 30/45 days or less. Mose operating systems (OSs) can enforce a password with an automatic expiration and prevent repeated or reused passwords.
6. User accounts should be frozen after five failed logon actempcs. All erroneous password entries should be recorded in an audit log for Lacer inspection and action, as necessary.
7. Sessions should be suspended after 15 minutes (or ocher specified period) of inactivity and require the passwords to be re-entered.
8. Successful logons should display the dace and rime of the lase logon and logotf.
9. Logon IDs and passwords should be suspended after a specified period of non-use.
10. For high-risk systems, after excessive violations, the system should generate an alarm and be able co simulate a continuing session (with dummy data) for the faj(ed user (co keep this user connected while personnel anempr co investigate the incoming connection).

Similarly, necizens should practice password guidelines co avoid being victim of getting cheir personal E-Mail accounts hacked/attacked by the attackers.

1. Passwords used for business E-Mail accounts, personal E-Mail accounts (Yahoo/Hotmail/Gmail) and banking/financial user accounrs (e.g., online banking/securities rrading accounts) should be kept separate.
2. Passwords should be of minimum eight alphanumeric characters (common names or phrases should be phrased).
3. Passwords should be changed every 30/45 days.
4. Passwords should not be shared with relatives and/or friends.
5. Password *used* previously should not be used while renewing the password.
6. Passwords of personal E-Mail accounts (Yahoo/Hocmail/Gmail) and banking/financial user accouncs (e.g., online banking/securities rrading accounts) should be changed from a secured system, within couple of days, if these E-Mail accounts has been accessed from public Internet facilities such as cybercafes/hocels/libraries.
7. Passwords should not be scored under mobile phones/PDAs, as these devices are also prone co cyber-actacks (explained in Section 3.8, Chapter 3).
8. In the case of receipt of an E-Mail from banking/financial institutions, instructing co change the passwords, before clicking the weblinks displayed in the E-Mail, legitimacy of che E-Mail should be ensured co avoid being a victim of Phishing attacks (we will explain Phishing attack in derail in Chapter 5).
9. Similarly, in case of receipt of $MS from banking/financial institutions, instructing to change the passwords, legitimacy of the E-Mail should be ensured to avoid being a victim of Smishing arcacks (explained in detail in Chapter 3).
10. In case E-Mail accounts/user accounts have been hacked, respective agencies/institutes should be contacted immediacely.

4.5 Keyloggers and Spywares

Keyscroke logging, often called keylogging, is the practice of noting (or logging) the keys struck on a keyboard, typically in a covert manner so that the person using the keyboard is unaware chat such actions are being monitored.[191]

Keystroke logger or keylogger is quicker and easier way of capturing the passwords and monitoring the victims' IT savvy behavior. le can be classified as sofrware keylogger and hardware keylogger.

4.5.1 Software Keyloggers

Sofrware keyloggers are software programs (see Table 4.5) installed on the computer systems which usually are located between che OS and the keyboard hardware, and every keystroke is recorded. Software keyloggers are installed on a computer system by Trojans or viruses (will discuss more on this in subsequent sections of this chaprer) without cbe knowledge of the user. Cybercriminals always install such tools on the insecure computer systems available in public places (i.e., cybercafes, library - we have already discussed this in Chapcer 2) and can obtain the required information abouc the victim very easily. A keylogger usually consists of two files that get installed in the same directory: a dynamic link library (DLL) file and an EXEcucable (EXE) file that installs the DLL file and triggers it to work. Oil does all the recording of keysuokes.[1,01]

Table 4.5 Software keyloggers

bsite	Brief Description	s
hu p://www.soft-cencral.net	SC-KeyLog PRO: It allows to secretly record computer user activities such as £-Mails, chat conversations, visited websites, clipboard usage, etc. in a protected logfilc. SC-KeyLog PRO also capwres Windows user logon passwords. The capmred informadon is completely bidden from the user and allows to remorely install the monitoring system through an E-Mail anachmenc without the user recognizing che installation at all.	
lmp://www.spycech-web.com	Spytech SpyAgent Stealth: It provides a large variety of esscmial compurer monitoring fcamres as well a website and application filtering, chat blocking and remote delivery of logs via E-Mail or Ff P.	
Imp://www.relytec.com	All In One Keylogger: le is an invisible keystrokes recorder and a *spy*sofrware cool that registers every activiry on the PC ro encrypted logs. lhis keylogger allows secretly tracking of all activities &om all computer users and automatically receiving logs to a desired E-Mail/FTP accounting. With this keyloggcr, one can read chat conversations, look at che E-Mails as well as watch the sites that have been surfed.	
hrrp://w,vw.stealthkeylogger.org	Stealth Keylogger: It is ;1 computer monitoring software that enables aniviiy log report where rhe entire PC keyboard acLivities are registered dd1cr :IL specific time or hourly on daily basis·. 1he entire log reports are generated either in rcxr or HTML file forma1as defined by 1he user. 11,e keylogger facilicares mailing of log report at rhe specified E-Mail address.	
http://,vww.bla1..ingrools.com	Perfect Keylogger: Ir has its advanced keyword detection and nocificarion. User can create a list of"on alcrc" words or phrases and kcylogger wilJ continually moniror keyboard typing, URLs and wcbpages for these words or phrases - for example, "bomb," "sex," "visiting places around Mumbai" and "Windows vulncrabilicies." When a keyword is detected, perfect keylogger makes screenshot and sends E-Mail notification co the user.	
hrrp://kgb-spy-software. en.softonic.corn	**KGB** Spy: Ir is a multifunctional keyboard tracking software, widely used by both regular users and IT security specialists. This program docs 1101 jusr record keystrokes but is also capable of recording language-specific characters. Ir records all typed data/all keyboard activiry. It can be used 10 moniror children's activity a1 home or co ensure employees do not use company's computers inappropriately. Visir www.refog.com to find more on this product.	
hr1p://www.spy-guide.ner/spybuddy- spy-sofrware.hcm	Spy Buddy: This, along with keylogger, has following features: • Internet conversation logging; • disk activity logging; • Window activity logging; • applicarion activity logging; • clipboard activity logging; • AOL/Internet explorer history; • prinred documents logging; • keylogger keystroke monitoring; • websites activity logging; • screenshoc captw'ing; • WrbWarch keyword alerting	

(Co111illutd)

Table 4.5 *(Continued)*

Website	*Brief Description*
hnp://www.elire-keylogger.com	Elite Keylogger: It captures ever)' keystroke typed, all passwords (including Windows logon passwords), chats, instant messages, E-Mails, websites visited, all program launched, usernames and time they worked on the computer, desktop activiry, clipboard, ere.
hnp://swww.cyberspysoftware.com	CyberSpy: Ic provides an array of features and easy-co-use graphical interface along with computer monitoring capabilities such as keep rabs on the employees and keeps track of what children are viewing on the Inrerner. CyberSpy can be used as complete PC monitoring solurion for any home or office. CyberSpy records all websites visited, instant message conversations, passwords, E-Mails and all keystrokes pressed. Ir also has the ability ro provide screenshors at set intervals.
hrrp://www.mykeylogger.com	Powered Keylogger: Powered keylogger can be used for the following: • *Surveillance:* It is for anyone to control what happens on the computer wheJl che computer's owner is away. • *Network administmtion:* It is for network adminiscrarors co control outgoing rraffic :rnd sites visited. • *Shared PC activity tmcking:* It is co analyze the usage of shared PC. • *Parental control:* le helps parents co monitor their children's compurer and Internet activity. • *Employee produl'tivity monitoring:* **ft** helps managers ro check and increase productivity of their stuff or just co prevent the leak of important informacion.
http://www.x-pcsofr.com	XPC Spy: XPC Spy is one of the powerful keylogger spy software, runs stealthy undet MS Windows and has the following features: • Records all keystrokes typed•; • records all websites visited; • records all programs executed, folders explored, files opened or edited, documents printed, etc.; • records all windows opened; • records all clipboard text content; • records all system activities; • records webmails sent (database update online, more and more webmail servers are supported); • records all [CQ Messenger char conversations; • records all MSN Messenger char conversations; • records all AOL/AIM Messenger char conversations; • records all Yahoo! Messenger char conversations; • runs invisible in the background and is protected by password; • is built-in screcnshm pictures viewer; • schedules monitor process, sers rime to stare or stop monitoring; • sends logs report via E-Mail.

4.5.2 Hardware Keyloggers

To install these keyloggers, physical access ro the computer system is required. Hardware keyloggers are small h:1rdware devices. These are connected to the PC and/or ro the keyboard and save every keystroke into a file or in the memory of the hardware device. Cybercriminals install such devices on ATM machines to capture ATM Cards' PlNs. Each keypress on d,e keyboard of tbe ATM gets registered by these keyloggers. ll1ese keyloggers look like an integrated part of such systems; hence, bank customers are unaware of their presence.

Listed are few websires where more information about hardware keyloggers can be found:

1. hrrp://www.keyghosr.com
2. http://www.keelog.com
3. http://www.keydevil.com
4. hnp://www.keykarcher.com

4.5.3 Antikeylogger

Amikeylogger[1111] is a rool thar can detect the keylogger installed on the computer system and also can remove the cool. Visit htcp://www.anti-keyloggers.com for more information.

Advantages of using anrikeylogger are as follows:

1. Firewalls cannot detect cJ1e installations of keyloggers on the sysrems; hence, anrikcyloggers can deccn installations of keylogger.
2. This software does nor require regular updates of signarure bases co work effectively such as other anrivirus and antispy programs; if nor updated, it does not serve the purpose, which makes the users ar risk.
3. Prevents Internet banking frauds. Passwords can be easily gained with the help of installing keyloggers.
4. [c prevents ID theft (we will discuss it more in Chapcer 5).
5. le secures E-Mail and inscanc messaging/chacting.

4.5.4 Spywares

Spywarc is a type of malware (i.e., malicious software - see Box 4.3 to know abouc different types of malwares) thac is installed on compurers which collects information abom users without their knowledge. The presence *of* SpY'vare is cypically hidden from the user; it is secretly inscalled on the user's personal computer. Sometimes, however, Spywares such as keyloggers are installed by rhe owner of a shared, corporate or public computer on purpose co secretly monitor ocher users.llll

Ir is dearly w1ders1ood from the term *Spyware* that it secretly monitors the user. l he features and functions of sud1Spywarcs are beyond simple monitoring. Spyware programs collecc personal information about the victim, such as the lnrernec surfing habits/patterns and websites visited. The Spyware can also redirect Inrernet surfing activities by insralling another stealth utility on the users' computer system. Spyware may also have an ability co d1ange computer settings, which may result in slowing of che Internet connection speeds and slowing of response time that may result into user complaining abouc che Internet speed connection wich Internee Service Provider (ISP). Various Spywares are available in d1e marker and the one char are popular arc lisced in Table 4.6.

To overcome che emergence ofSpywares that proved to be croublesome for the normal user, anti-Spyware sortwares {refer co Appendix 8: Lise of Useful Software Utilities and Websites in CO) are available in the marker. lnsrallatio□ of anti-Spyware software has become a commo n elemenr nowadays from computer security practices perspective.

Box 4.3 Malwares

Molware, short for malicious software, is a software designed to infiltrate a computer system without the owner's informed consent (see Box 9.8. Chapter9). The expression is a general term used by computer professionals to mean a variety of forms of hostile, intrusive or annoying software or program code.[1131]Malwore con be classified as follows:

1. **Viruses and worms:** These are known as *infectious* mo/wore. They spread from one computer system to another with a particular behavior (will discuss more on this in Section 4.6).
2. **Trojan Horses:** A Trojan Horse,[1141]Trojan for short. is a term used to describe malware that appears. to the user. to perform a desirable funct!on but. in fact. facilitates unauthorized access to the user's computer system (will discuss more on thisin Section 4.7).
3. **Rootklts:** Rootkits[1151]is a software system that consists of one or more programs designed to obscure the fact that a system has been compromised. For further details refer to Section 7.12.1, Chapter 7.
4. **Backdoors:** Backdoor[1161] in a computer system (or cryptosystem or algorithm) is a method of bypassing normal authentication. securing remote access to a computer. obtaining access lo plain text and so on while attempting to remain undetected.
5. **Spyware:** For further details see Section 4.5.
6. **Botnets:** For further details see Section 2.6 in Chapter 2.
7. **Keystroke loggers:** For further details see Section 4.5.

Table 4.6 Spywares

Website	*Brief Description*
hrcp://www.e-spy•sofcware.com	007 **Spy: It** has following key features: • Capability of overriding "antispy" programs like "Ad-aware"; • record a,11websites URL 1•isited in Internee; • powerful kcylogger engine ro capmre all passwords; • view logs remotely from anywhere ar anytime; • export log report in HTML formar to view it ıJ1 d1e browser; • automatically clean-up on ourdared logs; • password prorecriun.
hrtp://www.specmrsofc.com	Spector Pro: Jc has following key foacures: • Captures and reviews all chars and inscanr messages; • captures E-Mails (read, senr and n:ccivcd); • captures websites visited; • captures activities performed on social neiworking sites such as MySpace aJ1d Facebook; • enables co bl<>ck any particular website and/or charring with anyuru:; • aces as a keyloggcr to caprnre every single keystroke (including usernames and passwords}.
http://www.speccorsoft.com	**eBlaster:** Besides keylogger and website watcher, ir also records E-Mail sent a.nd received, files uploaded/downloaded, logging users' acriviries, record online searches, recording MySpacc and facebook activities and any ocher program activiry.
http://www.rcmorcspy.com	Remotespy: Besides remote computer monitoring, silently and invisibly. ir also monitors :rnd records users' PC without any need for physical access. Moreover, it records keystrokes (keylogger), screenshors, E-Mail, passwords, chars, instant messenger conversations and websites visited.

(Continued)

Table 4.6 *(Continued)*

Website	*Brief Description*
hrrp://www.copofbesrsoft.com	**Stealth Recorder Pro:** It is a new rype of utility that enables co record a variety of sounds and transfer them automatically through Internet without being notified by original location or source. Ir has following features: • Real-time MP3 recording via microphone, CD, line-in and stereo mixer as MP3, WMA or WAV formatted files; • r,ransferring via E-Mail or FTP, the recorded files co a user-defined E-Mail address or FTP autqmacically; • controlling from a remote location; • voice mail, records and se:nds the voice messages.
hccp://www.amplusnet.com	**Stealth Website Logger:** It records all accessed websites and a detailed reporr can be available on a specified E-Mail address. lr has following key features: • Monitor visited websites; • reports sent co an E-Mail address; • daily log; • global log for a specified period; • log deletion after a specified period; • hockey and password protection; • not visible in add/remove programs or cask manager.
hcrp://www.flexispy.com	**Flexispy: Ir** is a cool char can be installed on a cell/mobile phone. After i.nsrallarion, Flexispy secredy records coversation that happens on rhe phone and sends chis information co a specified E-Mail address.
Imp://www.wiretappro.com	**Wiretap Professional:** Ir is an application for monitoring and capturing all activities on the system. It can capcure the entire lnremet activiry. This spy software can monitor and .record E-Mail, char messages and websites visited. In add.ition, it helps in monitoring and recording of keystrokes, paS-\words entered and all documents, pictures and folders viewed.
http://www.pcphonehome.com	PC PhoneHome: It is a software'char cracks and locares lost or stolen laptop and desktop computers. Every time a compurer system on which PC PhoneHome has been installed, conneced to the Internet, a sccalth E-Mail is sent to a specified E-Mail address of the user's choice and 10 PC PhoneHome Producr Company.
http://www.spyarsenal.com	**SpyArsenal Print Monitor Pro:** It has following features: • Keep track on a printer/plotter usage; • record every document printed; • find out who and when certain paper printed with your hardware.

4.6 Virus and Worms

Compucer virus is a program chat can "infect" legitimate programs by modifying them to include a possibly "evolved" copy of irsel£ Viruses spread themselves, without the knowledge or permission of the users, to potentially large numbers of programs on many machines. A computer virus passes from computer to compurer in a similar manner as a biological virus passes from person to persop. Viruses may also concain malicious instructions rhat may cause damage or annoyance; rhe combination of possibly Malicious Code with the ability to spread is what makes viruses a considerable concern. Viruses can often spread without any readily visible symptoms. A virus can start on evenc-driven effects (e.g., triggered after a specific number of executions), time-driven effects (e.g., triggered on a specific dace, such as Friday che 13th) or can occur ac random. Viruses can cake some typical actions:

I. Display a message to prompt an action which may sec of the virus;
2. delete files inside the system into which viruses enter;
3. scramble data on a hard disk;
4. cause erratic screen behavior;
5. halt the system (PC);
6. just replicate themselves to propagate further harm.

figures 4.1-4.3 explain how viruses spread (a) through the Internet, (b) through a stand-alone computer system and (c) through local networks.

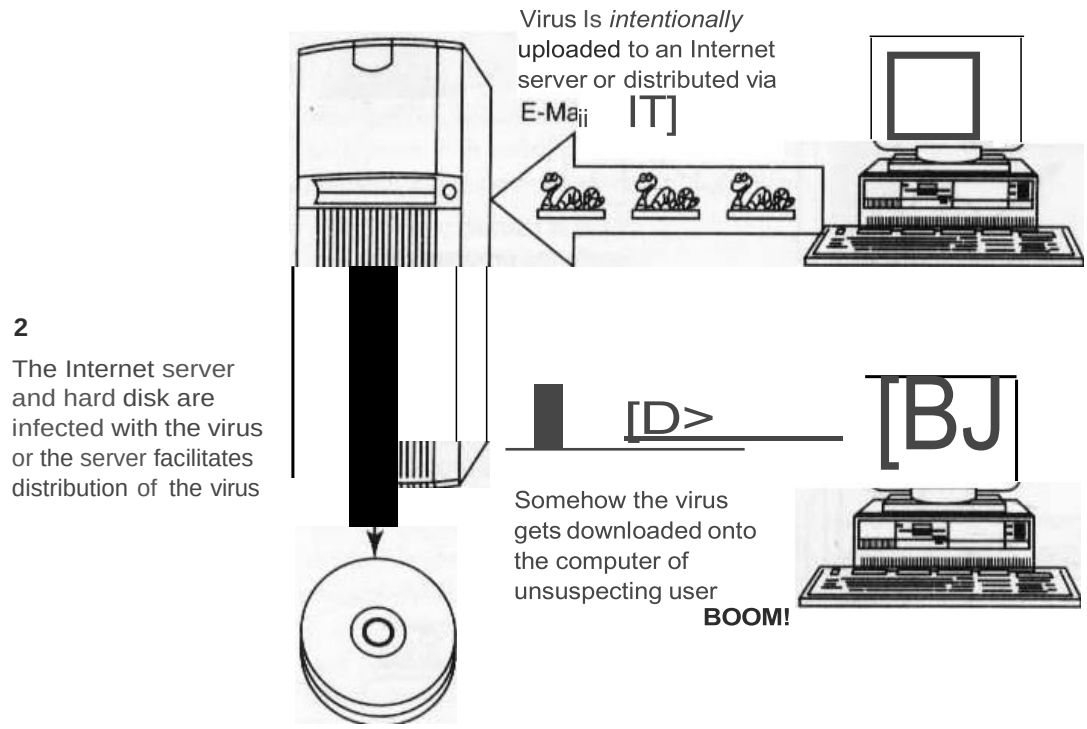


Figure 4.1 Virus spreads through the Internet.

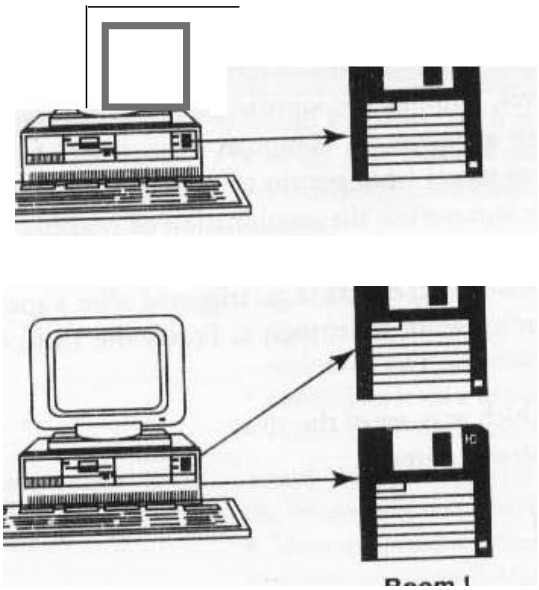


Figure 4.2 Virus spreads through stand-alone system.

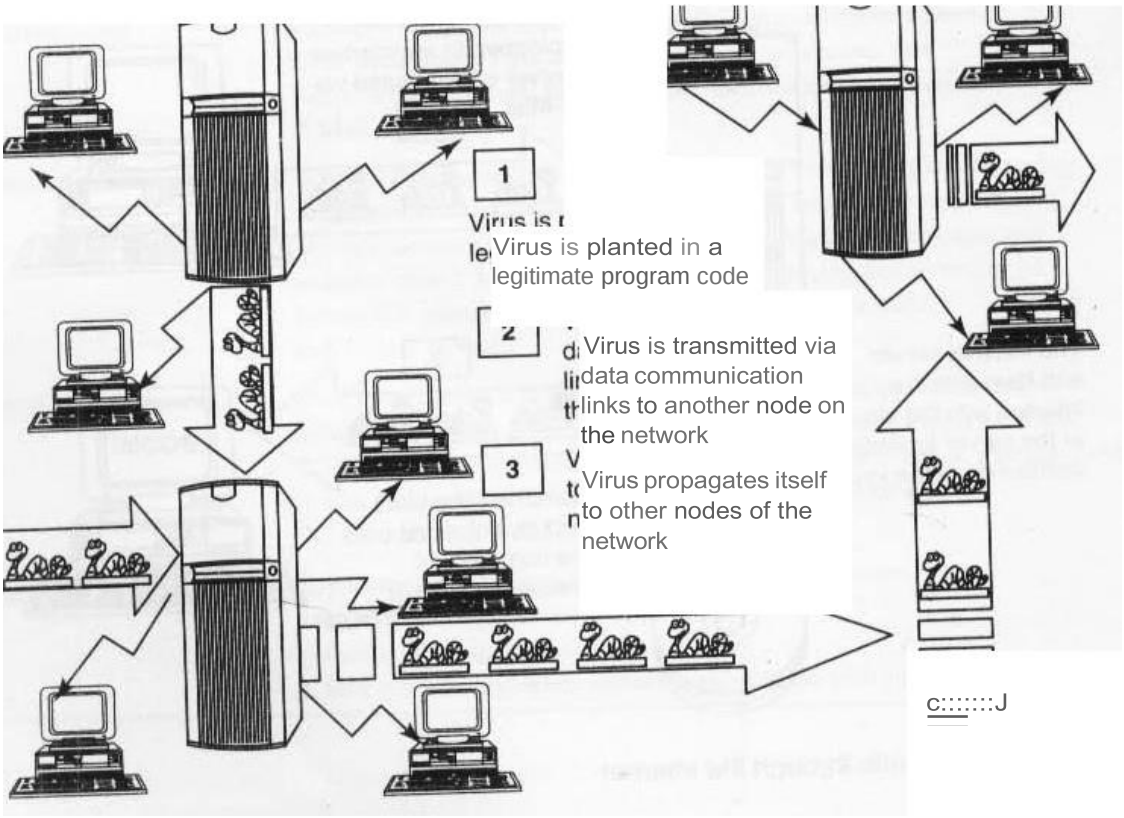


Figure 4.3 Virus spreads through local networks.

Computer virus has the ability to copy irself and infect Lhe system.'Ine term *virus* is also commonly but erroneously used ro refer co ocher types of malware, Adware and Spyware programs rhar do nm have reproductive ability. A true virus can only spread from *one* system co another (in some form of executable code) when its hosr is taken ro che target computer; for instance, when a user senr il over rhe Internet or a necwork, or carried it on a removable media such as CD, DVD or USB drives. Viruses can increase Lhcir chances of spreading to ocher systems by infecting files on a network file system or a file system char is accessed by another system.[1171]

As explained in earlier sections, the term *computer virus* is sometimes used as a *catch-ail* ***phrase*** co include all types of malware, Adware and Spywarc programs char do not have reproductive ability. Malwarc includes computer viruses, worms, Trojans, most Rootkirs, Spyware, dishonest Adware, crimeware and ocher ma!i-cious and unwanted software as wdl as true viruses. Viruses are sometimes confused with computer worms and Trojan Horses, which are technically different (see Table 4.7 to undemand 1he difference becween computer viru and worm). A worm spreads itself automarically co ocher computers through networks by exploiting security vulnerabilities, whereas a Trojan is a code/program that appears co be harmless but hide.'> malicious functions. Worms and Trojans, such as viruses, may ha.rm the system's dara or performance. Some viruses and ocher malware have noticeable 'ymptoms chat enable com purer user to rake neces ary corrective actions, but many viruses are surreptitious or simply do nothing for user's to rake note of them. Some virus donothing beyond reproducing Lhemselves.[1171]

Table 4.7 Difference between computer virus and worm

Sr. No.	Facet	Virus	Worm
	Different cypes	Stealth virus, self-modified virus, encryption with variable key virus, polymorphic code virus, metamorphic code virus	E-Mail worms, instant messaging worms, Internet *worms*, lRC worms, file-sharing ne,works worms
2	Spread mode	Needs a hose program co spread	Self, without t.Uet intervention
3	What is it?	A computer virus is a software program char can copy itself and infect rhe dara or information, without 1he users' knowledge. However, co spread to another computer, it needs a host program that carries the virus	A computer worm is a sofcware program self-replicating in nature, which spreads cJ1rough a nerwork. It can send copies through the network with or without user intervention
4	Inception	The creeper virus was considered as chc first known virus. It was spread through ARPANET in che early I970s. It spreads through the TENEX OS and uses connected modem to dial out rn a remote computer and infect it.	The name worm originated from 1l1e Shockwave Rider, a science fiction novel published in 1975 by John Brunner. Later researchers John FShock and Jon A Hupp at Xerox PARC published a paper in J982, *!he Wonn Programs* and after that the name was adopred
5	Prevalence	Over 100,000 known computer viruses have been there though nor all have attacked computers (rill 2005)	Prevalence for virus is very high as againM moderate prevalence for a worm.

Sourer: See [18) in References section.

4.6.1 Types of Viruses

Computer viruses can be categorized[1191] based on attacks on various elements of the system and can puc the system and personal data on rhe system in danger.

1. Boot sector viruses: It infects che srorage media on which OS is stored (e.g., floppy diskettes and hard drives) and which i.s used to start the computer system. The entire data/programs are stored on the floppy disks and hard drives in smaller sections called sectors. The first sector is called che BOOT and it carries the master boot record (MBR). MBR's function is to read and load OS, char is, ic enables computer system to stare through OS. Hence, if a virus attacks an MBR or infects the boot record of a disk, such floppy disk infects victim's hard drive when he/she reboots the system while che infected disk is in the drive. Once the victim's hard drive is infected all rbe floppy diskettes that are being used in the system will be infected. Booe sector viruses often spread to ocher systems when shared infected disks and pirated sofcware(s) are used.
2. **Program viruses:** These viruses become active when d1e program file (usually with excensions .bin, .com, .exe, .ovl, .drv) is excuted (i.e., opened - program is started). Once these program files get'infecced, che virus makes copies of itself and infects the other programs on the computer system.
3. **MuJtipartite viruses:** Ir is a hybrid of a boot sector and program viruses. It infects program files along with the boot record when the infected program is active. When che victim scares the computer system next time, it will infect the local drive and ocher programs on the victim's computer system.
4. Stealth viruses: It camouflages and/or masks icself and so detecting this type of virus is very difficult. It can disguise itself such a way that antivirus software also cannot detect it thereby preventing spreading into the computer system. lt alters ics file size and conceals itself in the computer memory to remain in the system undetected. The first computer virus, named as Brain, was a stealth virus. A good amivirus detects a stealth virus lurking on the victim's system by checking the areas the virus must have infected by leaving evidence in memory.
5. Polymorphic viruses: le aces like a "chameleon" char changes its virus signature (i.e., binary paccern) every time it spreads through the system (i.e., multiplies and infects a new file). Hence, iris always difficult co detect polymorphic virus wid, the help of an antivirus program. *Polymorphic generators* are che routines (i.e., small programs) chat can be linked with the existing viruses. These generators are not viruses but the purpose of these generators is co hide acrual viruses under the cloak of polymorphism. The first all-purpose polymorphic generator was the mutarion engine (MtE) published in 1991. Ocher known polymorphic generators are Dark Angel's Multiple Encryptor (DAME), Darwinian Genetic Muration Engine (DGME), Dark Slayer Mucacion Engine (DSME), MutaGen, Guns'n'Roses Polymorphic Engine (GPE) and Dark Slayer Confusion Engine (DSCE).
6. **Macroviruses:** Many applicacions, such as Microsoft Word and Microsoft Excel, support MACROs (i.e., macrolanguages). 1hese macros are programmed as a macroembedded in a document. Once a macrovirus gets onto a victim's computer rhen every document he/she produces will become infected. 'This rype of virus is relatively new and may get slipped by the amivirus software if the user does not have the most recent version installed on his/her system.
7. **Active X and Java Control:** All che web browsers have settings about Active X and Java Controls. Little awareness is needed about managing and controlling these settings of a web browser co prohibit and allow certain functions to work - such as enabling or disabling pop-ups, downloading 61es and sound - which invites the threats for che compurer sysrem being rargeced by unwanted software(s) floating in cyberspace.

To know more on viruses see Box 4.4 and co know more on the world's worse virus attacks see Table 4.8. *As* Windows OS is the most used OS across che globe, the lisrs of viruses displayed in Table 4.8 are rhe attacks on Windows OS. 1l1e terms "Virus" and "Worm" are used interchangeably and hence readers may find char the viruses listed under Table 4.8 may be referred as worms on some websiLes and/or in some books.

Box 4.4 More about Viruses!

1. The early "hacking" sites that have allowed to download favorite virus ore as follows:
   - www.2600.com
   - www.LOpht.com
2. The exhaustive list of viruses can be found al:
   http://en.wikipedia.org/wiki/List_of_compurer_viruses_(all)
3. The viruses can attack a system 365 days a year. However, on 1he designated payload dates, the virsues may do more than just infect the system. Virus calendar can be found o1:
   http://home.mcofee.com/viruslnfo/VirusCalendor.aspx
4. **Computer virus hoax:** It is a•message warning the recipient of a non-existent computer virus threat. The message isusually a chain E-Mail that tells the recipient to forward it to everyone they know. They often include announcements claimed to be from reputable organizalions such as Microsoft, IBM or news sources such as CNN and include emotive language and encouragement to forward the message. These sources are quoted lo add credibility to the hoax. The list of virus hoax can be found at:
   http://en.wikipedio.org/wiki/Virus_hoax
5. **Unix and Linux OS are Immune from computer viruses:** This is a myth that Unix/Linux systems are as susceptible to hostile software attacks as any other systems. However. such systems usually found to be well-protected compared with Microsoft Windows because fast updates are avail- able lo most Unix/Linux vulnerabilities. The list of virus/worms found on Unix/Linux systems can be found at:
   http://en.wikipedia.org/wiki/Linux_malware

Table 4.8 The world's worst virus attacks!!!

Sr. No.	Virus	Brief Description
	Con1icker	le is also known as Downup, Downadup and Kido. It targets Microsoft: Windows OS and was first detected in November 2008. Ir uses Raws in Windows software and dictionary atcaclcs on administraror passwords co co-opt machines and link them into a virrual computer tbar can be commanded remor.ely by its authors. The name Conficker is blended from a English cerm *"configure"* and the German word *"1-"icker,"* which means "co have sex with" or "co mess with" in colloquial German.
2	IN.F/AucoRun	*AutoRun* and che companion feature *A11t0Play* are components of the Microsoft Windows OS that diccate what actions the system takes when a drive is mounted. This is tbe most common threat chat infects a PC by creating an "autorun.inf" file. The file concains information abour programs meant ro run aucoma tically when removable devices are connected co the computer. End-users muse disable che AucoRun feature enabled by default in windows. AucoRun fw1cclonalicy is used in attack vector attacks.

(Continued)

Table 4.8 *(Continued)*

No.	Virus	Brief Description
		le is a dangerous virus rhar replicates itself as other viruses and spreads from one
3	Win32 PSW. OnLincGames	le is a dangerous virus char replicates itself as other viruses and spreads from one computer system ro :mocher carrying a payload of destruccion. h can infect several computers within few minures. Ir is more concerned with gamers around the world, stealing confidential and orher financial credentials as wcU as gaining access t0 rhe vicrim's accoum·.niis virus is .1lso rermed as Trojan.
4	Win32/Agenr	'This virus is also termed as Trojan. It copies irselfinco temporary locations and steals information from the infected sysrem. It adds entries into the registry, creating several files ar differcnr places in the system folder, allowing ir ro run on *every* scare-up, which enables to gather complete information about rhe infected sysrem and rhen transferred to rhc inrruder's sysrem.
5	Win32/FlyStudio	Ir is k11own as Trojan with characteristics ofbackdoor. This vims does nor replicate itself, but spreads only when the circumsranccs are beneficial. It is called as backdoors because rhe informarion stolen from a sysrem is senr back to the intruder.
6	Win32/Paceic.Gen	This threat designates a wide range of malwares char makes use of an obfuscation layer to steal passwords and orher informarion from che infected system.
7	Win32/Qhosr	·1his virus copies itself co the Sysrcm32 folder of chc Windows directory giving conrrol of the compmer ro che arracker. The arcacker then modifies che Domain Name Server/Sysrem (DNS) settings redirecting 1he compurer to ocher domains. This is done ro compromise the infecred machine from downloading any updates and redirect any arcemprs made ro a website chat downloads ocher malicious files on the victim's computer.
8	WMA/ TrojanDownloader. GetCodec	·1his threat as the suffix .GcrCodec modifies che audio files presenr on che syscem to ".wma" formar and adds a URL header chat poinrs 10 rhe location of rhe new codec. In this manner, the hosecompurer is forced co download the new codec and along wirh the new codec several orher Malicious Codes are also downloaded. lhis means char the end-user wiU download chc new codec believing that something new might happen, whereas che Malicious Code runs in tbe background causing harm co Lhe host compmer. At present, there is no way to verify the aurhenriciry of rhe codec being downloaded as a new enh,mcement or a Trojan Horse; rhereforc. users muse avoid unnecessary downloading of new codecs uni= they are downloaded from a trusted website. Unnecessary dow11loading of codecs should also be avoided.

Sour,·e: hnp://www.brighthub.com/compuring/smb-m:uril}'/anidc;/44811..l';px

A computer worm is a self-replicating malware computer program.[1201] It *uses* a computer network rosend copies of itself to ocher nodes (computers on the ncn.vork) and it may do so wirhout any use.r intervention. Thi!> is due co security shortcomings on rhe target computer. Unlike a virus, it does nor need co attach itself co an existing program. Worms almost always cause at least some harm ro che nerwork, if only by consuming bandwidth, whereas viruses almosl always corrupt or modify files on a targeted compurer.[1181] See Table 4.9 co know more on World's worse worm arcaclcs.

Table 4.9 The world's worst virus and worm attacks!!!

Sr. No.	Worm	Brief Description
	Morris Worm	It is also known as "Grear Worm" or Internet Worm. It was wrinen by a studenr, Robert Tappan Morris, at Cornell University and launched on 2 November 1988 from MIT. It was reported chat around 6,000 major Uni.x machines were infected by rite Morris worm and che rotal cost of the damage calcu1ared was US$ 10-100 millions.
2	LLOVEYOU	le is also known as VBS/Lovclerter or Love Bug Worm. lr successfully a1racked tens of millions of Windows computers in 2000. The E-Mail was sent with the subjecL line as "ILOVEYOU" and an arcachmenr "LOVE-LETTER-FOR-YOU.TX1 vbs." Toe file extension "vbs" was hidden, hence the receiver downloads che attachment and opens it to see the contents.
3	Nimda	le is che most widespread computer worm and a file infecter. Tccan affect Inremer's within 22 minutes. Nimda alfecced both user workstarions (i.e., c:lkms) running on Windows 95, 98, Me, NT, 2000 or XP and Servers running on Windows NT :ind 2000. It is "admin" when this worm's name is spelled backward.
4	Code Red	This computer worm was observeci on the Interncr on J3 July 2001. 11 artacked compmers running on Jvlicrosofr's 11S web server. The Code Red worm was fir. t discovered and researched by eEye Digital Security employees, Marc Maiffret and Ryan Permeh. They named rhc worm Code Red bec:iuse chey were drinking Pepsi's "MOLuirain Dew Code Red" over che weekend. They analyzed ic because of the phrase "Hacked by Chinese!" with which che worm defaced websites. On 4 August 200 l "Code Red LI" appeared on che l memer and was found co be a variant oFthe original Code Red worm.
5	Melissa	It is also known a. "Melissa," "Simpsons," "Kwyjibo" or "Kwejeebo." IL is a mass-mailing macro worm. Melissa was written by David L. Smirh in Aberdeen 1ownship, New Jersey, who named ir after a lap dancer he mer in Florida. The worm was in a file called "Lise.DOC" which had passwords thaL allow the access inro 80 pornographic websitt:s. This worm in the original form was sem Lhrough an E-Mail to many Internet u. ers. Melissa spread on Miccosofr \Xlord 97. Word 2000 and also on Microsoft Excel 97, 2000 and 2003. It can mass-mail itself from E-Mail client Microsoft Ourlook 97 or Outlook 98.
6	MSBlast	The Blaster \Vonn: le is a.lso known as Lovsan or Lovesan, found during August 2003, which spread across the systems running on Microsofr Windows XP and Windows 2000. The worm also creates an encry under OS regisrry ro launch che worm every time Windows stares. This worm contains two messages hidden in strings. The .first, "I just waor co say LOVE YOU SAN!!" and so the worm sometimes was called "Lovesan worm." The second message, "Billy g:ices why do you make chis possible? Stop making money and fix yoUI software!!" This messag<.: was for Bill Gates, the co-founder 01 Microsofr and Larger of rht: worm.
7	Sobig	This worm, found duringAugu. t 2003, infected millions oflnr<.:rncc-connectcd computers that were running on Microsoft Windows. Jr was wrirttcr1 in Microsoft Visual C++ and compressed using a data compression *cool,* "tF.lodc" 111.is \Xlorm not only replicates by itsdfbur also a Trojan Horse rhac ir masquerades as somerhing other rhan malwarc. Jc will appear as an E-Mail with one of the Following subjects: • Re: Approved • Re: DetaiIs

(Comhwrd)

Table 4.9 *(Continued)*

Sr. No.	*Worm*	*Brkj'Dncriptunt*
		• Re: Re: *My* details • Re: Thank you! • Re: That movie • Re: Wicked screcnsaver • Re: Your application • ll1ank you! • Your details le will contain the text as "See the attached file for details" or "Please see the a1rached file for derails."'ll1e E-M:til will also contain an auachmcnt by one of rhc names menrioned below: • applkarion.pif • dctails.pif • documcnr_9446.pif • documem_all.pif • movie0045.pif • thank_you.pif • your_details.pif • your_docurnem.pif • wicked_scr.scr
8	Storm Worm	This worm, found on 17 January 2007, is also known a a backdoor Trojan Horse rhat affects rhe systems running 011 Microsoft OSs. The Srorm worm infected thousands of computer systems in Europe and in the US on Friday, 19 January 2007, through an E-Mail with a subject line abour a recent wearher disaster, "230 dead as storm barrcrs Europe." The worm is also known as: • Small.dam or Trojan-Down1oader.Win32.Small.dam • CME-71 I • W32/Nuwar@MM and Oownloader-BAI • Troj/Dorf and Mal/Dorf • Trojan.DL.Tibs.Gcn!Pac13 • Trojan.Oownloader-647 • Trojan.Peacomm • TROJ_SMALL.EDW • Win32/Nuwar • Win32/Nuwar.N@MM!CME-71 I • W32/Zhelatin • Trojan.Peed, Trojan.Tabs
9	Michelangelo	It i a worm discovered in April 1991 in New Zealand. This worm was designed primarily to infect the sysrerns rhar were running on disk operating system (DOS) systems. Like other boot sector viruses, Michelangelo operated ac the BIOS level and remained dormant until 6 March, rhe birthday of an anise "Michelangelo di Lodovico Buonarroti Simoni" - an Italian Renaissance painter, sculptor, architect and poer.

(Continued)

Table 4.9 *(Continued)*

Sr. No.	Worm	Brief Description
10	Jerusalem	This worm is also known as "BlackBox." Jerusalem infecred rhe 61es residing on DOS char was detected in Jerusalem, Israel, in Ocrober 1987. It has become memory resident (using 2 KB of memory). Once rhe system gets infected then it infects *every* executable file, excepr "COMMAND.COM." ".COM'files grow by 1,813 bytes when infected by Jerusalem and are nor reinfected. Similarly ".EXE" files grow from 1,808 ro 1,823 byres each time they get infecred. Jcm alem reinfect$".EXE" files each time the file is loaded until their size is increased that is found to be "roo large co load inro memory."

Almost every day new viruses/worms are created and they become new threat to necizens. (See Box 4.4 co know more about viruses.) In summary, in spice of different platforms (i.e., OS and/or applications), a rypical definition of computer virus/worms might have various aspeccs[1211] such as:

1. A vim, attacks specific file types (or files).
2. A virus manipulates a program to execute casks unintentionally.
3. An infected program produces more viruses.
4. An infected program may run without error for a long time.
5. Viruses can modify chem.selves and may possibly escape detection this way.

4.7 Trojan Horses and Backdoors.

Trojan Horse is a program in which malicious or harmful code is contained inside apparently harmless programming or data in such a way that it can get control and cause harm, for example, ruining che file allocation table on che hard disk. A Trojan Horse may get widely redistributed as part of a computer virns.'2[21] The term Trojan Horse comes &om Greek mythology about the Trojan War (see Box 4.5).

Box 4.5 Trojan War

The Trojan Horse is o tole from the Trojan War, as told in Virgil's Latin epic poem *The Aeneid* Quintus of Smyrna. The events in this story from the Bronze Age took place ofter Homer's *Iliad* and before his *Odyssey*. It was the stratagem that allowed the Greeks finally to enter the city of Troy and end the conflict. In the best-known version, after o fruitless 10-yeor siege, the Greeks construct a huge wooden horse in an attempt to once and for all destroy Troy from the inside. According to Quintus, it was Odysseus who cameup with the idea of building a great wooden horse in which 30men could hide lo be wheeled into the city without the Trojans knowing. The Greeks build a huge, magnificent wooden horse in 3 days_under the leadership of Epeios. Odysseus' plan also calls for one man to remain outside or the horse. This man will act as though the Greeks abandoned him, leaving the horse as a gift for the Trojans. The Greeks chose their soldier Sinon to play this role, as he is the only volunteer. Virgil describes the actual encounter between Sinon and the Trojans; Sinon successfully convinces the Trojans that he hos been left behind and the Greeks are gone, and thehorse is wheeled inside the city walls asa victory trophy. That night, the Greek soldiershidden inside the horse emerged and opened the city gates for lhe rest of the Greek army. They raid and destroy the city of Troy, finally ending the Trojan War.

Sovrce: http://en.wikipedia.org/wiki/Trojon_Horse (11 January 10).

Like Spyware and Adware, Trojans can geL into Lhe system in a number of ways, including from a web browser, via E-Mail or in a bundle wich ocher sofuvare downloaded from the Internet. It is also possible to inadverrendy cransfer malwarc Lhrough a USB flash drive or other portable media. Ir is possible rhar one could be forced to reformat USB flash drive or other portable device co eliminate infection and avoid trans- ferring it Lo ocher machines. (Users would noc know that these coLJd infect their network while bringing some music along with chem co be downloaded.)

Unlike viruses or worms, Trojans do nor replicate themselves bur they can be equally descructive. On chc surfocc, TroJans ,1ppear benign and harmless, but once the infecred code is executed, Trojans kick in and perform malicious functions ro harm the computer system without the user's knowledge.

For example, waterfalls.scr is a waterfall screen saver as originally claimed by the author; however, it can be associated with malware and become a Trojan ro unload hidden programs and allow unauthorized access to the user's PC.

Visit http://en.wikipedia.org/wiki/Lisr_of_crojan_horses to ger rhe list of noteworthy Trojan Horses. Some typical examples of thrcacs by Trojans[lJI are as follows:

J. They era..\e, over.vrite or corrupt data on a computer.
2. They help LO l>pread other malware such as viruses (by a dropper Trojan).
3. They deactivate or inrerfere with anrivirus and firew:ill programs.
4. 11,ey allow remote access to your computer (by a remote access Trojan).
5. ·1hey upload and download file without your knowledge.
6. 1hcy gather E-Mail addresses and use chem for Spam.
7. 'niey log ki::ysrrokes to sccal information such as p:tsswor<ls and crcdir card numbers.
8. 'll1ey copy fake links Lo false websiLes, display porno sires, play ounds/videos and display images.
9. They \low down, rcsrarr or shuLdown the system.
10. 11,cy reinstall rhemselves after being disabled.
11. They disable the ra k manager.
12. They Jis:1bli: rhc control panel.

4.7.1 Backdoor

A b,1cl<door i a mean:, of .iccess to a computer program rhar bypasses security mechanisms. A programmer may somcrimes inst,1ll J backdoor *so* char the program can be accessed for rroubleshooring or other purposes. I lowevcr, altackcrs often u:.e backdoors chat rhey derecr or install themselves as part of an exploit. In some 1:.tsc , a worm is designed m cake advanrage of a backdoor created by an earlier arcack[1241]

A back<loor worb in background and hides from Ll,e user. It is very similar ro a virus and, therefore, is tJuin:difficult to detect and completely disable. A backdoor is one of the most dangerous parasite, as it allows .t m,1liciou:, person rn perform any possible action on a comprombed system. Mose backdoors are autonomic malicious programs tbat musr be somehow installed ro a computer. Some parasites do not require installa- tion as their pan!. .ire already integrated inco particular software running on a remote hosr. Programmers ,omcrime leave uch backdoors in their sofrv.:are for diagnostics and rroublcshooring purpmes. Attackers often discover these undocun1cnced foacures and use them to intrude into rhesysrem.

What a Backdoor Does?

Following are some functions ofbackdoor[1251]:

1. It ,Jlow, an auacker to creare, dcleLe, rename, copy or edir any file, execute various commands; ch,ingc: ,tny system sctrings; alter Lhc Windows registry; run, control and rerminare applicacions; inscall arbitrary sofrwarc and parasites.

2. Jr allows an atracker co control compurer hardware devices, modify rclared setrings, shurdown or resrarc a computer without asking for user permission (see Section 7.13.7, Chapter 7).
3. le steals sensitive personal information, valuable documents, passwords, login names, 10 derails; logs user activiry and cracks web browsing habits.
4. lr records keyscrokes char a user rypes on a computer's keyboard and captures screenshocs.
5. Ir sends all gathered data co a predefined E-Mail address, uploads ir co a predetermined ITP server or transfers it through a background lncernec connection co a remote host.
6. 1t infects files, corrupts installed applications and damages the enrire system.
7. Jr distribures infected files co remore computers with certain security vulnerabilities and performs arcacks against hacker-defined remote hosrs.
8. Jc installs hidden ITP server rhar can be used by malicious persons for various illegal purposes.
9. Jc degrades Internet connection speed and overall system performance, decreases system security and causes software instability. Some parasites are badJy programmed as they waste roo many computer resources and conflict with installed applications.
10. le provides no uninscall feature, and hides processes, files and other objecrs co complicare ics removal as much as possible.

Following are a few examples ofbackdoor Trojans:

1. Back Orifice: le is a well-known example of backdoor Trojan designed for remote system adminis-rrarion. It enables a user co control a com purer running che Microsoft Windows OS from a remote location. 'TI,e name b a word play on Microsoft BackOffice Server software. Readers may visit hrrp://www.culcdeadcow.com/rools/bo.hrml ro know more about backdoor.
2. Bifrosr: lt is another backdoor Trojan char can infect Windows 95 through Vista. It uses rhe typicaJ server,crver builder :u1d client backdoor program configuration to allow a remote attacker, who uses client, ro execute arbitrary code on the compromi. cd machine.
3. SAP backdoors[1261]: SAP is an Emerprise Re ource Planning (ERP) *system* and nowadays ERP is the heart of che business cechnologicaJ platform. These systems handle the key business processes of the organizari()n, such as procurement, invoicing, human resources management, billing, stock management and financial planning. Backdoors can prescm into SAP User Master 1hat supporrs an authentication mechanism when a user connects to access SAP and ASAP Program Modules which suppon SAP Business Objects.
4. Onapsis Bizploit: It is the open-source ERP penetration testing framework developed by the Onapsis Research Labs. Bizploit assists security professionals in che discovery, exploration, vulner-ability assessmem and exploitation phases of specialized ERP penetrarion rests. Readers may visir hrrp://ww,,v.onapsis.com/research.hrml co know more abour chis cool.

4.7.2 How to Protect from Trojan Horses and Backdoors

Follow the following steps co protect your systems from Trojan Horses and backdoors:

1. Stay away from suspect websites/webBnks: Avoid downloading free/pi raced softwares that often gee infected by Trojans, worms, viruses and other things. We have addressed "how ro determine a legitimate website" in Chapter 5.
2. Surf on the Web cautiously: Avoid connecting with and/or downloading any information from peer-co-peer (P2P) necv,orks, which are mosr dangerous networks ro spread Trojan Horses and 0tJ1cr threats. P2P networks crcare files packed with maliciow, softwart:, and then rename chem ro fiJcs wich rhe criteria of common seard1 Lhac are used while surfing rhe informarion on the Web.

(See Box 4.6 to know more on P2P networks.) le may be experienced chat, after downloading the file, il never works and here is a chreal that - alchough the file has nor worked, something musr have happened co the system - the malicious software deploys irs gizmos and rhe *sys*rem is at serious healrh risk. Enabling Spam filter "ON" is a good practice but is not I 00% foolproof. asspammers are consranrly developing new ways co gee through such filters.

3. Install antivirus/Trojan remover software: Nowadays antivirus sofrware(s) have built-in feature for protecting che system nor only from viruses and worms but also from malware such as Trojan Horses. Free Trojan remover programs are al o available on the Web and some of them are really good.

Box 4.6 Peer-to-Peer (P2P) Networks

Peer-to-peer. commonly abbreviated as P2P. is any distributed network architecture composed or participants that make a portion of theirresources (such as processing power. disk storage *or* network bandwidth) directly available to other network participants. without the need for central coordino-llon inslances (such asservers *or* sloble hosts). Peers are both suppliers and consumers of resources. in contrast lo the trod1tionol client-server model where only servers supply and clients consume.'2[71] There are different levels of P2P networking[1281]:

1. Hybrid **P2P:** There is a central server that keeps information about the network. The peers ore responsible for storing the information. If they wont lo contact another peer. they query the server for the address.
2. **Pure P2P:** There is absolutely no central server or router. Each peer acts as both client and server at the some lime. This is also sometimes referred lo as "serverless" P2P.
3. **Mixed P2P:** Il is between "hybrid" and "pure" P2P networks. An example of such a network is Gnutello that hos no central server but clusters its nodes around so-called "supernodes."

Advantages of P2P Networks

1. Il enables foster delivery ot information from one computer to another by bypassing a central server.
2. It increases personal efficiency and personal empowerment. Users will no longer hove to wait in queues to perform essential tasks. as all activities toke place at the user'sdiscretion.
3. Il represents significant cost soving.s over client/server models. As resources and computing power are distributed across the entire network. there is no need for expensive centralized serv-ers: this will reduce the need for centralized management. storage and other related resources.
4. It offers easy scalability and all that is necessary for a network to grow is odd more peers.
5. It increasesa network's fault tolerance. As no port of the system is essential to its operation. you con toke down a few nodes and the network remains functional.
6. It leverages previously unused resources found on hundreds of millions of computers (and other services) that ore connected to the "edges" of the Internet.
7. Il freesup bandwidth on the Internet (or on a private network). In traditional client-servermodel. the server is the bottleneck and often cannot handle everything the client requests.
8. It requires no centralized management. oversight *or* control.
9. Il offers Increased privacy, as all data and messages are directly exchange between two computers.
10. Il results in networks that are more flexible and adoptable compared with traditional client-server networks.

Besides all these advantages, there ore still many reasons why P2P might not be the right model and is used only for specific set of activities.

Box 4.6 Peer-to-Peer ... *(Continued)*

Drawbacks of P2P Networks

1. It propagates all sorts of undesirable items and ac1ivities including misinformation.
2. It increases network's. on indivicluai system's. exposure lo network atl·acks, viruses and other malicious damage.
3. 11'makes no guarantee 1ha1content/resources will always be available - any peer can go ·'dark" if he/she shuts down his/her computer.
4. Il does not enforce content ownership (copyright).
5. It cannot enforce slandards (either technological or ethicol/moral/socialj.
6. It can be overwhelmed by increased traffic when it is unprepared (Nopster uses many clogged university networks).
7. It is plagued by lack or standards, infras1ructure and supporl. Il is a kind of "Wild West" of the Internet.
8. Its transactions are difficult to transla1'e into revenues streams and this lack or revenue generation could hinder its future development.

Ares, BilTorrent, Limewlre and Kazaa are a few examples of popular P2P file-sharing programs. Readers may visit http;//www.bestsecuritytips.com/xfsection+article.articleid+49.htm 1o know more on these popular P2P file-sharing programs.

Source: www.bus.ucf.edu/leigh/isrn5937/1inked/Ledesrno_J.doc (I 7 May 2010).

4.8 Steganography

Sceganography is a Greek word chac means ·'shelrcrcd wriring." l.t is a med1od tha1 attemprs co hide rhe exisrence of a message or communication. The word "steganography" comes from the two Greek words: sceganos meaning "covered" and graphcin meaning "rn write" cha1 means "concealed writing." "ll1is idea of darn hiding is nor a novclry; ir has been used for centuries all across the world under differenr regimes. 17,e pracrice dates back co :111ciem Rome a11d Greece where rhe messages were etched inco wooden mblcrs a.nd then cove.red with wax or when messages were passed by shaving a messenger's head :ind rhen carcooing a secrcr message on ir, lening his hair grow back and rhen shaving ir again afrer he arrived at rhe receiving party to reveal the message.

Given the sheer volume of data stored and transmitted electronically in che world today, ir is no surprise rhar coundess methods of pro1ecring such data bave evolved. One bser known bm rapidly growing method is steganography, the arr and Kienet:: of hiding informarion so rhar ir docs nor even appear ro exist! Sreganography is always misunderstood wid1 crypcography (see Box 4.7 to know difference berwecn rhese rwo cech.niques). The different names for sreganography are data hiding, information hiding (explained in Section 7.12.2, Chapter 7) and digital watermarking.

For example, i.n a digital image rhe least significam bit of each word can be used LO comprise a message without causing anyigni1ica□r change in the image. Sreganography can be used to make a digital watermark to detect illegal copying of digital images. 1hus, ir aids confidentiality and integriry of the data. *Digital watermarking* is the process of possibly irreversibly embedding information inco a digital signal. TI1e signal may be, for example, audio, pictures or video. If the signal is copied rhen the information is also carn·ed ·rn ·m-e copy-.[JI]

Box 4.7 Difference between Steganography and Cryptography

Stegonography is the ort and science of writing hidden messages in such a way that no one apart from the in1ended recipient knows the existence of the message: this is in contrast to cryptography, where the existence of the messa ge itself is not disguised, but the content is obscured. II is said 1hot terrorists use stegonography techniques to hide their communication in images on the Internet; mosf popular images ore used such as those of film actresses or other celebrities. In its basic form, steganography Is simple. For example, soy every fourth letter of o memo could hide o message. This simple technique hos on added advantage over encryption that ii does not arouse suspicion, that is, there is not much scope for getting storied on investigation! Presence of on encryption could set off on investigation. but a message hidden in plain sight would get ignored (see Box 7.13, Chapter 7).

In October 2001, the New York Times published on article claiming that al-Qaeda had used steganographic techniques to encode messages into images, and then transported these via E-Mail and possibly via Usenet to prepare and execute the l l September 2001 Terrorist Attack.[1301]

The term "cover" or "cover mediwn" is used to describe the original, innocent message, data, audio, sciD, video and so on. le is rhe medium rhar hides rhe secret message (see Fig. 4.4). Ir muse have pares char can be altered or used without damaging or noticeably changing rhe cover media. If the cover media are digital, these alterable parts are called "redw1danr bits." These bits or a subset can be replaced with the message char is intended co be bidden. Interestingly, steganography in digital media is very similar ro "digital water- marking." In ocher words, when sceganography is used co place a hidden "trademark" in images, music and software, rhe result is a technique referred co as "watermarking" (see Table 4.10 co know more abour sreg- anography cools).

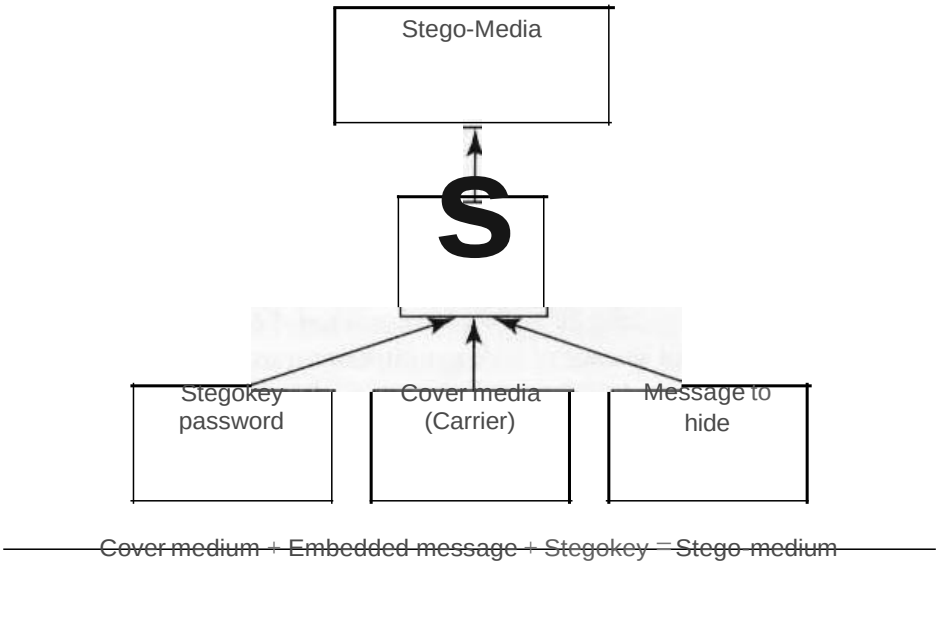


Figure 4.4 How steganography works.
Source: http://www.cosc.iup.edu/sezekiel/Seminar/steg.ppt#452,15,Steganography%20of%20today's%20talk (11 May 10).

Table 4.10 Steganography tools

ebsite	*Brief Description*
http://www.securityfocus.com	DiSi-Steganograph: It is a very small, DOS-based steganography program that embeds data in PCX images.
http://www.brochcrsofr.com/invisible-foldm-54597.html	Invisible Folders: It has the ability to make any file or folder invisible to anyone using your PC even on a network.
http://www.,,invisibbccrecs.com	Invisible Secrets: It not only encrypts the data and files for safe-keeping or for secure transfer across the Net but also hides them in places such as picture or sound files or webpages. These types of files are a perfect disguise for sensitive information.
http://www.programurl.com/stealth-files.htm	Stealth Files: It hides any type of file in almost any other type of file. Using steganography technique, Stealth Files compresses, encrypts and then hides any type of file inside various types of files (including EXE, DLL, OCX, COM, JPG, GIF, ART, MP3, AVI, WAV, DOC, BMP) and other types of video, image and executable files.
http://www.programurl.com/hermetic-stego.htm	Hermetic Stego: It is a steganography program that allows an encrypt and hide contents of any data file in another file so that the addition of the data.110 The container file will not noticeably change the appearance of them file. This program allows hiding a file of any size in one or more BMP image files with or without the use of a user-specified Stego/encryption key so that,11 (a) the presence of the hidden file is undetectable (even by forensic software mathematically proof method)) and (b) if a use -specified stego key is used then the hidden file can be extracted only by someone, using this software, who knows that stego key.
http://www.securstar.com/products_drivecryptpp.php	DriveCrypt Plus (DCPP): It has following features: • It allows secure hiding of an entire OS inside the free space of another OS. • Full-disk encryption (encrypts parts or 100% of your hard disk including the OS). • Preboot authentication (before the machines boot,, a password is requested to decrypt the disk and start your machine).
http://www.petitcolas.net/fabien/steganography/mp3stego	**MP3Stego:** It hides information in MP3 files during the compression process. The data is first compressed, encrypted and then hidden in the MP3 bit stream.
http://compression.ru/video/stego_video/index_cn.html	MSU StegoVideo: It allow, hiding any file in a video,equem:c. Main features are as follow : • Small video diMortions after hiding information. • It is possible to extract information after video compression. • Information is protected with the password.

St.....ography, SudolJu ""n:le. and SM.S: It is o revised version of information hiding (i.e.. steganogr()J;'.)t\'y) wsirtg Si.Jdohi puitle. This methodolo y was proposed by Chang et 01. during 2008. which was Inspired by Zhong and Wong's method and Sudoku solutions. Sudoku game hos gained popularity recently and SMS is o popular medium of communication nowadays - messages ore concealed Into Suduko pwz,tle:, whlCh or.e tt')eru::iommunicoted to Intended recipient 1hrough SMS. As. soon os recipient solves the puzzle, he/she can ex!roct the ctoto hldden into Sudoko pl./zzle image.

4.8.1 Steganalysis

Sceganalysis is the an and science of detecting messages char are hidden in images, audio/video files using sceganography. lhe goal of sreganalysis is to identi , suspected packages and ro determine whether or nor rhey have a payload encoded into them, and if possible recover ic. Aucomaced tools are used to dececr such srcganographed data/information hidden in the image and audio and/or video files (seeTable 4.11 for more derails).

4.9 DoS and DDoS Attacks

A denial-of-service attack (DoS attack) or djscribuced denial-of-service attack (DDoS attack) is an acrempr co make a computer resource (i.e., information systems) unavailable co its intended users.

4.9.1 DoS Attacks

Tn chis rype of criminal act, the attacker Ao.o<ls rhe bandwidth of rhe victim's network or fills his E-Mail box with Spam *mail* depriving him of the services be is entitled co access or provide. Although the means ro carry our, motives for, and targets of a DoS arrack may va_f)', it generally consisrs of che concened efforts of a person or people co prevent the Inrerner sire or service from functioning efficiently or at all, temporarily or indefinitely. The attackers typically target sires or services hosted on l1igh-profile web servers such as banks, credit card payment gateways, mobile phone networks and even rooc name servers (i.e., domain name

Table 4.11 Steganalysis tools

Website	*Brief Description*
hrtp://w,.vw.sarc-wv.com/producrs/srcgalyzeras.aspx	StegAlyzerAS: It is a digital Forensic analysis tool designed ro scan "suspect media" or "forensic images" of suspect media for known arcifuccs of sceganography applicnions.
http://www.sarc-wv.com/stegalyzerss.aspx	**StegAlyierSS:** It *is* a digical fon:nsic analysi.s cool designed to scan "suspect media" or "forensic images" of suspect media for uniquely idenclliable hexadecimal byre p:trtems, or known signatures. lefc inside fik8 when particular sreganography applicarions are used to embed hidden information within tl1em.
Imp://www.spy-huntcr.com/sregspy download.hrm	StegSpy: Ir is :t program th:it is always in progress and Lhe lacesr version includes idencification of a "sreganized" file. Ir dcteccs sreganography and the program used co hide rhc message. The laresc version also idenrifie. the location of the hidden conrenc as well. SregSpy identifies programs such as Hiderman, JPHidcandSeek, Masker, JPegX and Invisible Secret .
htrp://www.outguess.org/decection.php	Stegderecc: It is ai1 amomated tool for detecting sreganographic coocenr in the images. It is c.apable of dececcing several diffc.rcnr steganographic methods ro embed hidden in_formarion in JPEG images.
http://stegsccret.sourceforge.ner	Stegsecret: It is a sreganalysis open-source projecr that makes detection nfhidden infom,acion possible ii1 different digital media. It is a JAVA-based rnultiplacform srcganalysis rool that allows che decea:ion of hidden information by LL';ing che most known sceganogmphic methods.
Imp:!/sourcefo(ge.nec/ projects/vsl	Virtual Steganographic Laboratory (VSL): Ir is a graphical block diagramming cool char allows complex using, testing and adjuscing of methods both for image sccganography and steganalysis.

servers). Buffer overflow technique i.s employed ro commit such kind of criminal attack known as *Spoofing*. 1 he cerm IP address Spoofing refers ro the creation of IP packets with a forged (spoofed) source CP address with the purpose of concealing the [0 of the sender or impersonating another computing system. A packet is a formatted unit of darn carried by a packet mode computer nerwork. 111e attacker spoofs the IP address and floods the network of rbe victim with repeated requests. As the IP address is fake, the victim machine keeps waiting for response from the attacker's m:tchine for each request. 111is consumes the bandwidth of the network which then fails co serve che legitimate requests and ultimately breaks down.

l he Unired Scates Compu rer Emergency Response Team defines symptoms of DoS atrack. co include:

1. Unusually slow network performance (opening files or accessing websites);
2. unavailability of a particular website;
3. inability to access any website;
4. dramatic increase in the number of Spam E-Mails received (this rype of DoS attack is termed as an E-Mail bomb).

111e goal of DoS is not to gain unauchori7,ed access ro systems or data, bur co prevent intended users (i.e., legitimate users) of a service from using it. A DoS attack may do the following:

l. Flood a network with traffic, thereby prevenring legitimate network traffic.
2. Disrupt connections between n,vo systems, thereby preventing access co a service.
3. Prevent a particular individual from accessing a service.
4. Disrupt service co a specific system or person.

4.9.2 Classification of DoS Attacks

See Table 4.12 for classihcation of DoS attacks.

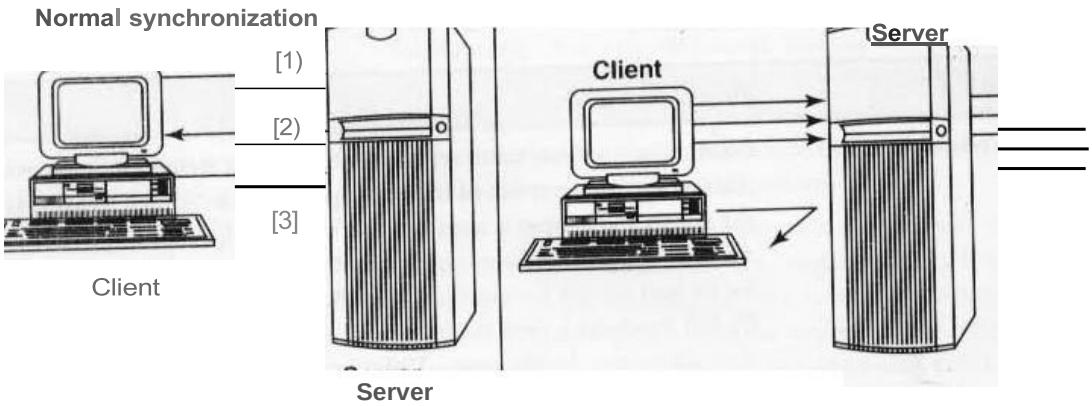
Table 4.12 | Classification of DoS attacks

Sr. No.	*DoS Attacks*	*Brief Description*
	Bandwjdch arcacks	Loading any website takes certain time. Loading means complece webpage (i.e., with entire comenc of the webpage - rexr along with images) appearing on the screen and system is awaiting user's input. This "loading" consumes some amoum of memory. Every site is given with a particular amount of ba.ndwidth for ics hosdng, say for example, 50 GB. Now if more visitors con, ume all 50 GB bandwidth then the hosting of che site can ban chis *site*.1he attacker does the same- he/she opens 100 pages of a sire and keeps on refreshing and consuming all the bandwidth, thus, the site becomes out of service.
2	Logic accacks	These kind of attacks can exploit vulnerabilities in network software such as web server or TCP/IP stack.
3	Prorocol attacks	Prorocols here are rules chat are co be followed to send data over network. 1hese kind of attacks exploit a specific fearure or implementation bug of some protocol installed at the victi.m's system to conswne excess amounts of its resources.
4	Unintentional DoS attack	1his is a scenario where a website ends up denied nor due co a delibemte attack by a single individual or group of individuals, bur simply due co a sudden enormous spike in popularity. lhis can happen when an extreme.ly popular websire posts a prominent link to a second, less well-prepared sice, for example, as part of a news scory. The result is that a significant proportion of the primary sites regular users', potentially hundreds of thousands of people, dick that link within a Few hou.rs and have the same effecc on the target website as a DDoS attack.

4.9.3 Types or Levels of DoS Attacks

There are several types or levels of Do$ arracks as follows:

1. Flood attack: This is che earliest form of DoS attack and is also known as *ping flood.* Ir is based on an artacker simply sending the victim overwhelming number of ping packers, usually by using rhe "ping" command, which resulr into more traffic than the victim can handle. This requires the arracker to have a faster nerwork connection than the victim **{i.e.,** access co greater bandwidth rhan the victim). It is very simple to launch, but co prevent ic completely is rhe most difficult.
2. Ping of death attack: The ping of death arrack sends oversized lncernet Conrrol Message Prorocol (ICMP) packers, and ir is one of rhe core protocols of the IP Suite. It is mainly used by networked computers' *OSs* to send error messages indicating (e.g., char a requested service is not avail:lble or that a host or router could nor be reached) datagrams (encapsulated in IP packers) co rhe victim. 'fne maximum packet size allowed is of 65,536 octets. Some systems, upon receiving the oversized packet, will crash, freeze or reboot, resulting in DoS (e.g., che ping of death arrack relied on a bug in the Berkeley TCP/IP stack, which also existed on mosr sysrcms that copied the Berkeley network code).
3. SYN attack: le is also termed as *TCP SYN Flooding.* In rhe Transmission Conrrol Prorocol (TCP), handshaking of nc:rwork connections is done wirh SYN and ACK messages. A11 arracker initiates a TCP connection co rhc server with an SYN (using a legitimate or spoofed source address). The server replieb wirh an SYN-ACK. The dienc then does not send back an ACK, causing the server (i.e., cargcr system) co allocate memory for rhe pending connection and wait. This fills up the buffer space for SYN messages on che cargcc 5yscem, prevencing orher systems on 1he network from com municaling with the target sy tem. Figure 4.5 explains how rhe DoS auack rakes place.



3-way Handshake

- Ghent sends synchronize (syn) pkt to web server
- Server sends synchronize acknowledgment (syn-ack)
- Client replies with an acknowledgment pkt, the connect is established

Chaotic Handshake

- Client sends multiple synchronize (syn) pkts to web server - all with bad addresses
- Server sends synchronize acknowledgments to in correct addresses leaving half open connections and flooded queue
- Legitimate user is denied access because queue is Full and additional connections cannot be accepted

Figure 4.5 Denial-of-service (DoS) attack.

4. Teardrop attack-:11,e teardrop attack is an attack where fragmented packers are forged cooverlap each other when che receiving hosr tries ıo reassemble chem. !P's packer fragmentation algorithm is used co send corrupred packers to confuse che victim and may hang che system. This arrack can cr.i h various 05s due co a bug in their TCP/IP fragmentation reassembly code. Windows 3.1x, Windows 95 and Windows NT *OSs* as well as versions of Linux (i.e., prior to versions 2.0.32 and 2.1.63) are vulnerable co rhis attack.[1311]
5. Smurf attack: Ir is a way of generating significant computer network traffic on a victim network. This is a type of DoS arrack char Aoods a target system via spoofed broadcasr ping messages. This arrack consiscs of a hose sending an ICMP echo request (ping) to a network broadcast address (e.g., necwork addresses with the host portion of the address having all ls). Every hosr on the network receives the JCMP echo request and sends back an JCMP echo response inundating the initiator with network rraffic. On a multi-access broadcast network, hundreds of machines might reply to each packet. 11-tis creates a magnified DoS attack of ping replies, Aooding rhe primary victim. Internee relay chat ([RC) servers are rhe primary victim of smurf attacks on the lnrernet [(!RC is a form of real-time lncerncl text messaging (chat) or synchronous conferencing)].
6. Nuke: Nuke[1321] is an old DoS attack against computer networks consisting of fragmented or otherwise invalid ICMP packecs senr to the target. h is achieved by using a modified ping utility to repeatedly send this corrupt data, thus slowing down the affected computer until it comes to a complete stop. A specific example of a nuke attack chat gained some prominence is the WinNuke, which exploited che vulnerabilicy in che NetBIOS handler in Windows 95. A sering of our-of-band dara was senc co TCP port I39 of che victim's machine, causing ic co lock up and display a Blue Screen of Death (BSOD).

4.9.4 Tools Used to Launch DoS Attack

Various rools (see lable 4.13) use differenr lypes of traffic co Aood a victim, but 1.hc objective behind the arrack and the result is the san1c: A service on chc system or che entire system (i.e., application/website/network) is w1available to a user because it is kepr husy trying lo responJ ro an cxorbicanl number of requests. A DoS attack *is* usually an arrack of lasr rcson because ic is considered co be an unsophislicaced attack as che arracker does nor gain access co any information but rather annoys the target and interrupts the service. (See Box 4.8 co know more about blended threats and Box 4.9 for PDoS arcacks.)

Table 4.13 Tools used to launch DoS attack

Sr. No.	*Tool*	*Brief D scripti<>n*
	Jo112	A major vulnerability bas hccn discovt:rcd in Windows' networking code. The vulnerability allows remorc atlackers ro cause a DoS arrack againsr Windows-based machines - me :lllack came thecarger machine 10 consume 100% of the CPU time on processing of illegal packers.
l.	Ncmesy	This program generates random packets of spoofed source IP ro enable the arrackcr ro launch DoS attack.
3	'J:irg;i	Ir is a program 1hat can be used co run eighccliffcrenr DoS acracks. Ihe arcackcr has rhe option co law1ch either individual a1cacks or 1ry all rhc anacks un1il one is successful.
4	*Cra1y* Pinger	This tool could send large packets of ICMP to .1 remote target nerwork.
5	SomeTrouble	It is a remote Hoocler and bomber. It is developed in Dclphj,

Box 4.8 Blended Threat

Blended threol is a more sophisticated attack fhot bundles some or the worst aspects of viruses. worms, Trojan Horses and Malicious Code into one single threat. Blended threats con use server and Inter nel vulnerabilities to initiate, transmil and thereofler spread an ollor:k. Characteristics of blended threats ore lhot

1. They cause harm to the infected system or network.
2. They propagate using multiple methodsas attack maycome from multiple points.
3. They also exploit vulnerabilities.

To be considered o blended t·hreat, the attack would normally serve to transport multiple oltocks in one payload. For example. ii would not only just launch a DoS attack but it would also, for example, install o bockdoor and maybe even damage a local system in one shot. Additionally, blended threats ore designed to use multiple modes of transport. Therefore, while o worm may travel and spread through E-Mail, a single blended threol could use multiple routes including E-Mail, IRC and file-shoring networks.

Finally. rolher than a specific attack on predetermined ".exe" files, o blended threat could do multiple malicious acts, such as modify your ".exe" files, HTML files and registry keys al the some time - basically ii con cause damage to several areas of your network at one lime.

Blended threats ore considered lo be the worst risk to security since lhe inception of viruses, as mosl blended tl1reals require no human intervention to propagate.

Source. http://www.webopedio.com/didyouknow/internet/2004/virvs.osp(11 Jonuory 2010).

Box 4.9 Permanent Denial-of-Service (PDoS) Attack

A PDoS attack damages a system so badly that ii requires replacement or reinstollotion of hardware. Unlike DDoS allack - which is used to sobologe a service or website or as a cover for molwore delivery - PDoS is o pure hardware sabotage. II exploits security flows that allow remote administration on the management interfaces of the victim's hardware. such as routers, printers or other networking hardware. The attacker uses these vulnerabilities to replace a device's firmware with a modified, corrupt or defective firmware image - a process which when done legitimately is known as *noshing.* Owing to these features. and the potential and high probability of security exploits on network-enabled-embedded devices (NEEDs), this technique hos come lo the attention of numerous hocker communities. PhlashDonce is o tool creeled by Rich Smith (on employee of Hewlett-Packard's Systems Security Lob) who detected and demonstrated PDoS vulnerabilities at the 2008 EUSecWest Applied Securlly Conference ln London.

Source. ttttp://en wilcipedio.org/wrki/Deniol-of-service_ottoclc (I I Moy 2010).

4.9.5 DDoS Attacks

In a DDoS attack, an accacker may use YOlLr compucer co arrack anocher compmcr. By raking advantage of ccuricy vulnerabiliries or weaknesses, an attacker could take control of your computer. He/she could then force your computer co send huge a.mounts of data co a website or send Spam co parcicular E-Mail addresses. lhe accack is "distributed" because rhe attacker is using multiple computers, including yours, co launch the OoS artack.

A DDoS arrack is a distribured DoS wherein a large number of zombie systems are synchronized coarrack a particular system. The zombie systems (as explained in Chapter I) arc called "secondary victims" and the main rarget is called "primary victim."

Table 4.14 Tools used to launch DDoS attack

Sr. No.	Tool	Brief Description
	Trinoo	le is a set of compurer programs rn conducr a DDoS attack. It is believed that Trinoo networks have b.:en set up on 1housands of systems on thr lmernec cha1 have been compromised by remote buffer overrun exploit.
2	Tribe Flood Network (TFN)	Ir is a sec of compucer programs ro conduct variOLL DDoS arcacks such as ICMP flood, SYN Aood, UDP Aoocl and Smu rf arrack.
3	Stachddrahc	IL *is* wrircen by Random for Linux and Solaris systems, which acts as a DDoS agent. le combines features ofTrinoo with TFN and adds c.ncryprion.
4	Shafr	l11is network looks conceptually similar to a''lrinoo; it is a packet Hooding attack and the client controls the size of che Hooding packers and duration of che attack.
5	MStream	Tr uses spoofed TCP packers with the ACK Aagset ro accack the carget. Communicarion is nm encrypted and *is* performed through TCP and VDP packet . Access rn the handler is password prorecred. This program has a feature not found in ocher DDoS rools. le informs all connected users of access, successful or not, co the handlcr(s) by compedng parties.

Malware can carry DDoS attack mechanisms - one of the bccrer-known examples of this is MyDoom. 1ypically, DoS mecha11ism triggered on a specific dare and time. 11,is type of DDoS artacks involves hardcoding the target IP address prior to release of the malware, hence no further interaction is necessary to lallllch the attack. A system may also be compromised wirb a Trojan, allowing the attacker ro download a zombie agent. Nowadays, Bomer (as explained in Chapter 2) is the popular 111edilll11 co launch DoS/DDoS attacks. Attackers can also break into systems using automated cools (secTable 4.14) mat exploit Aaws in programs that listen for connections &om remote hosts.

4.9.6 How to Protect from DoS/DDoS Attacks

Computer Emergency Response Team Coordination Center (CERT/CC) offers many preventive measures from being a victim of DoS arcack.[1331]

1. Implement router filters. This will lessen your exposure ro certain DoS anacks.
2. ff such 61ters are available for your system, install parches to guard agai11Sc TCP SYN flooding.
3. Disable any unused or inessential network service. This can limit the abiliry of an attacker co cake advanrage of these services to execute a DoS arrack.
4. Enable quota systems on yout OS if they are available.
5. Observe your system's performance and establish baselines for ordinary activity. Use the baseline ro gauge unusual levels of disk activity, cenrral processing unit (CPU) usage or nerwork traffic.
6. Routinely examine your physical securiry with regard co your current needs.
7. Use Tripwire or a similar wol co detect changes in configuration information or other 61es (see Table 4.15).
8. Invest in and maintain "hor spares" - machines char can be placed into service quickly if a similar machine is disabled.
9. Invest in redundanr and fault-tolerant network configurations.
10. Establish and mainrain regular backup scheduJes and policies, particularly for important configuration informadon.
11. Establish and mainrain appropriate pasS\vord policies, especially access to highly privileged accounts such as Unix root or Microsoft Windows NT Administraror.

Table 4.15 | Tools for detecting DoS/DDoS attacks

No.	Tool	Brief Description
	Zombie Zapper	It is a free, open-source rool rha1 can tell a wmbie system Aooding packers co scop Aooding. Ir works againsc Trinoo, TFN and Sracheldrahr. Jr assumes various defaults are still in place used by these arrack cools, however, it allows you to put the zombies to sleep.
2	Remote Intrusion Deteccor (RID)	It is a tool developed in "C" computer language, which is a highly configurable packet snooper and generator. It works by sending our packecs defined in rhe config.rxt file, then listening for appropriate replies. Ir detects che presence of Trinoo, TFN or Srachddrahc cliencs.
3	Securiry Audicor's Research Assiscanc (SARA)	Ir gathers information abour remote hoses and nerworks by examining nerv.,ork ervices. This includes information about the necwork information services as well as potential securiry flaws such as incorrectly set up or configured network services, well-known bugs in the sysrem or network utilities *system* software vulnerabilities listed in the Common Vulnerabilities and Exposures (CVE) database and weak policy decisions.
4	Find_DDoS	It *is* a tool that scans a local sysrem that likely contains a DDoS program. It can detect several known DoS attack tools.
5	ODoSPing	It is a remote network scanner for the most common DDoS programs. It can detect Trinoo, Scacheldraht and Tribe Flood Network programs running with 1heir default settings.

Compvlet Emer:9.ency Re ponse _!eorp.Coqrqino1ionCenter (CERT/CC} was started in December 1988 by1he Defense Advof\ted :esear.ch Projects·AgenCy;whichWosport ¢f theUS t)epQrt'mer,t Qt Defense. ofter the Morris Worm disabled ooout 10% of all computers connected to the Internet. It is located at th Softw6re 'Ehg11'.leeri'ng 1ristiti:Jte,,a fe/11erolly. fun¢jecl research. c nter o,per.oteq by Carnegie Mellon Universily. It stvdies Internet security vulneroblllities and provides servlces to websites thol h'ove been attacked. It ols.opublishes sec;uri.tv:,olet;ts'. ,,i.

Sovrce: http://WWW.WeQOpedki.com/TERM/C/CERTCC.hfml 131 Moy 20 I0).

4.10 SOL Injection

Scructurecl Query Language (SQ L) is a Jarabase computer language designed for managing data in relational darnbase managemenc systems (RDBMS). SQL injection is a code injeccion cechnique chat exploits a security vulnerability occurring in the darnbase layer of an aµplication.'n1e vulnerabiliry is present when user input is either filtered incorrectly for string literal escape characrers embedded in SQL sratemenrs or user inpuc is not strongly typed and thereby unexpectedly execured. le is an instance ot a more general class of vulnerabilities rhat can occur whenever one programming or scrtring language is embedded inside another. SQL injection attack.,, are also knov,rn as SQL insenion auacks.l.l·l

Attackers rargec the SQL servers - common database servers used by many organizations to score confidenti.tl data.·n1c prime objective behind SQL injection attack is ro obr:iin rhe informarioo while acccs1-ing a database table thac may contain personal informacion such as credir card numbers, social secu• riry numbers or passwords. During an SQL injection actack, Malicious Code is inserted into a web form

field or che website's code ro make a system execute a command shell or ocher arbitrary commands. Just as a legiclmate user enters queries and addicions ro the SQL database via a web form, the attacker can insert commands to the SQL server through rhe same web form field. For example, an arbitrary command from an acracker might open a command prompt or display a table from the database. This makes an SQL server a Mgh-value carger and therefore a system seems to be very attractive ro attackers.

111e attacker determines whether a darabase and the cables residing into it are vulnerable, before launching an arrack. Many webpages cake parameters from web user and make SQL query ro the database. For example, when a user logs in with username and password, an SQL query is sent ro the database to check if a user has valid name and password. With SQL injection, it is possible for an acracker co send crafted username and/or password field chat will change the SQL query.

4.10.1 Steps for SOL Injection Attack

Following are some seeps for SQL injection accack:

1. The arrack.er looks for rhe webpages chat allow submiccing data, char is, login page, search page, feedback, etc. The attacker also looks for the webpages that display the HTML commands such as POST or GET by checking the site's source code.
2. To check rhe source codeof any website, right dick on the webpage and click on "viewsource" (if you are using lE - [ncerner Explorer) - source code is displayed in the notepad. The attacker checks the source code of the HTML, and look for "FORM" rag in the HTML code. Everything between the <FOR.l'vb and </FORM> have potential parameters chat might be useful co find the vulnerabilities.

   <FORM action=Sear-chlsearch.{I.Sp method=post>
   <input type=hidden name=A value=C>
   <IFOR/\1>
3. The anacker inpurs a *single quote* under the rexr box provided on the webpage to accept the username and password. This checks whether the user-input variable is sanitized or interpreted literally by the server. [f the respon e is an error message such as *use 'a"= '11"* (or something similar) then the websire is found to *be* susceptible to an SQL injecrion attack.
4. The atcacker uses SQL commands such as SELECT sracemem command to recrieve data from che database or INSERT statement ro add information to rhe database.

Here are few example of variable field cexc rhe attacker uses on a webpage ro test for SQL vulnerabilities:

J. *Bfah'orl=l--*
2. *LtJgin:b!ah' or l=l--*
3. */>assword::b!.il/ or 1=1-*
4. *http:llsearch/index.asp?id=blah'or /=1-*

Similar SQL commands may allow bypassing of a login and may recurn many rows in a cable or even an emire dacabase cable because the SQL server is interpreting the terms literally. The double dashes near the end of rhe command tell SQL to ignore the rest of tbe command as a comment.

Blind SQL Injection

Blind SQL injeccion[1J[4]l is used when a web application is vulnerable ro ru1 SQL injection but cbe results of rhe injection are nor visible co the attacker.'D1e page with che vulnerabiucy may nor be che one that displays daca; however, it will display differently depending on the results of a logical sratement injected into the legitimate SQL sraremenr called for chat page. This type of arcacl< can become time-intensive because a new scacemem must be crafted for each bir recovered. There a re several cools char can aurom:ite these anacks once the location

ofthe vulnerability and the rargec information have been established. Readers may refer to Ref. #7, Addjtional Useful Web References, Further Reading co know about white paper.

ln summary, using SQL injections, arcackers can:

1. Obcain some basic information if the purpose of the artack is reconnaissance
   - To gee a ilirectory liscing: Blah' ;exec masrer..xp_cmdshell "dfr c:\".* *Is* >c:\direccory.txc";
   - To ping an IP address: Blah' ;exec mascer.. xp_cmdshell "ping 192.168. J. l".
2. May gain access to the database by obraining username and their password
   - To gee a user Llsring: SELECT [1] FROM users WHERE name= "OR '1' = 'l'."
3. Add new daca co rhe dacaba. e
   - Execute the INSERT command: This may enable selling politically incorrect items on an £-Commerce website.
4. Modify daca currently in Lhe database
   - Execute Lhe UPDATE command: May be used co have an expensive item suddenly be deeply "discounrcd."

mySQLenum: It is a command line automatic blind SQL injection tool for web application that uses MySQl server as its back-end. The main objective of this tool is to provide an easy-to-use command line interface. Readers may visit http://pentestit.com/2010/01/15/mysqlenum-automatic-blind-sql-injection-tool/ to know more on this tool.

See Table 4.16 co know some automated cools that are used either co find database vulnerabilities and/or co protecc the dacabase appLlcations.

Table 4.16 Tools used for SOL Server penetration

Sr. No.	Tool	Brief Description
	hccp://www.appsecin .com	**AppDete,ctivePro: le** is a nerwork-based, discovery and vulnerability assessment scanner char discovers database applications within rhe infrascrnccurc and assesses security scrength. Ir locates, examines, reports and fucc. security hole. and misconfigurations as well as identify user rights and privilege levels based on its security methodology and extensive knowledge based on application-level vulnerabilities. Thus, organizarions can harden their database applications.
2	http://www.appsecinc.com	**DbProtect: le** enables organi:t:ations with complex, heterogeneous environments to optimize database securiry, manage risk and bolster regularory compliance. **It** integrates database asset management, vulnerability management, aurut and threat management, policy management, and reporti11g and analytics for a complete enterprise solution.
3	http://www.iss.ner	Database Scanner: It is .UI incegrared part oflmernet Security Systems' (ISS) Dynamic Threat Protection platform that assesses online business risks by identifying security exposures in the database applications. Darabase scanner offers security policy generation and reporting functionality, which instantly measures policy compliance and automates the process of securing critical online business data. Database scanner runs independently of the database and quickly generates derailed reports with all the information needed ro correctly configure and secure databases.

(*Continued*)

Table 4.16 j *(Continued)*

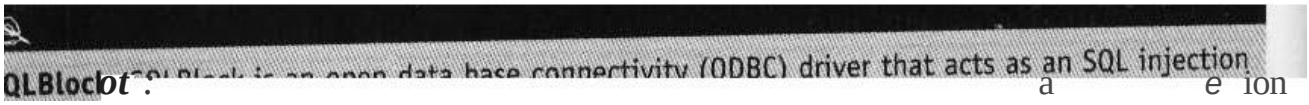
Sr. No.	Tool	Brief Description
4	hrrp://www.ca.com/us/securityadvisor	SQLPoke: IL is an NT-based tool that locates Microsoft SQL (MSSQL) servers and tries LO connect with d,e default Sysrem Adminisrrator (SA) accounc. A list of SQL commands arc executed if rhe connection is successfuJ.
5	http://ww,,v,ng.ssoftw;ue.c.:0111/	NGSSQLCr-ack: h can guard against weak pas wnrds rhat make the network suscepdble co attack. This is a pa.,sword cracking utility for Mjcrosofr SQL server 7 and 2000 and identifies user accoums wirh we,tk pas words so char rhey can be reset wilh stronger ones, thLL, pro1ecring rhe overall incegrity of the system.
6	http://www.security-daLabase.com/ioolswa tch	Microsoft SQL Server Fingerprint (MSSQLFP) Tool:'Jhis is ;i 1001 that performs fingerprindng version OD Microsofr SQL Server 2000, 2005 and 2008, using weH-known techniques based on several public wols char identifies the SQL version aDd also can be used to identify vulnerable versions of Microsofr SQL Server

4.10.2 How to Prevent SQL Injection Attacks

SQL injection accacks occur due co poor website administration and coding. 11,e following steps can be ta.ken to prevent SQL injection.

1. **Lnput vaBdation**
   - Replace all single quotes (escape quotes) to two single quotes.
   - Sanitize the iJ1pur: User input needs LO be checked and cleaned of any characters or srrings rhat could possibly be used maliciously. For example, character sequences such :is ; , -, select, insert and xp_ can be used to perform an SQL injection a[tack.
   - Numeric values should be checked while accepting a query string value. Function - IsNumeric() for Active Server Pages (ASP) should be used to check these numeric values.
   - Keep aLI rext boxes and form fields as short as possible ro limir the length of user inpur.
2. **Modify error reports:** SQL errors should nor be displayed to outside users and ro avoid chis, the developer should handle or configure the error repom very carefully.'Jhese errors some time display full query pointing ro che syntax error involved and rhe attacker can use ir for further attacks.
3. Other preventions
   - The default system accounts for SQL server 2000 should never be: used.
   - Isolate database . erver and web server. Boch should reside on different machines.
   - Mose often attackers may make use of several extended swred procedures such as xp_cmdshell and xp_granclogin in SQL injection attacks. In case such exre1ided scored procedL1Ies are not used or have unused triggers, stored procedures, user-defined funcrions, etc., then these should be moved to an isolaced server.

·n1ese are rhe minimum countermeasures d1at can be iJnplemenred co prevem SQL injection attack. Technocracs may wane co k11ow more on this topic and can go through Refs. #8 and #9, Additional Useful Web References.



4.11 Buffer Overflow

Buffer overflow, or buffer overrun, is an anomaly where a process scores data in a buffer outside the memory the programmer has sec aside for ic. The excra data overwrites adjacenr memory, which may contain other data, including program variables and program flow concrol daca. This may re uJr in erracic program behavior, including memory access errors, incorrect result , program termination (a crash) or a breach of ysrem securiry.

Buffer overflows can be triggered by inputs that are designed to execute code or alrer rhe way rhe program operates. They are, chus, che basis of many software vulnerabilities and can be maliciously exploited. Bounds checking can prevent buffer overflows.

Programming languages commonly associated with buffer overflows include C and C++, which provide 110 built-in protection against accessing or overwriting data in any pan of memory and do not aucomaricall,. check drnr daca wrircen to an array (the buik-in buffer rype), which is within che boundaries of that array.[115]

Buffer overflow occurs when a program or process cries ro score more darn in a buffer (temporary tiara storage area) than it was intended to hold. *As* buffers are created to contain a finite amount of daca, rhe extra information - which has to go somewhere - can overflow into adjacent buffers, corrupting or overwriLing chc vaJid data held Ln rhec:m. Ald,ough ic may occur accident,Jly through programming error, bLLffer overflow is an increasingly common *rype* of securiry arrack on data integriry.

·1heknowledge of C, C++ or any ocher high-level computer language (i.e., assembly language) is essential to understand buffer overflow, as basic knowledge of process memory layout is very important. A buffer is a contiguous allocated chw,k of memory such as an array or a pointer in C. In C and Ct+, there re no auromaric bounds checking on che buffer - which means a user can write past a buffer. For example,

```
int main () {
int buffer{lO);
buffer{20) = 10;
}
```

1his C program is a valid program :md every compiler can compile it without any errors. I Jowever, the program attempcs ro write beyond rhe allocated memory for chc buffer, which migbt result in an unexpected behavior.

4.11.1 Types of Buffer Overflow

Stack-Based Buffer Overflow

Stack buffer overAow occurs when a program writes to a memory address on **the** program• caJI tack outide the intended data strucwre - usuaJly a fixed length buffer. Here are rbe characteristics of srack-based programming:

1. "Stack" is a memory space in which automatic variables {and often function paramerers) are allocared.
2. function parameters are allocated on cbe srack (i.e., local variables char are declared on the srack - unless they are also declared as "static" or "register") and are nor automatically inirializcd by rhe system, so they usually have garbage in rhem until they arc initialized.

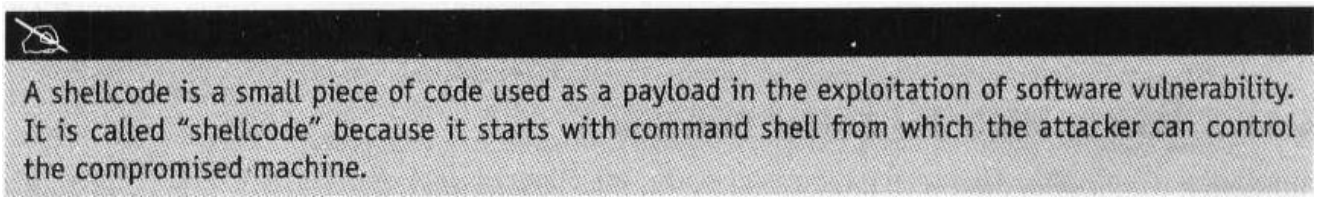
3. Once a function has completed its cycle, the reference ro rhe variable in the stack is removed. (Therefore, if a function is called multiple times, its local variables and parameters are recreated and destroyed each time che function is called and exited.)

U1c arcacker may exploit stack-based buffer overAows to manipulate che program in various ways by overwriting:

1. A local variable rhac is near che buffer in memory on the stack to change che behavior of che program chat may benefir the attacker.
2. The return address in a stack frame. Once the function returns, execution will resume ar the return address a. specified by the attacker, usually a user input-filled buffer.
3. A function pointer, or exception hanc!Jer, which is subsequenrly execured.

ll1e facrors chat contribute to overcome the exploits are

1. Null byres in addresses;
2. variabiliry in rhe location of shellcode;
3. differences between environments.



A shellcode is a small piece of code used as a payload in the exploitation of software vulnerability. It is called "shellcode" because it starts with command shell from which the attacker can control the compromised machine.

NOPs

NOP or NOOP (short form of no peration or no operation performed) is an assembly language instruction/ command chat effectively does nothing ar all. lhe explicit purpose of chis command is nor to change the scare of scarus flags or memory locations in che code. This means NOP enables rbe developer to force memory alignment ro act as a place holder ro be replaced by acrive instructions lacer on in program development.

NOP opcode can be used to form ru1 NOP slide, which allows code ro execute when the exact value of the instruction pointer is indeterminate (e.g., when a buffer overflow causes a function's return address on the stack ro be overwritten). It is the oldesc and most widely used technique for successfully exploiting a stack buffer overflow. It helps ro know/locare the exact address of the buffer by effectively increasing rhe size of the rarger srack buffer area. The attacker can increase rhe odds of findings che right memory address by padding his/her code with NOP operation. To do chis, much larger sections of che stack are corrupred wirh the NOOP machine instruction. Ac che end of the attacker-supplied data, after che NOOP Lnstrucrions, an instruction is placed to perform a relative jump to the top of the buffer where the shellcode is located. 'TI1is collection of NOOP is referred ro as the "NOP sled" because if rhe return address is overwrinen with any address wichin the NOOP region of the buffer then ir will "slide" down the NOOP tLOtil it is redirected ro the actual Malicious Code by the jump at the end. This technique requires the attacker to guess where in the stack che NOP sled is compared with small shellcode.

Owing to the popularity of chis technique, mru1y vendors of intrusion prevention system wiU search for chis pattern ofNOOP machine instructions in an artempr co detect shellcode in use. le is important to note char an NOP sled does not necessarily wncain only rradicional NOOP machine inscrnctions bur also any insrrucrion that does nor corrnpt che state of machine ro a poinr where the shellcode will not run and can be used in place of the hardware-assisted NOOP. As a result, it has become common practice for exploit writers to compose me NOOP sled with randomly chosen instructions that will have no real effect on the shellcode execution.13[51]

Heap Buffer Overflow

Heap buffer overflow occurs in the heap dara area and may be introduced accidentally by an applkarion programmer, or ir may re!>ulc from a deliberate exploit. In either case, the overflow occur when an application copies more d:ita inro a buffer than rhc buffer was designed ro contain. A rourinc.: is vulnerable to exploicarion ific copies daca to a huffer wirhour firsc verifying chat the source will fir into the dcscin.nion. The char.tcterisrit"!I ofsrack-basc-d and heap-based programming are as follow :

1. "Heap" is a "free score" that is a memory pace, where dynamic object!> are allocated.
2. The heap is the memory space char is dynamically allocated new(), m:illoc() and calloc() functions; ir i differenc from rhe memory space allocated for stack and code.
3. Dynamiectlly created variables (i.e., declared variables) are crearecl on rhe hear before the execution program is initialized to 2.eros and are stored in the memory unLil the life cycle of the object has completed.

Memory on the heap i dynamically allocated by the application at run-rime and normally conrains program data. Exploicacion is performed by corrupring this daca in specific ways to cause the application ro ovcrwrice internal truccures such as linked list pointers. The canonical heap overflow technique overwrict'.S dynamic memory allocation linkage (sud, a malloc mecadarn) and uses the resulting pointer exchange co overwrite a program funcrion pointer.

4.11.2 How to Minimize Buffer Overflow

Although ic is difficult to prevent all possible arracks, chc following methods will ddinirely help ro mini mile uch anacks:

1. Assessment of secure code manually: Buffer overflow occurs when .1 progr:im or rrocess crie rn core more data in a buffer than it was intended co hold. Developers should be educated about mini mizing the use of vulnerable funcrions available in C library, such as trcpy(), strcar(), sprintf() and vsprintf(). which operate on null-rerminated strings and perform no bounch checking. ·1he input vaUdation alier scanf() function rhar reads user input inco a buffer is very es ential.
2. Disable stack execution: Malicious Code causes inpu1 argument co rhe program, and ir reside in rhe srnck and not in the co<le segment. Any code that attempt ro execute any other code residin in che tack will cause a segmentation violation. Therefore, rhe simplest solution i co invalidate rhe tack ro execute any inscructions. I lowever, rhc solution is not easy co implement. Although po - sible in Linux, some compilers [(including GNU Compliance Connection (GCC)l u e trampoline functions to implement taking the address of a nested function that work!> on rhe ystcm suck being execurahle. A trampoline is a small piece of code creared ac run-time when rhe addres of ,1 nested function *is* taken. Ir normally resides in 1he scack and in the smck frame of 1he co11taini11g fu11'-1ion and thus requires rhe srack co be execucable. However, a version of the I.inw. h.1 r1nel th.n enforce.\ rhe• non-executable stack is freely available.
3. Compiler **cools:** *Over* the years, compilers have become more .incl more aggre ive in op11mi,.arions ,llld rhe checks they perform. Various compiler cools already offer warnings on the use of unsafe con• scructs uch a gees(), strcpy(), ccc. Developers ,hould be educated ro re!>crucrure che programming code if such warnings arc displayed.
4. **Dynamic run-time checks: In** this scheme. an application ha resrricred acces to prevenc attacks. -11,is method primarily relies on the safety code being preloaded before an applicarion is executed. This preloaded component can eicher provide safer versions of die tandard unsafe funccions or

Table 4.17 Tools used to defend/protect buffer over11ow

Sr. No.	Tool	Brief Description
	StackGuard	lr was released for GCC in 1997 and published at USENIX Security 1998. Jc is an extension to GCC thar provides buffer overflow protection. It was invented by Crispin Cowan. 1t is a compiler approach for defending programs and systems against "stack-smashing" attacks. These attacks are the most common form of security vulnerability. Programs that have been compiled with StackGuard are largely immune to srack-smashing attack. Whenever vulnerability is exploited, it detects the attack in progress, raises an intrusion alert and halts the victim program.
2	ProPolice	'TI1e "stack-smashing protector" or SSP, also known as PmPolice, is an enhancement of the StackGuard concept writcen and maintained by Hiroaki Ecoh of rBM. Its name derives from the word propolis. The stack protectio11 provided by ProPolice is specifically for the C and C++ languages. It is also optionally available in Gcncoo Linux with the hardened USE flag.
3	**LibSafe**	**It** was released in April 2000 and gained popularity in the Linux community. It does 110c need access to the source code of the program to be protected. Libsafe protection is system wide and automatically gets attached ro the applicario11s. It is based on a middle-ware sofrware layer that i11terceprs all function calls made to library functions known co be vulnerable. A substitute version of rhe corresponding fw1ction irnplemenr.sthe original function in a way char ensures that any buffer overflows are contained within the current stack frame, which prevents attackers from overwriting the return address and hijacking the control flow of a running program. The real benefit of using libsafe is protection against future att.acks on programs nor yet known co be vulnerable.

it can ensure char return addresses are nor overwritten. One example of such a cool is libsafe. The libsafe library provides a way co secure calls to these functions, even if the function is nor available. Jc makes use of the fact chat stack &a.mes are linked cogecher by frame pointers. When a buffer is passed as an argument co any of tbt: unsafe functions, libsafe follows the frame pointers to the correct stack frame. It rhen checks the distance co the nearest return address and wben che function executes, ic makes sure chat address is noc overwritten.

5. Various tools are used to detect/defend buffer overflow: See Table 4.17 co know abouc few such tools.

4.12 Attacks on Wireless Networks

Even when people travel, they scilJ need co work. Thus, work *seems* co be moving om of the traditional offices into homes, hotels, airport lounges and taxis. The employee *is* no longer tied to an office location and is, in effect, "boundaryless." When one talks co the young generation about their lifescyles, one realizes chat gone are those days when an "office" conjured up the image of the four walls, sec in the formal setting, typical office decor and with all che formality chat one can imagine, which may perhaps be difficult for our new generation to appreciate. 1n rhe yesteryears, "working" meant leaving home, commuting co the workplace, spending chose typical 9 a.m.-6 p.m. in the office and chen shurting down che work and commuting back home or wherever cbac one wished to be after office hours. The "working" and "away from work" were cleanly delineated distinct states char one could be in. Gone are those days and now we are in the era of computing anywhere, anytime! There is no doubt chat workforce "mobility" is on che rise (see Box 9.1, Chapter 9).

ll1e following are differenc types of"mobile workers":

1. Tethered/remote worker: This is considered co be an employee who generally remains at a single poinr of work, but is remote co the central company systems. This includes home workers, tele-cottagers and, in some cases, branch workers.
2. Roaming user: This is either an employee who works in an environment (e.g., warehousing, shop Boor, etc.) or in mulciple areas (e.g., meeting rooms).
3. Nomad.: This category covers employees requiring solutions in hotel rooms and ocher semi-tethered environments where modem use is still prevalent, along with the increasing use of multiple wireless tedmologies and devices.
4. **Road warrior:** ll1is is che ultimate mobile user and spends liccle cime in the office; however, he/she requires regular access ro data and collaborative functionality while on tbe move, in transit or in hotels. This cype includes the sales and field forces.

Wireless technologies have become increasingly popular in day-co-day business and personal lives. Hand-held devices such as the PD.As allow individuals co access calendars, E-MaiJ addre.%es, phone number lists and the Internee. Wireless networks exrend r.he range of rraditional wired networks by using radio Waves to transmit data co wireless-enabled devices such as laptops a11d PD *As*. Wireless networks are gcneraJly composed of rwo basic elements: (a) access points (APs) and (b) ocher wireless-enabled devices, such as laptops radio transmicters and receivers co communicate or "connect" with each ocher (see Fig. 4.6). APs are connected through physical wiring co a conventionaJ necwork, and they broadcast signals wirh which a wireless device can connect.

Wireless access co nerworks has become very common by now in India - for organizations and for individuals. Many laptop computers have wireless cards preinstalled for the buyer, for example, in India, such cards arc provided by1ATA lndicom, Reliance and Airtel. There are many hotels and equivalent establishments all over rhe world (includjng India) where rhe rooms are "Wi-Fi enabled." There is no denying iliac the ability cq enter a network while on the move (working away from home or in other locations char are not routine office locations, working while in hotels, etc.) has great benefits (see Box 4.10 for some inrerescing facts).

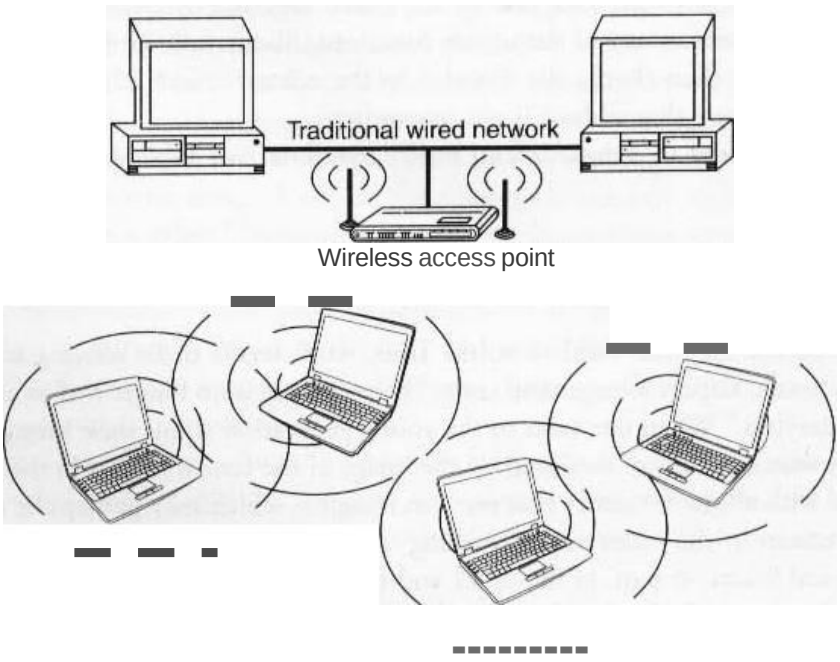


Figure 4.6 Wireless networks.

Box 4.10 Going Wi-Fi

Stort with a laptop compu1er or o1her portable device that could benefit from Internet access. Make sure It is wireless. Look for Intel's Centrino sticker or any sign that Wi-FI is built into the device. II not. you need on external Wi-Fi Personal Computer Memory Card International Association (PCMCIA)-compliant cord. Find o public hotspot by searching store windows for stickers that soy Wi-Fi Zone, T-Moblle HotSpol or anything indicating a wireless service. Boot up your laptop and login, ot home or al a hotel. or get a WI-Fi router and plug one end into your cable or digital subscriber line (DSL) modem. The router wilt broadcast the wireless Internet signal in your house and you can sit on the couch and surf the Internel.

Although wireless technology is not new, it is now being used by families who need on easy way to shore a fast Internet connection with two or more computers at home. It is helping almost anybody, fhol Is. even the "non-techies," lo get Internef access while they buy their doily cup *of* coffee of a WI-Fi coffeehouse. This kind of scene ls now very common in most Indian metros. including some small cities too.

Cell phones hove become indispensable for many who use them to keep track of family members or lo coll for help in on emergency. Wi-Fi is not there yet, however, the idea of wireless Internet access on every corner is becoming a 24/7 possibility as more companies set up public hotspofs. Like cell phones, WI-Fi is not somefhing you will use every minute, but II con be convenient when you need to check for on E-Mail message or compare the price ol on online gift.

Readers may like to visit http://computer.howstuffworks.com/wifi-quiz.htm to test fundamental knowledge about wireless networks before going through this section.

Wireless rcchnology is no more bu1.zword in roday's world. Let us understand important componems of wircl nerwork, ,tpan from components such as modem . routers, hubs and firewall, which arc integral pan of any wired nerwork as well as wireless nerwork.

J. 802.11 networking standards: I11sritute of Electrical and Electronics Engineers (IEEE)-802.1I is a family of srandards for wireless local area network (WLAN), stating the specifications and/or requirements for computer communication in the 2.4, 3.6 and 5 *GHL* frequency bands.

- *802. I I:* Ir is applicable ro WLANs and provides 1 or 2 Mbps cransmis1-ion in chc 2.4 GHz band using either frequency-hopping spread spectrum (FHSS) or direct l,equencc spread spectrum (DSSS).
- *802.I In:* le provides 54 Mbps rnmsmission in the 5 *GH1* band and uses orthogonal frequency-division multiplexing (OPDM) which is rnorc efficienr coding rechnique compared with FHSS and DSSS.
- *802. / lb:* It provides 11 Mbps transmission in rhe 2.4 GHz band and uses complemenrary codec: keying (CCK) modulation co improvepeeds. In I999, rarilication was made ro the original 802.11 standard, and was termed as 802.11 b, which allowed wireless functiomtliry comparable lo Ethernet. Although ir was being a slowest sr:mdard, ar the same rime being rhe least expensive, rhc evolution led to the rapid acceptance of 802.1 lb across the world as cl1e definitive WLAN technology and known as "Wi-Fi standard."
- *802.I lg:* [r providei, 54 Mbps transmission in the 2.4 GI lz band and chc same OFDM coding as 802. I I a, hence ir b a lot fosrer than 802.11a and 802.11 b.
- *802.1111:* It is rhe newest srandar<l available widely and uses mulciple-i11put multiple-output (M1MO) that enabled to improve the speed and range signilicancly. For example, although

802.11g provides 54 Mbps traJlsmission theorerically, however, it can only achieve 24 Mbps of speed because of network traffic congestion. However, 802.1 In can achieve speeds as high *as 140* Mbp .

·1he other importam 802 family members are as follows:

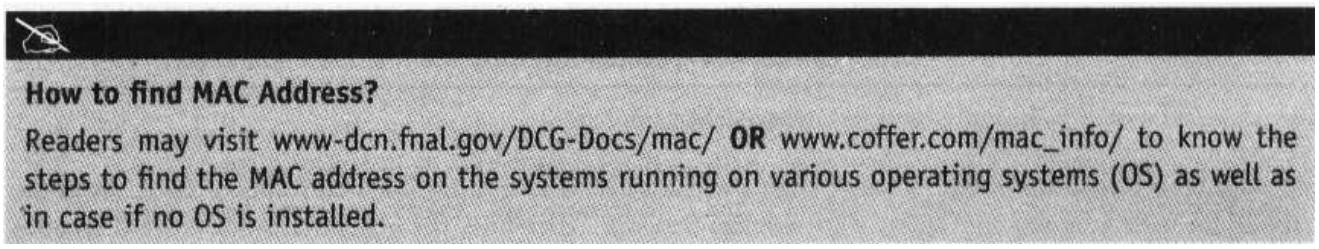
- *802.15:* This scandard is used for *personal WLANs* and covers a very short range. Hence, ic is used for *Bluetooth Technology.*
- *802.16:* It is also known as *WiM11x.* le combines the benefits ofbroadbanJ and wireless, hence ir provides high-speed wireless Internet over very long distances and provides access to large areas such as cities. This standard is developed by IEEE working group established in 1999 co develop the standards for *Wirdm Metropolit11n Are11 Networks.*

2. Access points: It is also termed a AP. It is a hardware device and/or a software char aces as a cencral transmirrer and receiver of WLAN radio signals. Users of wireless device, such as laprop/PDAs, get connected with chese APs, which in turn ger connected with the wired LAN. An AP acts as a communicacion hub for users to connect with the wired LAN.
3. Wi-Fi hotspots: A hotspot is a sire chat offers the Internet access by using Wi-Fi technology over a WLAN. Hotspots are found in public areas (such as coffee shops, public libraries, l10tels and rescau• rants) and are commonly offered facility throughout much of North America and Europe.
   - *Free Wi-Fi hotspots:* Wireless Internet service is offered in public areas, free of cosc and that ro without any auchenticacion.The users will have co enable the wireless on rheir devices, search for such hotspots and will have to say *(click)* connect. 1l1e Internet facility is made available co the user. *As* tl1e authenricacion mechanism on the router is disabled, user gets connected co WLAN and cybcrcriminals gee their prey. As, access to free horspots cannot be controlled, cybcrsecuriry is always questioned. Readers may visit www.hocspor-locations.com to find wireless hocspors inco their area. Horspor locations is the free global hotspot database of wireless access points made available co the general public.
   - *Commercial hotspots:* The users arc redirected to authentication and online paymem to avail che wireless Internet service in public areas. The payment can be made using credit/debit card chrough payment gateways such as PayPal. Major airports and business hotels are usually charged to avail wireless Internet service. Some Internet ervice providers offer virtual privare network (VPN) as a security feature buc found to be an expensive oplion.

   Although che user has been authenticated while connecting co a hotspot, ic docs nor mean that *he/* she is on the secured communication channel. A "poisoned/rogue hotspot" is cermed to be a free public hocspor set up by rhe cybercriminals, with che objective of sniffing the data sent by me user. They can easily obtain the User IDs (i.e., login names), decipher the passwords and/or other sensi- tive informarion by examining packets scnc by the user (see Section 7.9, Chapter 7).
4. Service set identifier (SSID): It is the name *of* 802.11i WLAN and all wireless devices on a WLAN must use the same SSID to commun.icace with each other. Whik setting up WLAN, the user (or WLAN administrator) scrs the SSID, which can be up co 32 characters long so char only the users who knew che SSID will be able co connect the WLAN. lt is always advised co turn OFF the broadcast of the SSID, which resulcs in the detected network displaying as an unnamed network and the user would need co manually enter the correct SSfD co connect to the network. Hence, iris also advised co sec the SSID manually rather than leaving ir blank. Moreover, it is important to note char turning off the broadcast of the SSID discourages casual wireless snooping, however, it does nor stop an acrncker trying ro attack the network.
5. Wired equivalence privacy (WEP): Wireless transmission is susceptible to eavesdropping and ro provide confidentiality, WEP was introduced as pare of the original 802.11i Protocol in 1997. It is

always termed as deprecated security algorithm for LEEE 802.1li WLANs. SSID along with WEP delivers fair amount of secured wireless network.

6. Wi-Fi protected access (WPA and WPA2): During 2001, serious weakness in WEP was identified chat resulted WEP crackingsoftware(s) being made available roenable cybercriminals to intrude into WLANs. WPA was introduced as an interim standard to replace WEP co improve upon che security features of WEP. WPA2 is the approved Wi-Fi alliance (www.wi-fi.org) inceroperable implementation of 802.11 i. WPA2 provides a stronger encryption mechanism through Advanced Encryption Standard (AES), which is a requirement for some corporate and government agencies.
7. **Media** access **control (MAC):** It is a uniqut identifier of each node (i.e., each nerwork interfaces) of the network and it is assigned by the manufacturer of a network interface card (NIC) stored in its hardware. MAC address filtering allows only the devices with specific MAC addresses co access the network. The router should be configured scaling which addresses are allowed. Although this method appears robe very secure, the accacker can spoof a MAC address, that is, copy the known MAC address to *entice* the network chat the device he/she is using belongs to the network , at che same time it is important co note chat, in case you purchase a new device or if any visitors would like to connect to che network, you will need to add the MAC addresses of these new devices to the list of approved addresses.



How to find MAC Address?

Readers may visit www-dcn.fnal.gov/DCG-Docs/mac/ **OR** www.coffer.com/mac_info/ to know the steps to find the MAC address on the systems running on various operating systems (OS) as well as in case if no OS is installed.

While all this sounds very exciting, it is important to understand chat wireless networking has many security issues. Crackers have found wireless networks relatively easy co break into. They are known to use wireless technology to crack into non-wireless networks. Network administrators must be aware of these risk and should stay up to date on any new risks that arise. Users of wireless equipment must be aware of these risks so as to cake personal protective measures. As che wireless service technology is getting improved and falling within an easy reach of information technology (IT) as well as non-IT workers, the risks to users of wireless technology have increased exponentially (see Section 9.3.1, Chapter 9).

There were relatively few dangers when wireless technology was first incroduced. Although the attackers have no time to latch on to the new technology as wireless was not commonly found in the workplace, however, rhere are a great number of security risks associated with wireless teclrnology. Some issues are obvious and some are not. At a corporate level, it is the responsibility of the IT department co keep up t<> dace with the types of threats and appropriate countermeasures to deploy. Security threats are growing in the wireless arena. The attackers have learnt that there is much vulnerability in the current wireless protocols, encryption methods and the carelessness and ignorance chat exist at the user and corporate IT levels. Cracking methods have become much more sophisticated and innovative with the availability of different cools used to search and hack wireless networks. Cracking has become much easier and more acces• sible with easy-co-use Windows- and Linux-based tools being made available on che Web ac no charge *(see* Table 4.18).

The overall philosophy behind wired networks vs. wireless networks is "trust." On a wired network, che hardware is w1der rhe direct control of the nenvork administrator, and therefore, the overall attitude coward

Table 4.18 Tools used for hacking wireless networks

Website	*Brief Description*
hup://www.nem umbier.com/	**NecSrumbler:** 1l1is cool is based on Windows OS and easily identil1es wireless signals being broadcast within range. Ir also has abiliry ro determine signal/noise char can be used for site surveys.
htrp://v.•ww.kismerwirelcss.nct/	**Kismet:** This t0ol deteccs and displays SSIDs rhat arc not being broadcas1 whid, *is* very criricaI in finding wireless networks. NcrSmmbler do nae h:1ve chis key functional element - abiliry co display wireless networks 1hac arc 001 broadcasting their SSID.
ht cp://sourceforge.nee/ projects/ airsnorc/filcs/	Airsnort: 1his rool *is* very easy and is usually used co sniff and crack WEP keys (htrp://airsnorc.shmoo.com/).
htrp://wirdessdefcncc.org/ Contents/co\XIPAttyMain.htm	CowPatty: This tool i used as J brute force cool for cracking WPA-PSK a11d is con idered robe the "New WEP" for home wirebs sccmiry. This program simply cries a bunch of different options from a dictionary file t0 sec if one ends up matching what is defined as the preshared key.
http://www.wircshark.org/	Wircshark (formerly etbcreal): Ethereal can scan wireless and Echcrner data and comes wirh some robusc leering cap.1.biliries. It can also be used co ,niff ouc 802.J I managemenr Beacons and probes, and subsequently could be used as a rool co sniff out non-broadcast SSIDs.

Sourer: h11p://www.ethicalha1.ker.ne1/con1em/view/ l 6/24/ (lO May 10).

the worlmations cends co be one of cruse. Witl1 a wireless network, it is possible rhac someone could siLin the parking loLwith a laptop and access your wireless nerwork. fhereforc, the general attimde coward wireless workstarions tends ro be one of extreme distrust. However, chis difference in arrirude ofrea causes the same adminiscraLors LO take extreme positions when it comes to guarding network security. Although chey tend co go to exLreme lengths ar securing a wireless network, at times they almost neglect wired ncrwork securiry. Things co wacch out are rhe following: Are there any unused nerwork jacks or unused switch ports in the office? This is importanr because if someone was able co sneak inco the office and plug a laprop imo one of these unused jacks, you may no more have rhe same level of rrusr in the hardware on your wired ncrwork,

4.12.1 Traditional Techniques of Attacks on Wireless Networks

In security bre:iches, penetration of ;i wireless necwork th.rough unauchoriled acccc,,<, is termed as *111irtless crtLcking.* There are various methods char demand high level of technological skill and knowledge, and av:.iilabilicy of numerous sofu-varc cools made it less sophisticated with minimal technological skill co crack WLANs.

I. **Sniffing:** Ir is eavesdropping on the neLwork and is the simplest of all acracks. Sniffing is the simple process of intercepting wireless data char is being broadcasred on an unsecured network. Also termed as reconnaissance technique, it gathers the required information about the active/available Wi-Fi ncrworks.'the attacker usually inscalls the sniffers re11101dy on the victim's system and conduas acrivitics such as
   - Passive scanning of wirdess network;
   - decection of SSJ O;
   - collering the MAC address;
   - collecting che &a.mes co crack WEI

2. Spoofing: The primary objective of chis accack is co successfully masquerade the identity by falsifying dara and thereby gaining an illegitimate advanrage. The attacker often launches an attack on a wireless network by simply creating a new network wich a scronger wireless signal and a copied SSID in the same area as a legitimate network. Ie causes unsuspecring compurers to automatically connect to che spoofed network instead of che real one. The arcacker can conduct chis acrivity easily because while setting up a \vireless network, tbe computers no longer need to be informed ro access tbe network; rather they access it aucomacically as soon as rbey move within the signal range. This convenient feature is always exploired by the attacker.
   - *MAC nddress Spoofing:* Ir is a technique of changing an assigned media access conrrol (MAC) address of a networked device to a differenr one·. n,is allows the attacker to bypass che access comrol lists on servers or routers by either hiding a computer on a network or allowing ir co impersonate another neC\vork device.
   - *IP Spoofing:* It is a process of creating IP packets with a forged source IP address, wirh the purpose of concealing the identity of the send.er or impersonating another computing system. To engage in IP Spoofing, the atcacker uses a variety of techniques co find an IP address of a rrusred hosr(s) and then modifies rhe packer headers *so* chat it appears that the packers are coming from chat host, that is, legitimate sender.
   - *Frame Spoofing:* The artacker injects the frames whose concent is carefully spoofed and which are valid as per 802. l l specifications. Frames themselves are nor auchencicaced in 802.11 networks and hence when a frame has a spoofed source address, it cannot be dececred unless che address is encirely faked/bogus.
3. Denial of service (DoS): We have explained this attack in derail in Section 4.9.
4. Man-in-the-middle attack **(MITM):** It refers to che scenario wherein an attacker on host A inserts A becween all communications - beC\veen hosts X and Y wichouc knowledge of X and Y. All messages senr by X do reach Y buc through A and vice versa. The objective behind chis artack is co merely observe the communication or modify it before sending it ouc.
5. Encryption cracking: Ir is always advised rhat rhe fusr srep co protect wireless nccworlu is to use WPA encryption. The anackers always devise new tools and techniques co deconscrucc the older encryption technology, which is quite *easy* for attackers due to continuous research in this field. Hence, tbe second step is to use a long and highJy randomized encryption key; this is very impor- ranr. It is a little pain co remember long random encryption; however, ar the same Lime Lhese keys are much harder co crack.

4.12.2 Theft of Internet Hours and Wi-Fi-based Frauds and Misuses

Information communication rechnolob'Y (ICT) is within reacb of people nowadays and most of rhe new sysrems (i.e., computers) are equipped for wireless Internet access as more and more people are opting for Wi-Fi in their homes. Wireless network inro homes is becoming common necessity because of lifestyle and availability of inexpensive broadband routers that can be configured easily and/or there is no need ro configure these devices al all because of plug-and-play feature. This enables che Internet on the finger tip of home users and in case, unfortunately, he/she visits a malicious webpage, the router is exposed for an arrack. Thus, as che networks become stronger and more prevalent, more of the signals are available outside the home of rhe subscriber, spilling over into neighbor's apartments, hallways and the street. In coday's era of high dependability on che lnrernec for many aspect& of our life and given char predacors are lurking around as potential cybercriminals, they (criminals) often wonder how they can find our who they are stealing ic from so char they can get a.n idea if char information is safe. According co a scudy by Jupiter Research, I4% of wireless

network owners have accessed cheir neighbor's connection. [361] le appears chat more and more people are logging on for free.

Cybercriminals know char they should nor sreaJ £ncernet hours purchased by others but somehow they wanr co get their work done without paying for the Internet connection and they also wanr ro know if anyone knows how to find ouc who they are stealing it from. Here is what they are mostly likely co do: (a) they find our the IP address of the router chat you are using, (b) open up a command prompt (go to scan click on run with; rype cmd and press enrer) at the command prompt and (c) rype chis command ipconlig/ all :md press enrer. Look for the default gaceway (chis is the router); once you see the IP address type the rourers IP address into your browser and you can find our some information abouc who you are see-a.ling Internet from.

An incere!>ting question is whether «steaJing" wireless Internet is illegal. We have discussed ic under a mini-case in Chaprer I I (in CD) and readers may visit che URL provided in Ref.#13, Additional Useful Web References, Further Reading. Here is one scenario, given that use of laptops is now common place. Suppose you figure our how ro connect the laptop to one of the many wireless networks detected on your laptop. Is this illegal? As we shall learn in Chapter 6 the laws vary around the world. However, for rhe most pan, logging and collecting information, such as surfing rhe Web or checking E-Mail, from wireless networks char are accessible co anyone with a receiver is OK. The act of wardriving is searching for wireless nerworks by a moving vehicle using a portable compucer or PDA."[71] Readers may visit the URL menrioned in Ref. #3, Video Clips, Further Reading to watch a small video clip on how wardriving is conducred.

Sofrware for wardriving is freely available and can be downloaded from the Incemet - to name a few NctSrumbler for Windows, Kismet or SWScanner for Linux, and FrecBSD, NecBSD, OpenBSD, DragonFly BSD, Solaris and KisMac for Macintosh. Wardrivers log and collect information from the wireless access points (WAP) they find while driving (see Box 4.11). Think about radio airwaves: as long as you have a radio, listening to a radio station broadcasting where you are driving is free (at lease in the US).

Box 4.11 The New "Wars" in the Internet Era!

Basically, the term "wardriving" was derived from the term wardialing from the 1983 fllm WarGomes, which involved searching for computer systems to connect to, using software that dialed numbers sequentially, to see which ones were connected loo fax machine or computer. Subsequently, many related terms come up:

1. **Warwolklng:** It Is also known as "warjogging" and is similar in nature to wardrivlng. except that it is done on foot rather thanconducted from o moving vehicle. The disadvantages of thisapproach consist in slower speed of travel (resulting in fewer and more infrequently discovered networks) and the absence of a convenient computing environment. Consequently, hand-held devices, such os Pocket PCs that con perform tasks while one is walking or standing, hove predominated in this area. The inclusion of integrated Wi-A (rather than o CompoctFlosh, i.e.. CF is o moss storage device format used in portable electronic devices or PCMCIA add-in card} in Dell Axim, Compaq iPAQ ond Toshiba pocket PCs in 2002 - and, more recently, on active Nintendo DS and Sony PSP enthusiast community possessing Wi-Fi capabilities on these devices - has expanded the extent of this practice o.s the newer Smortphones hove also integrated Global Positioning System (GPS). Of recent note. the Nokia N770. N800 and N810 Internet Tablets hove very good antennas and will pick up nearly anything in the area, even blocks away from the unit.
2. **Warblklng:** Although worbiking is some as wordriving, ii involves searching for wireless networks while on o moving bicycle or motorcycle. This activity is facilitated by the mounting of o Wi-Fi-copable device on the vehicle itself.

Box 4.11 The New "Wars" ... *(Continued)*

3. **WarkItting:** Workilling was identified by Tsow, Jakobsson, Yong and Wetzel In 2006. This is a combination of wordriving and rootkitting - an ollock in which the wireless access point's conng. uration or firmware is modiOed over the wireless connection. This allows lhe attacker to control all traffic for the victim and may even permit fo disable Secure Sockef Loyer (SSL) by replacing HTML content. when it is being downloaded. The allacker first discovers vulnerable wireless routers through wardriving and/or by retrieving thenecessary data from existing Wi-A access point data• bases such as WiGLE (www.wigle.net) or WiFiMaps (www.wlfimaps.com) to carry out a work1tting attack
4. **WAPKIttIng:** In this attack, external software clutches the control of router's nrmworo that can be easily accomplished by exploi1ing open administrative access. WAPldtting con theoretically proceed by more traditional means such as buffer overflow. The ability to install arbitrary control sof1wa1e on a wireless rouler opens unlimited possibilities to on attacker.
5. **WAPJackIng:** This type of attack is very similar to DNS poisoning allacks. It changes the settings of existing firmware that helps on attacker to engage in malicious configura1ion of firmware settings; however. it makes no modification to the firmware itself, that is. allow connections to be hijacked and/or rerouted without !he user's knowledge. WAPjocking is less powerful attack compared to WAPkitting.

WAPkitting and WAPjocking ore independent ot the means of infection, and specify the relative modifications done to a WAP upon corruption. Warkilting, on the other hand, does not specify the type of WAP alferation, but it does relate to how infection occurs.

Sovrce: http//on.w,lc.1ped10.org/wik1/Wordriving (31 Moy 2010J.

Be careful with use of WAPs; when you are usiog a WAP ro gain access co computer on _a nccwork, be aw.tre of the local laws/legislarions where you are doing it because rhings can become dangerous from securiry and privacy as well legal perspective. Maybe if corporations were nor in such a hurry to rele:i e chis rechnology an<l thought abour it more thoroughly, they would not have LO deal wich securiry breaches and crea1ing uperior protection for their own sysrems. The moral c>f the story is that you must secure your nerwork.

4.12.3 How to Secure the Wireless Networks

Nowadays, security fearures of Wi-Fi networking producrs are not rhar time-consuming and non-intuitive: however, they are still ignored, cspeciaily, by home users. Although following ummarizcJ Hep will help to improve :rnd strengthen rhe security of wireless network. see Table 4.19 co know the available cools ro monitor and protccr 1he wireless nenvorks:

1. ChJnge the default setrings of all the equipmenrs/componcms of wireless network (e.g., [P address/ user 10s/administraror passwords, ere.).
2. Enable WPA/\'QEP encryption.
3. Change the default SSID.
4. Enable MAC address filtering.
5. Disable remote login.
6. Disable *SSID* broadcast.
7. Disable the fearurcs 1hat arc nor used in the AP (e.g., printing/music support).
8. Avoid providing rhe nerwork a name which can be easily identified (e.g., My_Home_Wili).
9. Connect only LO ccured wireless network (i.e., do nor autoconnect ro open Wi-Fi horspor,).
10. Upgrade router's firmware perioruc.1lly.

Table 4.19 Tools to protect wireless network

bsite	Brief Description
hrrp://www.zamzom.com/	Zamzom Wireless Network Tool: New frecware tool helps to protect wireless networks and maintain computer security, detects aU computer names, Mac and IP addresses utilizing a single wireless network, reveals all compurers - both auchorized and unauthorized - who have access coany given wireless network. Thus, it helps users co rake viral sreps roward securing their wireless networks and acts as a measure chat should not be overlooked or skipped.
lmp://www.airdefense.ner/	AirDefense Guard: lbe wol provides advanced intrusion derecrion for wireless LANs and is based on signarure analysis, policy deviation, protocol assessment policy deviation and statistically anomalous behavior. AirDefense decects responds 10: • Denial-of-service (DoS) arracks; • man-in-the-middle attacks; • identity the&.
hnp://www.loud-fa1-blokc.co.uk/rools.hcml	**Wu-eless Intrusion Detection System (WIDZ):** lhis *is* an intrusion detection for wireless LANs for 802.11. le guards APs and monitors local frequencies for potentially malevolent activity. It can detect *scans,* association *Roods* and bogus APs, and ir can easily be integrated wilh other products such as SNORT or Rcalsecure.
hup://www.dachbOden.com/projects/bsd-airtools.hrrnl	BSD-Airtools: "lliis cool provides a complete roolset for wireless auditing (802.11b). le contains AP detection application, Dsrumbler - similar ro Netsrumblcr. It c:an be used to detect wireless access poims and connected nodes, view signal-co-noise graphs, and interactively *scroll* through scanned *APs* and view stacisrics for each. l.r also contains a BSD-based WEP cracking application (called as Dwepucils).
http://wifi.google.com/	Google Secure Access: Google Wi-Fi is a free wireless lmernec service offered to the city of Mountain View (California, USA). With your Wi-Fi-enabled device and a Google Account, one can go online for free by accessing the network name uGoogleWi-Fi," which is secured by Google's virtual private network (VPN). Google Secure Access encrypts the Internet traffic and sends it through Google's servers on the Lnternet

l 1. Assign static IP addresses to devices.
12. Enable firewalls on each computer and the router.
13. Position the router or AP safely.
14. Tum off the network during extended periods when not in use.
15. Periodic and regular monitor wireless network security.

SUMMARY

When information systems are the target of offense, the criminal's goal is to steal information from, or cause damage to, a computer, computer system or computer oerwork. The perpetrators range from teenagers (script kiddies/cyberjoyriders) ro organized crime operarors and international terrorists.

A computer can be the target of offense; cools may be used in an offense, or may contain evidence of an offense. An understanding of different uses of a computer will provide foundation of the application of **the** criminal statures.

UNIT V
Cyber Security Organizational Policies, Risk and Challenges

Cybersecurity: Organizational Implications

In the global environment with continuous network connectivity, the possibilities for cyberattacks can emanate from sources that are local, remote, domestic or foreign. They could be launched by an individual or a group. They could be casual probes from hackers using personal computers (PCs) in their homes, hand-held devices or intense scans from criminal groups.

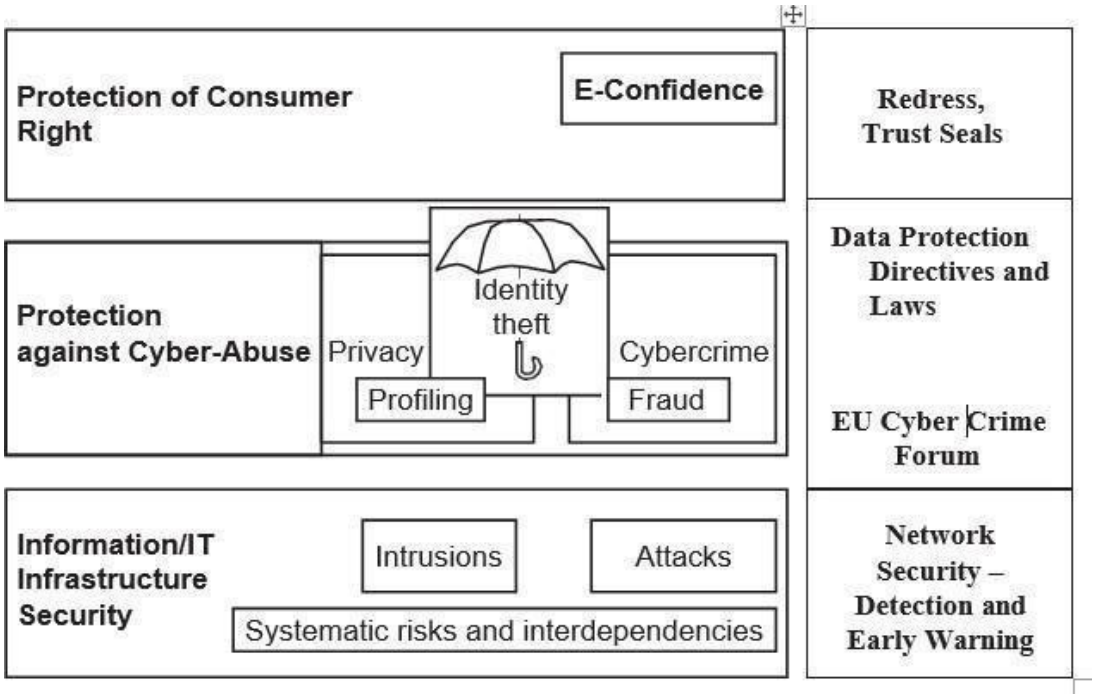


Fig: A cybersecurity perspective. EU is the European Union.

PI is information that is, or can be, about or related to an identifiable individual. It includes any information that can be linked to an individual or used to directly or indirectly identify an individual.

Most information the organization collects about an individual is likely to come under "PI" category if it can be attributed to an individual. For an example, PI is an individual's first name or first initial and last name in combination with any of the following data:

1. Social security number (SSN)/social insurance number.
2. Driver's license number or identification card number.
3. Bank account number, credit or debit card number with personal identification number such as an access code, security codes or password that would permit access to an individual's financial account.
4. Home address or E-Mail address.
5. Medical or health information.

An insider threat is defined as “the misuse or destruction of sensitive or confidential information, as well as IT equipment that houses this data by employees, contractors andother ‘trusted’ individuals.”

Insider threats are caused by human actions such as mistakes, negligence, reckless behavior, theft, fraud and even sabotage. There are three types of “insiders” such as:

1. A malicious insider is motivated to adversely impact an organization through a range of actions that compromise information confidentiality, integrity and/oravailability.
2. A careless insider can bring about a data compromise not by any bad intention but simply by being careless due to an accident, mistake or plain negligence.
3. A tricked insider is a person who is “tricked” into or led to providing sensitive or private company data by people who are not truthful about their identity or purpose via “pretexting” (known as social engineering).

- **Insider Attack Example 1: Heartland Payment System Fraud**

A case in point is the infamous “Heartland Payment System Fraud” that was uncovered in January 2010. This incident brings out the glaring point about seriousness of “insider attacks. In this case, the concerned organization suffered a serious blow through nearly 100 million credit cards compromised from at least 650 financial services companies. When a card is used to make a purchase, the card information is trans- mitted through a payment network.

- **Insider Attack Example 2: Blue Shield Blue Cross (BCBS)**

Yet another incidence is the Blue Cross Blue Shield (BCBS) Data Breach in October 2009 the theft of 57 hard drives from a BlueCross BlueShield of Tennessee training facility puts the private information of approximately 500,000 customers at risk in at least 32 states.
The two lessons to be learnt from this are:

1. Physical security is very important.
2. Insider threats cannot be ignored.

What makes matters worse is that the groups/agencies/entities connected with cybercrimes are all linked. There is certainly a paradigm shift in computing and work practices; with workforce mobility, virtual teams, social computing media, cloud computing services being offered, sharp rise is noticed in business process outsourcing (BPO) services, etc. to name a few.

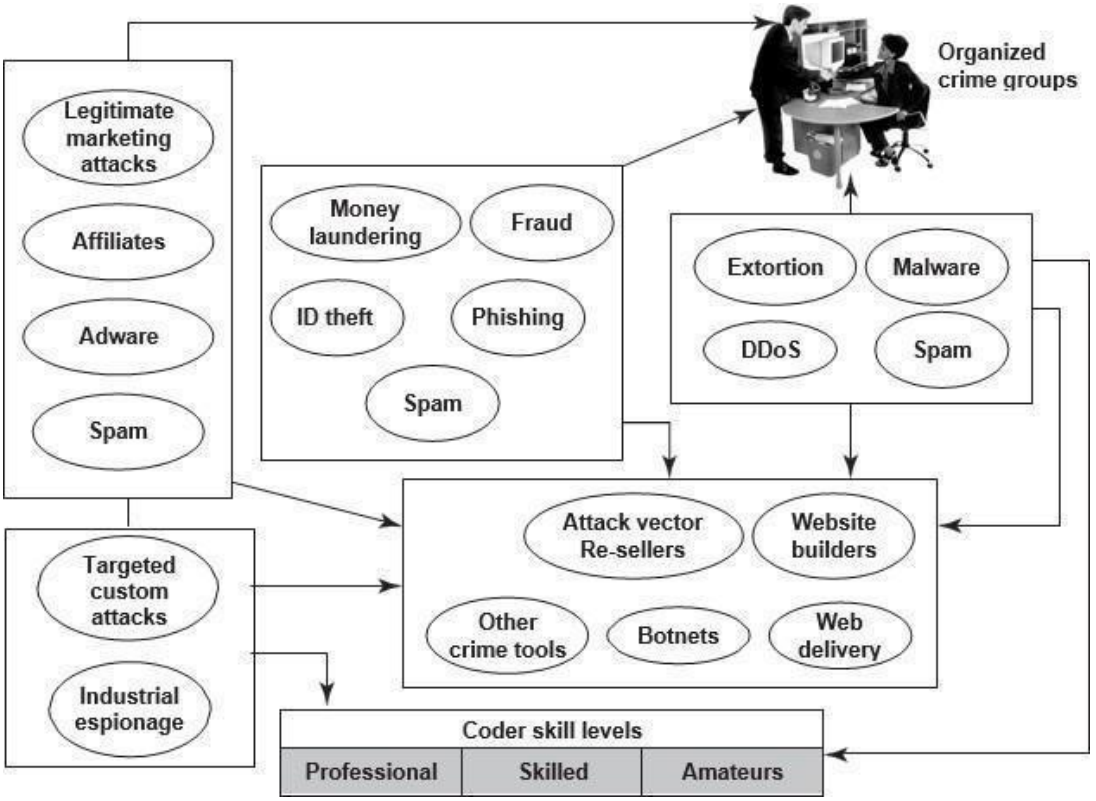


Fig: Cybercrimes – the flow and connections.

A key message from this discussion is that cybercrimes do not happen on their own or in isolation. Cybercrimes take place due to weakness of cybersecurity practices and "privacy" which may get impacted when cybercrimes happen.

Privacy has following four key dimensions:

1. **Informational/data privacy:** It is about data protection, and the users' rights to determine how, when and to what extent information about them is communicated to other parties.
2. **Personal privacy:** It is about content filtering and other mechanisms to ensure that the end-users are not exposed to whatever violates their moral senses.
3. **Communication privacy:** This is as in networks, where encryption of data being transmitted is important.
4. **Territorial privacy:** It is about protecting users' property for example, the user devices from being invaded by undesired content such as SMS or E-Mail/Spam messages. The paradigm shift in computing brings many challenges for organizations; some such key challenges are described here.

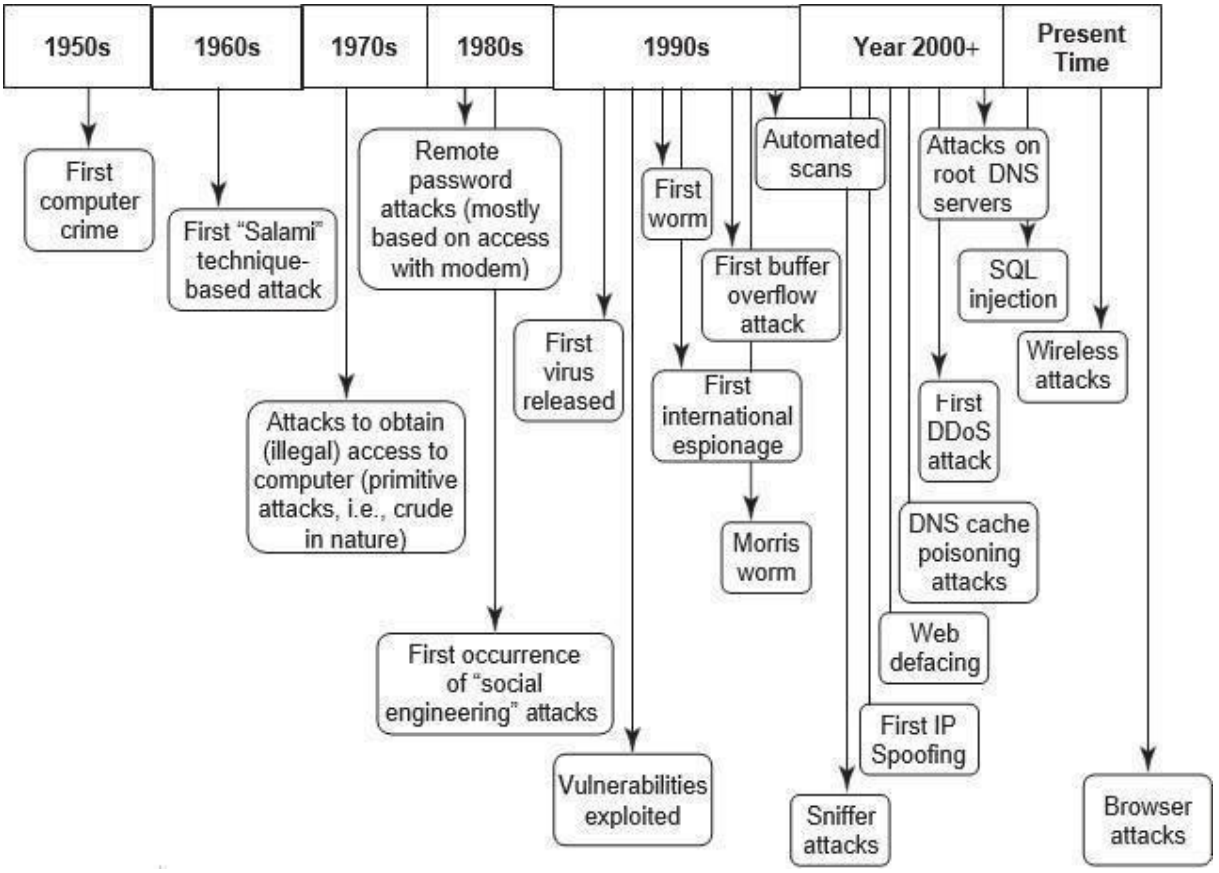


Fig: Security threats – paradigm shift.

The key challenges from emerging new information threats to organizations are as follows:

1. **Industrial espionage:** There are several tools available for web administrators to monitor and track the various pages and objects that are accessed on their website.
2. **IP-based blocking:** This process is often used for blocking the access of specific IP addresses and/or domain names.
3. **IP-based "cloaking":** Businesses are global in nature and economies are interconnected.
4. **Cyberterrorism:** "Cyberterrorism" refers to the direct intervention of a threat source toward your organization's website.
5. **Confidential information leakage:** "Insider attacks" are the worst ones. Typically, an organization is protected from external threats by your firewall and antivirus solutions.

➔ **Cost of Cybercrimes and IPR Issues: Lessons for Organizations**

Reflecting on the discussion in the previous sections brings us to the point that cybercrimes cost a lot to organizations.

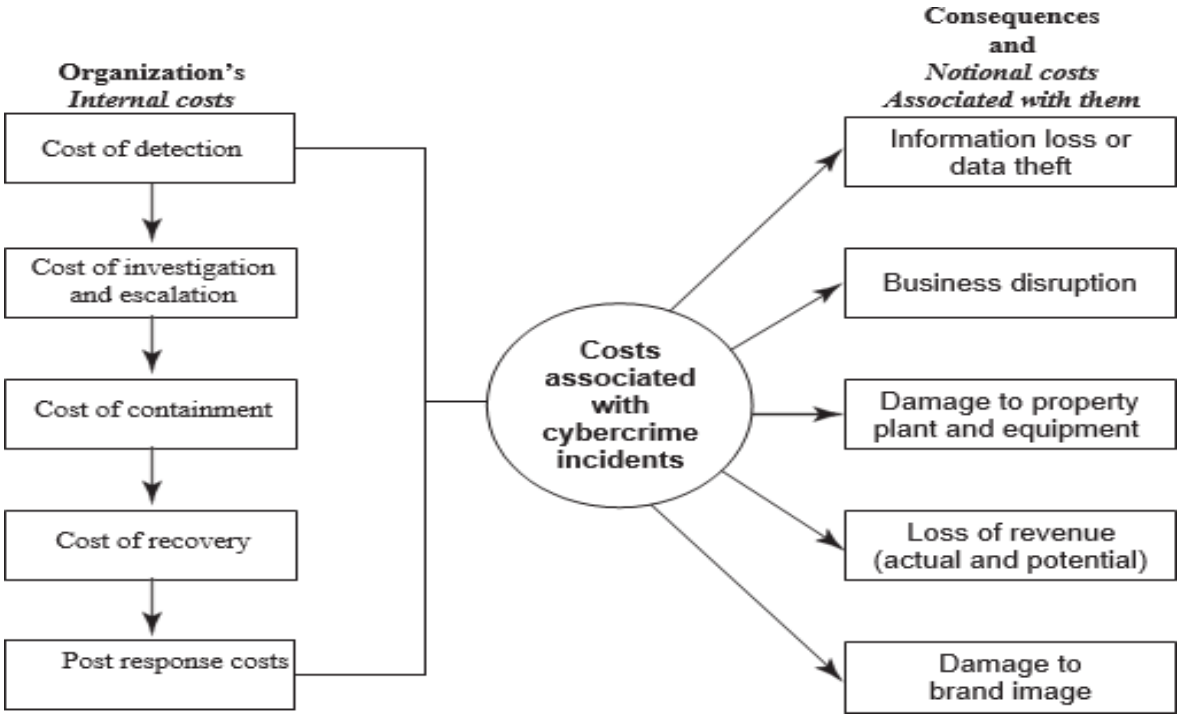


Fig: Cost of cybercrimes.

When a cybercrime incidence occurs, there are a number of internal costs associated with it for organizations and there are organizational impacts as well.

Detection and recovery constitute a very large percentage of internal costs. This is supported by a benchmark study conducted by Ponemon Institute USA carried out with the sample of 45 organizations representing more than 10 sectors and each with a head count of at least 500 employees.

- **Organizations have Internal Costs Associated with Cybersecurity Incidents**

The internal costs typically involve people costs, overhead costs and productivity losses. The internal costs, in order from largest to the lowest and that has been supported by the benchmark study mentioned:

1. Detection costs.
2. Recovery costs.
3. Post response costs.
4. Investigation costs.
5. Costs of escalation and incident management.
6. Cost of containment.

- **The consequences of cybercrimes and their associated costs, mentioned**
  1. Information loss/data theft.
  2. Business disruption.

3. Damages to equipment, plant and property.
4. Loss of revenue and brand tarnishing.
5. Other costs.

- **There are many new endpoints in today's complex networks; they include hand-held devices.**

  Again, there are lessons to learn:

1. **Endpoint protection:** It is an often-ignored area but it is IP-based printers, although they are passive devices, are also one of the endpoints.
2. **Secure coding:** These practices are important because they are a good mitigation control to protect organizations from "Malicious Code" inside business applications.
3. **HR checks:** These are important prior to employment as well as after employment.
4. **Access controls:** These are always important, for example, shared IDs and shared laptops are dangerous.
5. **Importance of security governance:** It cannot be ignored policies, procedures and their effective implementation cannot be over-emphasized.

- **Organizational Implications of Software Piracy**

  Use of pirated software is a major risk area for organizations.

  From a legal standpoint, software piracy is an IPR violation crime. Use of pirated software increases serious threats and risks of cybercrime and computer security when it comes to legal liability.

  The most often quoted reasons by employees, for use of pirated software, are as follows:

1. Pirated software is cheaper and more readily available.
2. Many others use pirated software anyways.
3. Latest versions are available faster when pirated software is used.

➔ **Web Threats for Organizations: The Evils and Perils**

Internet and the Web is the way of working today in the interconnected digital economy. More and more business applications are web based, especially with the growing adoption of cloud computing.

- **Overview of Web Threats to Organizations**

  The Internet has engulfed us! Large number of companies as well as individuals have a connection to the Internet. Employees expect to have Internet access at work just like they do at home.

  IT managers must also find a balance between allowing reasonable personal Internet use at work and maintaining office work productivity and work concentration in the office.

- **Employee Time Wasted on Internet Surfing**

  This is a very sensitive topic indeed, especially in organizations that claim to have a "liberal culture." Some managers believe that it is crucial in today's business world to have the finger on the pulse of your employees.

  People seem to spend approximately 45-60 minutes each working day on personal web surfing at work.

- **Enforcing Policy Usage in the Organization**

  An organization has various types of policies. A security policy is a statement produced by the senior management of an organization, or by a selected policy board or committee to dictate what type of role security plays within the organization.

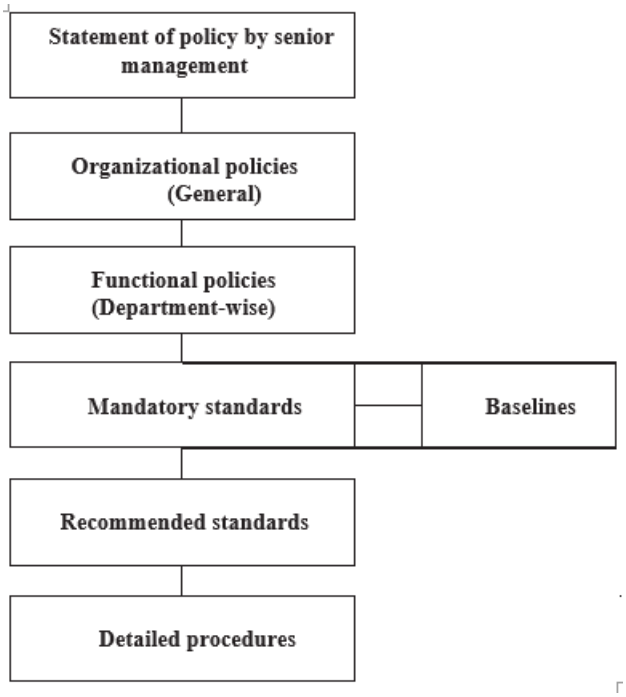


Fig: Policy hierarchy chart.

- **Monitoring and Controlling Employees' Internet Surfing**

  A powerful deterrent can be created through effective monitoring and reporting of employees' Internet surfing.

  Even organizations with restrictive policies can justify a degree of relaxation; for example, allowing employees to access personal sites only during the lunch hour or during specified hours.

- **Keeping Security Patches and Virus Signatures Up to Date**

  Updating security patches and virus signatures have now become a reality of life, a necessary activity for safety in the cyberworld! Keeping security systems up to date with security signatures, software patches, etc. is almost a nightmare for management.

- **Surviving in the Era of Legal Risks**

As website galore, most organizations get worried about employees visiting inappropriate or offensive websites. We mentioned about Children's Online Privacy Protection.

Serious legal liabilities arise for businesses from employee's misuse/inappropriate use of the Internet.

- **Bandwidth Wastage Issues**

Today's applications are bandwidth hungry; there is an increasing image content in messages and that too, involving transmission of high-resolution images.

There are tools to protect organization's bandwidth by stopping unwanted traffic before it even reaches your Internet connection.

- **Mobile Workers Pose Security Challenges**

Use of mobile handset devices in cybercrimes. Most mobile communication devices for example, the personal digital assistant

- **Challenges in Controlling Access to Web Applications**

Today, a large number of organizations' applications are web based. There will be more in the future as the Internet offers a wide range of online applications, from webmail or through social networking to sophisticated business applications.

- **The Bane of Malware**

Many websites contain malware. Such websites are a growing security threat. Although most organizations are doing a good job of blocking sites declared dangerous, cyber attackers, too, are learning. Criminals change their techniques rapidly to avoid detection.

- **The Need for Protecting Multiple Offices and Locations**

Delivery from multi-locations and teams collaborating from multi-locations to deliver a single project are a common working scenario today. Most large organizations have several offices at multiple locations.

➔ **Social Media Marketing: Security Risks and Perils for Organizations**

Social media marketing has become dominant in the industry.

According to fall 2009 survey by marketing professionals, usage of social media sites by large business-to-business (B2B) organizations shows the following:

1. Facebook is used by 37% of the organizations.
2. LinkedIn is used by 36% of the organizations.
3. Twitter is used by 36% of the organizations.
4. YouTube is used by 22% of the organizations.
5. My Space is used by 6% of the organizations.

Although the use of social media marketing site is rampant, there is a problem related to "social computing" or "social media marketing" – the problem of privacy threats.

Exposures to sensitive PI and confidential business information are possible if due care is not taken by organizations while using the mode of "social media marketing."

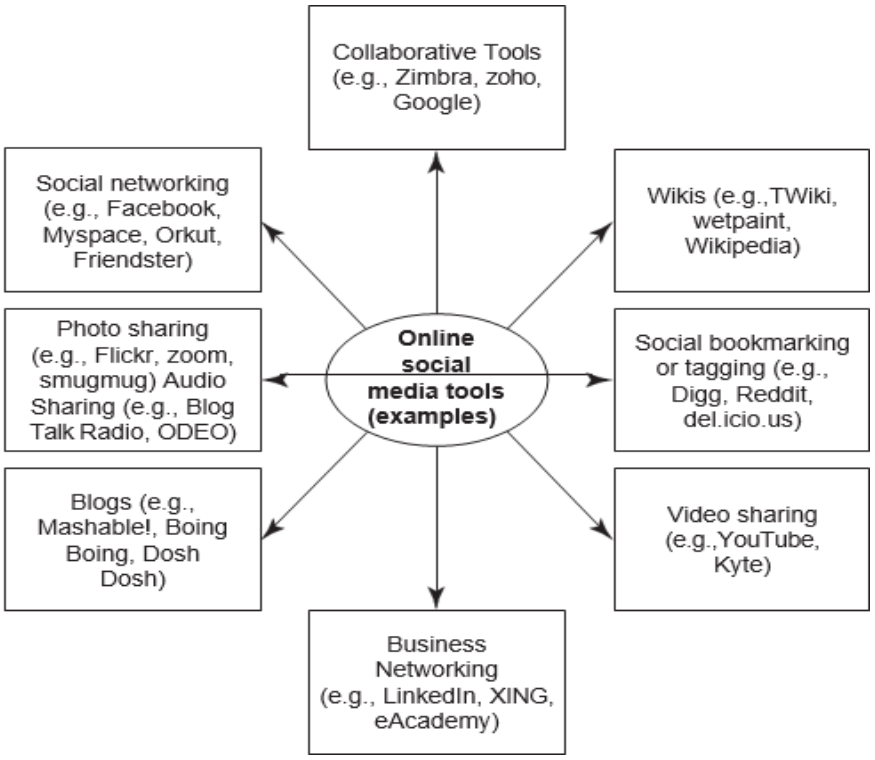


Fig: Social media - online tools.

- **Understanding Social Media Marketing**

Most professionals today use social technologies for business purposes. Most common usage include: marketing, internal collaboration and learning, customer service and support, sales, human resources, strategic planning, product development.

Following are the most typical reasons why organizations use social media marketing to promote their products and services:

1. To be able to reach to a larger target audience in a more spontaneous and instantaneous manner without paying large advertising fees.
2. To increase traffic to their website coming from other social media websites by using Blogs and social and business-networking. Companies believe that this, in turn, may increase their "page rank" resulting in increased traffic from leading search engines.
3. To reap other potential revenue benefits and to minimize advertising costs because social media complements other marketing strategies such as a paid advertising campaign.
4. To build credibility by participating in relevant product promotion forums and responding to potential customers' questions immediately.

5. To collect potential customer profiles. Social media sites have information such asuser profile data, which can be used to target a specific set of users for advertising

There are other tools too that organizations use; industry practices indicate the following:

1. Twitter is used with higher priority to reach out to maximum marketers in the technology space and monitor the space.
2. Professional networking tool LinkedIn is used to connect with and create a communityof top executives from the Fortune 500.
3. Facebook as the social group or social community tool is used to drive more traffic to Websense website and increase awareness about Websense.
4. YouTube (the video capability tool to run demonstrations of products/services, etc.) is used to increase the brand awareness and create a presence for corporate videos.
5. Wikipedia is also used for brand building and driving traffic.

WHAT IS SOCIAL COMPUTING?

The social and interactive aspect of online activity is known as social computing. The phrase may be interpreted in contrast to personal computing, which refers to the activities of single users.

Blogs, wikis, Twitter, RSS, instant messaging, multi-gaming, and open source development are just a few examples of social computing. It also includes social networking and social bookmarking sites. The concept of Web 2.0 can be interpreted as the architecture for applications that support its processes. The term "social computing" is somewhat of a misnomer. It should not be implied that social computer applications are the same as artificial intelligence programs such as socially intelligent computing. The computer is required to exhibit social capabilities and make the person using it feel more socially engaged when they are not.

BENEFITS OF SOCIAL COMPUTING

Social networking allows organizations to do many things, including disseminating information among its various users, keeping them up to date on new knowledge and experience, reducing interruptions, and connecting them with the best experts for particular needs.

The notion of "social computing" refers to increasing knowledge access speed. In addition, it allows for a wide range of information to be shared through interactions with numerous people. By connecting people and thus lowering the cost of communication, computer technology improves communication among many users. The methodology improves user performance and efficiency, increasing access to specialists. Users obtain a better performance and greater efficiency due to this method.

Social computing reduces traveling expenses since it is linked to the internet process, lowering labor and travel costs. As employee satisfaction rises, so does its role in improving performance and quality of service.

EXAMPLES OF SOCIAL COMPUTING

Social computing uses computers and software to create communities around shared interests. All of these examples and blogs, wikis, Twitter, RSS, instant messaging, multiplayer gaming, open-source development, and social networking and social bookmarking sites are all forms. Web 2.0 is closely linked to the notion of social computing.

Many less obvious kinds of social computing are accessible to us today. Consider eBay, where buyers can leave user reviews of sellers and their responses. Look to Amazon, where you may now rate the reviewer rather than only the product.

Security and Privacy Implications from Cloud Computing

There are data privacy risks associated with cloud computing. Basically, putting data in the cloud may impact privacy rights, obligations and status. There is much legal uncertainty about privacy rights in the cloud. Organizations should think about the privacy scenarios in terms of "user spheres."

There are three kinds of spheres and their characteristics are as follows:

1. **User sphere:** Here data is stored on users' desktops, PCs, laptops, mobile phones, Radio Frequency Identification (RFID) chips, etc. Organization's responsibility is to provide access to users and monitor that access to ensure misuse does not happen.
2. **Recipient sphere:** Here, data lies with recipients: servers and databases of network providers, service providers or other parties with whom data recipient shares data.
3. **Joint sphere:** Here data lies with web service provider's servers and databases. This is the in between sphere where it is not clear to whom does the data belong.

➔ **Protecting People's Privacy in the Organization**

The costs associated with cybercrimes. A key point in that discussion is that people perceive their PI/SPI to be very sensitive. From privacy perspective, people would hate to be monitored in terms of what they are doing, where they are moving.

In the US, Social Security Number is a well-established system/mechanism for uniquely identifying all American citizens; however, similar thoughts are now emerging in India. The UID Project was started by Government of India and is running through an agency called Unique Identification Authority of India (UIDAI) based on the similar concept.

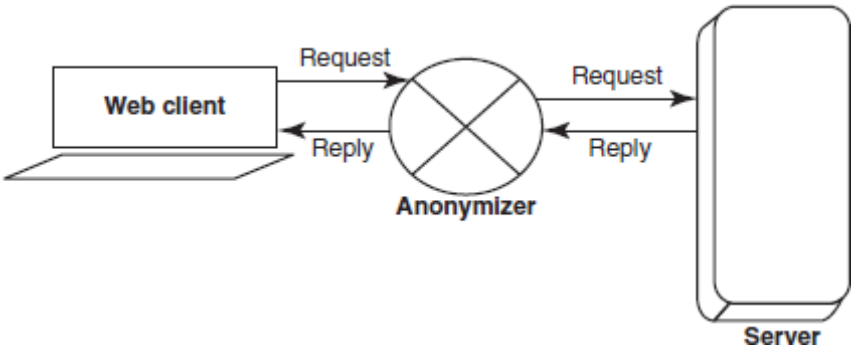


Fig: Anonymity by web proxy.